Draft ETSI EN 304 621 V1.0.5 (2026-08)



HARMONISED EUROPEAN STANDARD

Cyber Security (CYBER);
CRA;
Cybersecurity requirements for Network Management systems

Reference
DEN/CYBER-EUS-009

Keywords
CRA, cybersecurity, network management

ETSI

650 Route des Lucioles
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B
Association à but non lucratif enregistrée à la
Sous-Préfecture de Grasse (06) N° w061004871

Important notice

The present document can be downloaded from the
ETSI Search & Browse Standards application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on ETSI deliver repository.

Users should be aware that the present document may be revised or have its status changed, this information is available in the Milestones listing.

If you find errors in the present document, please send your comments to the relevant service listed under Committee Support Staff.

If you find a security vulnerability in the present document, please report it through our Coordinated Vulnerability Disclosure (CVD) program.

Notice of disclaimer & limitation of liability

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.
No recommendation as to products and services or vendors is made or should be implied.
In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

Copyright Notification

No part of this document may be reproduced in any form, by any means and in any media, without the prior written authorization of ETSI and except as expressly permitted below.
By way of exception and when the document is a normative deliverable (European Standard (EN), Technical Specification (TS), Group Specification (GS) or ETSI Standard (ES)), ETSI authorizes to reproduce and incorporate into products, services and technical documentation only those extracts (e.g. templates) that are strictly necessary for the technical implementation of the normative deliverable, to ensure compliance with the latter.
Nothing in this notice shall be construed as limiting any mandatory exceptions to copyright provided by applicable law.

© ETSI 2026.
All rights reserved.

Contents

Intellectual Property Rights 10
Foreword 10
Modal verbs terminology 11
Introduction 11
1 Scope 12
2 References 12
2.1 Normative references 12
2.2 Informative references 13
3 Definition of terms, symbols and abbreviations 14
3.1 Terms 14
3.2 Symbols 15
3.3 Abbreviations 15
4 Product context 17
4.0 Introduction 17
4.1 Product Functions 17
4.1.0 Introduction 17
4.1.1 Network functions management 17
4.1.2 Software defined network management 18
4.1.3 Ecosystem management 18
4.1.4 ICT device management 19
4.2 Product Architecture 19
4.2.0 Introduction 19
4.2.1 Network architecture 20
4.2.1.1 Software Defined Network 21
4.2.1.2 Application in a SDN 22
4.2.1.3 Pocket deployment 22
4.2.1.4 Devices using provided connectivity 23
4.2.2 Controller design 23
4.2.3 Applying encryption in IETF RFC 1122 24
4.2.4 Inventory, device and subjects management 24
4.2.4.1 Identifying privileged subjects 24
4.2.4.2 Device management 24
4.2.4.3 Inventory management 25
4.3 Operational Environment 25
4.3.1 General description 25
4.3.2 Physical/Hardware environment 25
4.3.3 Logical/Software environment 26
4.3.4 Connectivity aspects 27
4.3.4.0 Introduction 27
4.3.4.1 Identity management 27
4.3.4.2 Attribute-Based Access Control 27
4.3.4.3 Role based authorisation 28
4.3.4.4 Trust initialisation 28
4.3.4.5 Risk management 28
4.4 Distribution of Security Functions 29
4.4.0 Introduction 29
4.4.1 Ancillary functionality 29
4.4.2 Related core functionalities 29
4.4.3 Security functions provided to other products 30
4.5 Users 30
4.6 Use Cases 30
4.6.0 Introduction 30
4.6.1 UC-1-HOME: Home NMS 31
4.6.2 UC-2-ENTER-*: Enterprise network 32

4.6.3 UC-3-TELCO: Telecommunications network 34
4.6.4 UC-4-SDN: Logical network deployment without physical hardware 35
4.6.5 UC-5-HYBRID: Physical network deployment with RDPS 36
4.6.6 UC-6-IOT: IoT network with monitoring data collection 39
4.6.7 UC-7-ICT: ICT Network Elements 40
4.6.8 UC-8-FLEET: Fleet management 42
4.6.9 UC-9-RESEARCH: Research NMS 43
4.6.10 UC-10-AIRGAP: Airgapped secure facility 43
4.6.11 UC-11-WATER: Management of distributed infrastructure 44

5 Technical requirements for products 44
5.1 Introduction - Applicability of the requirements 44
5.2 Appropriate level of cybersecurity 46
5.3 No known exploitable vulnerabilities 47
5.4 Secure by default configuration 47
5.5 Security updates 48
5.6 Authentication and access control 49
5.7 Confidentiality protection 50
5.8 Integrity protection 51
5.9 Data minimisation 51
5.10 Availability protection 52
5.11 Non-interference 52
5.12 Attack surface minimisation 53
5.13 Exploit mitigation 53
5.14 Monitoring 54
5.15 Factory reset and data portability 56

6 Assessment criteria for compliance with technical requirements 56
6.1 Introduction to the assessment and compliance criteria 56
6.1.0 Assessment guide 56
6.2 Appropriate level of cybersecurity 58
6.2.1 CYB_GENERAL-1 58
6.2.2 CYB_GENERAL-2 58
6.2.3 CYB_GENERAL-3 59
6.2.4 CYB_GENERAL-4 59
6.2.5 CYB_GENERAL-5 60
6.2.6 CYB_GENERAL-6 60
6.2.7 CYB_GENERAL-7 61
6.2.8 CYB_OPS-8 61
6.2.9 CYB_OPS-9 62
6.2.10 CYB_OPS-10 62
6.3 No known exploitable vulnerabilities 62
6.3.1 KEV_EXPLOIT-1 62
6.4 Secure by default configuration 64
6.4.1 SBD_TECH-1 64
6.4.2 SBD_TECH-2 64
6.4.3 SBD_TECH-3 65
6.5 Security updates 65
6.5.1 SU_UPDATES-1 65
6.5.2 SU_UPDATES-2 66
6.5.3 SU_UPDATES-3 66
6.5.4 SU_UPDATES-4 67
6.5.5 SU_UPDATES-5 67
6.5.6 SU_UPDATES-6 68
6.5.7 SU_UPDATES-7 68
6.5.8 SU_UPDATES-8 69
6.5.9 SU_UPDATES-9 69
6.5.10 SU_UPDATES-10 70
6.5.11 SU_UPDATES-11 70
6.5.12 SU_UPDATES-12 71
6.5.13 SU_UPDATES-13 71
6.5.14 SU_UPDATES-14 72

6.5.15 SU_UPDATES-15 72
6.6 Authentication and access control 73
6.6.1 AAC_AUTH-1 73
6.6.2 AAC_AUTH-2 73
6.6.3 AAC_AUTH-3 74
6.6.4 AAC_AUTH-4 74
6.6.5 AAC_AUTH-5 75
6.6.6 AAC_AUTH-6 76
6.6.7 AAC_AUTH-7 76
6.6.8 AAC_AUTH-8 77
6.6.9 AAC_AUTH-9 77
6.6.10 AAC_AUTH-10 78
6.6.11 AAC_AUTH-11 78
6.6.12 AAC_AUTH-12 79
6.6.13 AAC_MACHINE-13 80
6.6.14 AAC_MACHINE-14 80
6.7 Confidentiality protection 81
6.7.1 CON_INGEST-1 81
6.7.2 CON_INGEST-2 81
6.7.3 CON_CRYPTO-3 82
6.7.4 CON_CHANNEL-4 82
6.7.5 CON_CHANNEL-5 83
6.8 Integrity protection 83
6.8.1 INT_CONF-1 83
6.8.2 INT_CONF-2 84
6.8.3 INT_CONF-3 84
6.8.4 INT_ROTATE-4 85
6.8.5 INT_ROTATE-5 85
6.8.6 INT_ROTATE-6 86
6.9 Data minimisation 86
6.9.1 DM_RETENTION-1 86
6.9.2 DM_RETENTION-2 87
6.9.3 DM_RETENTION-3 87
6.10 Availability protection 88
6.10.1 AP_HA-1 88
6.10.2 AP_HA-2 88
6.10.3 AP_HA-3 89
6.10.4 AP_HA-4 89
6.10.5 AP_HA-5 90
6.10.6 AP_HA-6 90
6.10.7 AP_HA-7 91
6.11 Non-interference 92
6.11.1 IM_SEGMENT-1 92
6.11.2 IM_SEGMENT-2 92
6.11.3 IM_SEGMENT-3 93
6.12 Attack surface minimisation 94
6.12.1 MAS_TECH-1 94
6.12.2 MAS_TECH-2 94
6.13 Exploit mitigation 95
6.13.1 EMM_ROUTE-1 95
6.13.2 EMM_ROUTE-2 95
6.13.3 EMM_ROUTE-3 96
6.14 Monitoring 96
6.14.0 Logging tests 96
6.14.1 MON_LOG-1 96
6.14.2 MON_LOG-2 97
6.14.3 MON_LOG-3 97
6.14.4 MON_LOG-4 98
6.14.5 MON_LOG-5 98
6.14.6 MON_LOG-6 99
6.14.7 MON_LOG-7 100
6.14.8 MON_LOG-8 100

6.14.9 MON_LOG-9 101
6.14.10 MON_LOG-10 101
6.14.11 MON_LOG-11 102
6.14.12 MON_LOG-12 102
6.14.13 MON_LOG-13 103
6.14.14 MON_METRICS-14 103
6.14.15 MON_METRICS-15 103
6.14.16 MON_METRICS-16 104
6.14.17 MON_METRICS-17 104
6.15 Factory reset and data portability 106
6.15.1 DRT_DELETE-1 106
6.15.2 DRT_DELETE-2 107

Annex A (informative): Relationship between the present document and the essential cybersecurity requirements of EU Regulation (EU) 2024/2847 108

Annex B (informative): Security analysis 112

B.0 Overview 112

B.1 Assets 112
B.1.1 Data 112
B.1.2 Hardware 113
B.1.3 Product and managed element functions 113

B.2 Risk factors 113
B.2.1 Overview 113
B.2.2 RF-ACC_ASSETS: Accessibility of network connected to product assets 113
B.2.3 RF-COMPLEX_CONF: Complexity of network configuration 113
B.2.4 RF-COMPLEX_FUN: Complexity of product functions 114
B.2.5 RF-SENS_ASSETS: Sensitivity of managed assets 114
B.2.6 RF-SENS_FUN: Sensitivity of functions of product 114
B.2.7 RF-NUM: Number of managed elements 115
B.2.8 RF-ADMIN: Availability and skill of administration 115

B.3 Assumptions 115

B.4 Mapping of risk factors to use cases 115
B.4.1 UC-1-HOME security analysis 116
B.4.2 UC-2-ENTER security analysis 116
B.4.3 UC-3-TELCO security analysis 117
B.4.4 UC-4-SDN security analysis 117
B.4.5 UC-5-HYBRID security analysis 117
B.4.6 UC-6-IOT security analysis 117
B.4.7 UC-7-ICT security analysis 118
B.4.8 UC-8-FLEET security analysis 119
B.4.9 UC-9-RESEARCH security analysis 119
B.4.10 UC-10-AIRGAP security analysis 119
B.4.11 UC-11-WATER security analysis 119

B.5 Threats and security analysis of threats 119
B.5.1 Security analysis methodology 119
B.5.2 List of threats, risk assessments, and mitigations 120
B.5.2.0 Introduction 120
B.5.2.1 TH-UEVU: Unknown exploitable vulnerabilities 120
B.5.2.2 TH-KEVU: Known exploitable vulnerabilities 121
B.5.2.3 TH-CACC: Circumvention of access control 123
B.5.2.4 TH-DSTP: Unauthorised access to data stored 124
B.5.2.5 TH-UADT: Unauthorised access to data transmitted 125
B.5.2.6 TH-CONF: Access to assets via configuration errors 126
B.5.2.7 TH-AVAI: Denial of service attack on product 127
B.5.2.8 TH-DDoS: Interference with other devices 129

Annex C (informative): Relationship between the present document and any related ETSI standards 131

Annexes D to F: Void....132

Annex G (informative): Guidelines on the implementation of the present document....133
G.0 Guidance on use-cases....133
G.1 Guidance on no known exploitable vulnerabilities requirements....133
G.2 Guidance on secure by default configuration requirements....133
G.3 Guidance on authentication and access control requirements....134
G.4 Guidance on confidentiality protection requirements....134
G.5 Guidance on integrity protection requirements....135
G.6 Guidance on availability protection requirements....135
G.7 Guidance on non-interference requirements....135
G.8 Guidance on exploit mitigation requirements....136
G.9 Guidance on exploit mitigation requirements....136
G.10 Guidance on monitoring requirements....136

Annexes H to J: Void....137

Annex K (normative): Generic cryptographic requirements and assessment....138

K.1 Cryptography....138
K.1.1 Requirement....138
K.1.2 Assessment of product cryptographic configuration....139
K.1.2.0 General....139
K.1.2.1 Assessment of ACM-listed cryptographic mechanisms....139
K.1.2.1.1 Assessment objective....139
K.1.2.1.2 Assessment preparation....139
K.1.2.1.3 Assessment activities....139
K.1.2.1.4 Assessment evidence....140
K.1.2.1.5 Assessment verdict....140
K.1.2.2 Assessment of ACM-extended cryptographic mechanisms....140
K.1.2.2.1 Assessment objective....140
K.1.2.2.2 Assessment preparation....140
K.1.2.2.3 Assessment activities....140
K.1.2.2.4 Assessment evidence....141
K.1.2.2.5 Assessment verdict....141
K.1.2.3 Assessment of interoperability-based cryptographic mechanisms....141
K.1.2.3.1 Assessment objective....141
K.1.2.3.2 Assessment preparation....141
K.1.2.3.3 Assessment activities....141
K.1.2.3.4 Assessment evidence....142
K.1.2.3.5 Assessment verdict....142

K.2 Crypto agility....142
K.2.1 Requirement....142
K.2.2 Assessment of crypto-agility....143
K.2.2.1 Assessment objective....143
K.2.2.2 Assessment preparation....143
K.2.2.3 Assessment activities....144
K.2.2.4 Assessment evidence....144
K.2.2.5 Assessment verdict....144

K.3 ACM-extended cryptographic mechanisms....144
K.3.1 Requirement....144
K.3.2 List of ACM-extended cryptographic mechanisms....144
K.3.3 Assessment....145

K.4 Interoperability-based cryptographic mechanisms....145
K.4.1 Requirement....145
K.4.2 List of interoperability-based cryptographic mechanisms....145
K.4.3 Assessment....145

Annexes L to Q: Void 146

Annex R (normative): Additional provisions for products relying on Remote Data Processing Solutions (RDPS) 147

R.1 Scope & Applicability 147

R.2 RDPS as a product-boundary extension 147

R.3 Threat Model 148
R.3.1 Introduction 148
R.3.2 Assets 148
R.3.3 Threat catalogue 149
R.3.3.1 Overview 149
R.3.3.2 T-RDPS-01 Loss of data authenticity of interactions across the RDPS boundary 149
R.3.3.3 T-RDPS-02 Loss of integrity of interactions across the RDPS boundary 149
R.3.3.4 T-RDPS-03 Unauthorised disclosure of interactions across the RDPS boundary 150
R.3.3.5 T-RDPS-04 Unavailability, unacceptable delay, or intolerable degradation of interactions across the RDPS boundary 150
R.3.4 Assets to Threats mapping 150

R.4 Security Requirements 150
R.4.1 Applicability of annex R requirements 150
R.4.2 Local product side requirements 151
R.4.2.1 REQ-RDPS-L-AUTH Data authenticity of interactions received from the RDPS side 151
R.4.2.2 REQ-RDPS-L-INTEG Integrity of interactions received from the RDPS side 151
R.4.2.3 REQ-RDPS-L-CONF Confidentiality of data exchanged with the RDPS side 151
R.4.2.4 REQ-RDPS-L-AVAIL Availability 152
R.4.3 RDPS side requirements 152
R.4.3.1 REQ-RDPS-R-AUTH Data authenticity of interactions received from the local product side 152
R.4.3.2 REQ-RDPS-R-INTEG Integrity of interactions received from the local product side 152
R.4.3.3 REQ-RDPS-R-CONF Confidentiality of data exchanged with the local product side 152
R.4.3.4 REQ-RDPS-R-AVAIL Availability 153
R.4.4 Threats ↔ Requirements mapping 153

R.5 Conformity assessment 153
R.5.1 Overview 153
R.5.2 Local product side assessments 153
R.5.2.1 REQ-RDPS-L-AUTH assessment 153
R.5.2.1.1 Objective 153
R.5.2.1.2 Preparation 153
R.5.2.1.3 Activities 154
R.5.2.1.4 Verdict 154
R.5.2.1.5 Evidence 154
R.5.2.2 REQ-RDPS-L-INTEG assessment 154
R.5.2.2.1 Objective 154
R.5.2.2.2 Preparation 154
R.5.2.2.3 Activities 155
R.5.2.2.4 Verdict 155
R.5.2.2.5 Evidence 155
R.5.2.3 REQ-RDPS-L-CONF assessment 155
R.5.2.3.1 Objective 155
R.5.2.3.2 Preparation 155
R.5.2.3.3 Activities 155
R.5.2.3.4 Verdict 156
R.5.2.3.5 Evidence 156
R.5.2.4 REQ-RDPS-L-AVAIL assessment 156
R.5.2.4.1 Objective 156
R.5.2.4.2 Preparation 156
R.5.2.4.3 Activities 156
R.5.2.4.4 Verdict 157
R.5.2.4.5 Evidence 157
R.5.3 RDPS side assessments 157

R.5.3.1 REQ-RDPS-R-AUTH assessment 157
R.5.3.1.1 Objective 157
R.5.3.1.2 Preparation 157
R.5.3.1.3 Activities 157
R.5.3.1.4 Verdict 158
R.5.3.1.5 Evidence 158
R.5.3.2 REQ-RDPS-R-INTEG assessment 158
R.5.3.2.1 Objective 158
R.5.3.2.2 Preparation 158
R.5.3.2.3 Activities 158
R.5.3.2.4 Verdict 159
R.5.3.2.5 Evidence 159
R.5.3.3 REQ-RDPS-R-CONF assessment 159
R.5.3.3.1 Objective 159
R.5.3.3.2 Preparation 159
R.5.3.3.3 Activities 159
R.5.3.3.4 Verdict 159
R.5.3.3.5 Evidence 160
R.5.3.4 REQ-RDPS-R-AVAIL assessment 160
R.5.3.4.1 Objective 160
R.5.3.4.2 Preparation 160
R.5.3.4.3 Activities 160
R.5.3.4.4 Verdict 160
R.5.3.4.5 Evidence 161

Annex S (informative): Change history 162

History 163

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables (European Standard (EN), Technical Specification (TS), Group Specification (GS) or ETSI Standard (ES)) may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the ETSI IPR online database.

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM**® and the GSM logo are trademarks registered and owned by the GSM Association.

Foreword

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Security (CYBER), and is now submitted for the combined Public Enquiry and Vote phase of the ETSI Standardisation Request deliverable Approval Procedure (SRdAP).

The present document has been prepared under the Commission's standardisation request C(2025) 618 final [i.3] to provide one voluntary means of conforming to the requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) (CRA) [i.1].

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

Proposed national transposition dates	
Date of latest announcement of this EN (doa):	3 months after ETSI publication
Date of latest publication of new National Standard or endorsement of this EN (dop/e):	6 months after doa
Date of withdrawal of any conflicting National Standard (dow):	18 months after doa

Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the ETSI Drafting Rules (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.

Introduction

The present document defines cybersecurity requirements for products with digital elements (product) whose intended purpose is to manage connected network elements, such as servers, routers, switches, workstations, printers or mobile devices, by monitoring them and controlling their network operations and configuration.The present document is part of a broader group of vertical standards developed to support the Cyber Resilience Act (CRA) [i.1] and should not be considered a standalone resource. Users are expected to consult it in conjunction with the CRA itself [i.1], the associated legal guidance [i.20], as well as relevant horizontal and neighbouring vertical standards cited in clause 2, such as prEN 40000-1-1 [i.4], prEN 40000-1-2 [i.5], prEN 40000-1-3 [i.6], and prEN 40000-1-4 [i.7]. Material already addressed in those sources is not repeated in the present document.

The present document provides the technical cybersecurity requirements for the products in scope, following a risk-based approach in support of the Cyber Resilience Act (CRA) [i.1]. The technical cybersecurity requirements are thereby proportionate to the intended purpose, reasonably foreseeable use, deployment context, and threat exposure of the products.

Clause 4 does not contain technical requirements; it describes the product context that is considered for the application of the present document.

Clause 4 also defines Use Cases (UCs) that represent the main deployment scenarios reflecting the intended purpose and reasonably foreseeable use of the product, which serve as the basis for identifying relevant cybersecurity risks.

Clause 5 specifies technical cybersecurity requirements for the product to mitigate the identified risks, including their applicability conditions.

Clause 6 specifies the assessment criteria and compliance verification procedures with the requirements of clause 5.

Annex A maps the technical requirements of the present document with the essential requirements of the CRA [i.1] regulation.

Annex B informs about the methodology used to assess the security risks of the products in their context.

Annex C informs the possible relationship between the product in the present document and other possible vertical products and their corresponding CRA-related harmonised standards.

Annex G presents further information on guidance for the application of the present document.

Annex K supports the definition of the cryptographic requirements and assessment criteria used by the present document.

Annex R provides supplementary requirements and assessment provisions where a product relies on Remote Data Processing Solutions (RDPS) for the provision or support of one or more product functions.

1 Scope

The present document specifies technical requirements and corresponding assessment criteria for Network Management Systems related to cybersecurity. The products with digital elements in scope, thereafter "NMS":

- are specified within the "technical description" of the "category of product" number "6" by the Commission Implementing Regulation (EU) 2025/2392 [i.2] as: "Products with digital elements that manage connected network elements, such as servers, routers, switches, workstations, printers or mobile devices, by monitoring them and controlling their network operations and configuration".

  This category includes but is not limited to end-to-end management systems and dedicated configuration management systems, such as controllers for software-defined networking.

- The products with digital elements in scope are only covered within the product context described in clause 4 of the present document.

The present document covers those products to demonstrate compliance with essential cybersecurity requirements in the Regulation (EU) 2024/2847 [i.1] Annex I Part I under the conditions identified in annex A.

This includes, but is not limited to, Mobile Device Management systems and Software Defined Networking, e.g when an SDN-controller is a stand-alone product using a network management protocol as its South Bound Interface (SBI).

NMS intended for use in the industrial Operational Technology (OT) [i.18] domain are excluded from the scope of the present document.

An NMS is a product controlling at least partially connected devices with network access. Despite its central positioning, an NMS can be an aggregate of several components, including but not limited to: end-to-end management systems, dedicated configuration management systems, or controllers for software-defined networking.

NMS can be composed of several components or can implement additional functions that are outside the scope of the present document.

EXAMPLE: Aggregate product design would be an implementation where the operating system acts as an abstraction layer for the system(s) that host the NMS, or the networking interfaces.

2 References

2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the ETSI docbox.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

[1] ENISA Report 1747792503 (version 2 - April 2025): "European Cybersecurity Certification Group Sub-group on Cryptography - Agreed Cryptographic Mechanisms" [ACM].

[2] IETF RFC 1122 (October 1989): "Requirements for Internet Hosts - Communication Layers".

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader's understanding, but are not required for conformance to the present document.

[i.1] Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

[i.2] Commission Implementing Regulation (EU) 2025/2392 of 28 November 2025 on the technical description of the categories of important and critical products with digital elements pursuant to Regulation (EU) 2024/2847 of the European Parliament and of the Council.

[i.3] Standardisation request M/606 - C(2025)618: "Commission Implementing decision of 3.2.2025 on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (CENELEC) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020and Directive (EU) 2020/1828 (Cyber Resilience Act)".

[i.4] prEN 40000-1-1: "Cybersecurity requirements for products with digital elements – Vocabulary"(produced by CEN CENELEC).

NOTE: Version and date to be added upon its publication by CEN CENELEC.

[i.5] prEN 40000-1-2: "Cybersecurity requirements for products with digital elements – Part 1-2: Principles, product risk management, and lifecycle activities"(produced by CEN CENELEC).

NOTE: Version and date to be added upon its publication by CEN CENELEC.

[i.6] prEN 40000-1-3: "Cybersecurity requirements for products with digital elements – Part 1-3: Vulnerability handling"(produced by CEN CENELEC).

NOTE: Version and date to be added upon its publication by CEN CENELEC.

[i.7] prEN 40000-1-4: "Cybersecurity requirements for products with digital elements – Part 1-4: Security controls – Generic security requirements"(produced by CEN CENELEC).

NOTE: Version and date to be added upon its publication by CEN CENELEC.

[i.8] IETF RFC 1918 (February 1996): "BCP 5: Address Allocation for Private Internets".

[i.9] NIST SP 800-63B-4: "Authentication & Authenticator Management".

[i.10] ISO/IEC 27000:2026: "Information technology — Security techniques — Information security management systems — Overview and vocabulary".

[i.11] ETSI EN 304 624 (V1.1.1): "Cyber Security (CYBER); CRA; Cybersecurity requirements for Public key infrastructure and digital certificate issuance software".

[i.12] ETSI EN 304 620 (V1.1.1): " Cyber Security (CYBER); CRA; Cybersecurity requirements for Virtual Private Networks (VPNs)".

[i.13] CEN/CLC EN 50770-4: "Security for Operational Technologies - Part 4: Security Profile for products with digital elements with the function of virtual private network (VPN)" (produced by CEN CENELEC).

[i.14] ETSI EN 304 622 (V1.1.1): "Cyber Security (CYBER); CRA; Cybersecurity requirements for Security information and event management (SIEM) systems".

[i.15] ETSI EN 304 626 (V1.1.1): "Cyber Security (CYBER); CRA; Cybersecurity requirements for operating systems".

[i.16] ETSI EN 304 627 (V1.1.1): "Cyber Security (CYBER); CRA; Cybersecurity requirements for routers, modems intended for the connection to the internet, and switches".

[i.17] ETSI EN 304 642 (V1.1.1): "CYBER; CRA; Cybersecurity Requirements for Network Functions of Telecommunications Systems".

[i.18] Example source for DDoS related threat reports.

[i.19] prEN 50770 series: "Security for operational technologies" (produced by CENELEC).

[i.20] EC: "Commission CRA draft legal guidance".

[i.21] BSI Technical Guideline TR-02102-1 (2026-01): "Cryptographic Mechanisms: Recommendations and Key Lengths".

[i.22] BSI Technical Guideline TR-02102-2 (2026-01): "Cryptographic Mechanisms: Recommendations and Key Lengths: Use of Transport Layer Security (TLS)".

[i.23] BSI Technical Guideline TR-02102-3 (2026-01): "Cryptographic Mechanisms: Recommendations and Key Lengths – Use of Internet Protocol Security (IPsec) and Internet Key Exchange (IKEv2)".

[i.24] BSI Technical Guideline TR-02102-4 (2026-01): "Cryptographic Mechanisms: Recommendations and Key Lengths – Use of Secure Shell (SSH)".

3 Definition of terms, symbols and abbreviations

3.1 Terms

For the purposes of the present document, the terms given in Regulation (EU) 2024/2847 [i.1], prEN 40000-1-1 [i.4] and the following apply:

component: software or hardware intended for integration into an electronic information system

cryptographic mechanism: security-related procedure using cryptography

cryptographic property: property provided or supported by a cryptographic mechanism

NOTE 1: The term "cryptographic mechanism" is used in the present document as an umbrella term covering the categories used in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [1], including cryptographic algorithms, primitives, schemes, protocols, protocol profiles, cipher suites, modes of operation, constructions and parameter sets.

NOTE 2: The terms "cryptographic primitive", "cryptographic construction", "cryptographic scheme" and "cryptographic protocol" are used consistently with the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [1].

NOTE 3: A cryptographic mechanism can be specified at different levels of abstraction. For example, AES is a cryptographic primitive, AES-GCM is a mode of operation / authenticated encryption construction, TLS 1.3 is a protocol, a TLS 1.3 restricted cipher-suite profile is a protocol profile, and TLS_AES_128_GCM_SHA256 is a cipher suite.

NOTE 4: Cryptographic properties include, for example, confidentiality, integrity, authenticity, entity authentication, message authentication, key establishment, key confirmation, replay protection, collision resistance, second-preimage resistance, pre-image resistance, signature unforgeability, non-repudiation, forward secrecy and password-verifier protection. Where relevant, a cryptographic property can be expressed using a formal cryptographic notion, for example IND-CPA, IND-CCA, IND-CCA2, EUF-CMA, SUF-CMA or authenticated key exchange security.

NOTE 5: A cryptographic property is distinct from a product-level technical requirement, although it can support such a requirement. For example, a secure communication requirement can rely on cryptographic properties such as confidentiality, integrity and authentication.

forward proxy server: proxy server with intelligent web-caching and improvements of accelerating data transmissions combined with access controls

log: record of an operational event

machine user: virtual user used to access the system programming interfaces

managed element: physical or virtual device managed by the product

product user: consumers or customers or entities like companies and institutions that operate the product in its intended and foreseeable use case

secure channel: cryptographically protected communication channel

subject: system user, machine user, or a process being authenticated by the identity provider

system user: person having the credentials to login to the product to operate administrative actions to control and maintain the managed element

trace: record of a system status with all relevant data that can be gathered

3.2 Symbols

Void.

3.3 Abbreviations

For the purposes of the present document, the following abbreviations apply:

ABAC	Attribute-Based Access Control
ACL	Access Control Lists
ACM	Agreed Cryptographic Mechanisms
ACN	Agenzia per la Cybersicurezza Nazionale

NOTE: In English: National Cybersecurity Agency of Italy.

AES	Advanced Encryption Standard
AES-GCM	Advanced Encryption Standard - Galois/Counter Mode
AES-XTS	Advanced Encryption Standard in XEX-based Tweaked Codebook mode with Ciphertext Stealing
API	Application Programming Interface
ARP	Address Resolution Protocol
AVAI	Availability
C2SP	Community Cryptography Specification Project
CA	Certificate Authority
CACC	Circumvention of Access Control
CISA	Cybersecurity and Infrastructure Security Agency
CONF	Confidentiality
CPU	Central Processing Unit
CRA	Cyber Resilience Act
CSP	Communication System Provider
CVE	Common Vulnerabilities and Exposures
DA	Data Asset

DB	Database
DDoS	Distributed Denial of Service
DHCP	Dynamic Host Configuration Protocol
DNS	Domain Name System
eBPF	extended Berkeley Packet Filtering
ECCG	European Cybersecurity Certification Group
EMP	Electromagnetic Pulse
EUVD	European Union Vulnerability Database
GDPR	General Data Protection Regulation
GUI	Graphical User Interface
HKDF	HMAC-based Key Derivation Function
HMAC	Hash-based Message Authentication Code
HTTPS	Hypertext Transfer Protocol Secure
HW	Hardware
IaaS	Infrastructure as a Service
IAM	Identity and Access Management
ICT	Information and Communication Technology
ID	Identity or Identifier
IdP	Identity Provider
INTEG	Integrity
IoT	Internet of Things
IP	Internet Protocol
ISO	International Organization for Standardization
IT	Information Technology
KEV	Known Exploited Vulnerability
MDM	Mobile Device Management
MFA	Multi Factor Authentication
MPLS	Multiprotocol Label Switching
NE	Network Element
NIST	National Institute of Standards and Technology
NMS	Network Management System
NVD	National Vulnerability Database
OCI	Open Container Initiative
OE	Operational Environment
OS	Operating System
OSI	Open Systems Interconnection
OT	Operational Technology
PaaS	Platform as a Service
PC	Personal Computer
PIA	Privacy Impact Assessments
PII	Personally Identifiable Information
PKI	Public Key Infrastructure
QoS	Quality of Service
RAN	Radio Access Network
RDPS	Remote Data Processing Solution
REQ	Requirement
RF	Radio Frequency
RF-NUM	Radio Frequency Number
RTO	Recovery Time Objective
SaaS	Software as a Service
SBI	South-Bound Interface
SDK	Software Development Kit
SDN	Software Defined Networks
SFP/SFP+	Small Form-factor Pluggable/Plus
SIEM	Security Information and Event Management
SRU	Service Requesting Users
SSH	Secure Socket Shell
TCP	Transmission Control Protocol
TCP/IP	Transmission Control Protocol/Internet Protocol
TH	Threat
TLS	Transport Layer Security
TR	Technical Requirement

UADT	Unauthorised Access to Data Transfer
UC	Use Case
UDP	User Datagram Protocol
UEVU	Unknown Exploitable Vulnerability
URI	Uniform Resource Identifier
VPN	Virtual Private Network

4 Product context

4.0 Introduction

This clause details the product context for network management systems. Product context is descriptive, and clause 4 does not contain normative requirements. Instead it is a tool for the manufacturer of NMS products that describes NMS products in greater detail and provides information regarding the functions, architecture, operational environment, distribution of security functions, and common use cases for network management systems.

The information below is provided as a tool for manufacturers of NMS products that wish to conform to the present document and offers insight into how a specific product fits within the scope of the present document and which of the technical cybersecurity requirements detailed in clause 5 apply to a specific product.

Network management systems consist of a variety of software and hardware products that enable their user to oversee a network of connected devices. This generally includes configuration, maintenance, and monitoring of the user's network so that it remains functional and connected. Beyond this most basic purpose and description, NMS products and their implementations vary widely.

The information below offers an overview of NMS within the scope of the present document and culminates in descriptive use cases that may assist manufacturers as models for determining the appropriate treatment of risk and mitigations necessary to apply to similar products.

4.1 Product Functions

4.1.0 Introduction

The following list of essential functions keeps the NMS self-secure and properly functioning during its operation and in its intended environment:

- Network function configuration and change management
- Access management to the product, and depending on the use case, to the connected devices
- Collection and evaluation of metrics to support monitoring of network operation
- Asset management through device discovery, inventory maintenance and depending on the use case topology map generation

4.1.1 Network functions management

Supporting use-cases:

- Home network deployment
- Enterprise network
- Telecom network

The Network Functions Management typically grows in dependency of the number of the connected Service Requesting Users (SRU) and of the network purpose. Complexity and the number of supported functions in the product is proportional to the risk level of the network. While home networks can tolerate loss of connectivity to various streaming services, telecom networks can not stop serving critical infrastructure without a large impact to society.

Network functions management inherits the essential functions listed in clause 4.1 and is characterised by the following functions:

- Fault detection, reaction and recovery from fail state.
- Functional resilience in terms of maintaining correct operation under abnormal network conditions, e.g. connection loss to managed elements.
- Depending on the use case, functional resilience in the event of:
    1) loss of connectivity to managed elements;
    2) loss of required supporting network services such as time synchronization or backup services;
    3) or loss of power.
- Produce and rely monitoring data for security and operational analysis.
- Provide execution environment for 3rd. party applications and workloads.

4.1.2 Software defined network management

Supporting use-cases:

- Logical network deployment without physical hardware
- Physical network deployment with RDPS

Software Defined Network (SDN) could be considered as part of network functions management, but it is separated to its own subgroup due to its volatile nature. In the SDN, the topology does not need to depend on the physicality of the infrastructure. The application workload sees a change in the networking as a temporal connectivity issue, and resumes operation when the packets continue flowing.

SDN inherits the essential functions listed in clause 4.1, can implement functions listed in clause 4.1.1, but are characterised by the following functions:

- Dynamic routing and switching control.
- Depending on the use case, resource provisioning based on requests.

4.1.3 Ecosystem management

Supporting use-cases:

- IoT network with monitoring data collection

Ecosystem management combines elements of a network controller with higher level application value. It could be considered as part of network functions management, but it is separated to its own subgroup due to its tight integration to the business logic.

The user end devices execute a well defined function in the deployment context and do not participate in the bulk traffic flow management like clause 4.1.1 does. The devices are often deployed to networks where connectivity and the network design is provided from the outside of the product control.

Ecosystem management inherits the essential functions listed in clause 4.1. The ecosystem can implement the following functions:

- Device software delivery

- Key distribution

4.1.4 ICT device management

Supporting use-cases:

- ICT Network Elements
- Server and host fleet lifecycle management

Device management can be considered to be a specialisation of ecosystem management. It combines the partial or full control of the connected devices to device governance function.

Device management inherits the essential functions listed in clause 4.1, can implement functions listed in clause 4.1.3, but are characterised by the following functions:

- Installed software reporting or in control in the managed element
- Full or partial remote removal of data
- Device tracking and compliance control
- Remote control of device application features

EXAMPLE: Market implementations: Widely deployed proprietary features from well-known brands such as lost or stolen phone retrieval functions or children's screen time parental control applications, etc.

4.2 Product Architecture

4.2.0 Introduction

Network management systems are commonly deployed using centralised management services that provide command, control, monitoring, and administration functions.

Depending on the design and autonomy of the managed elements, some elements may continue limited operation when connectivity to the network management system is unavailable. In larger deployments, network design and operational parameters can affect the reliability and scalability of connectivity between managed elements and the network management system.

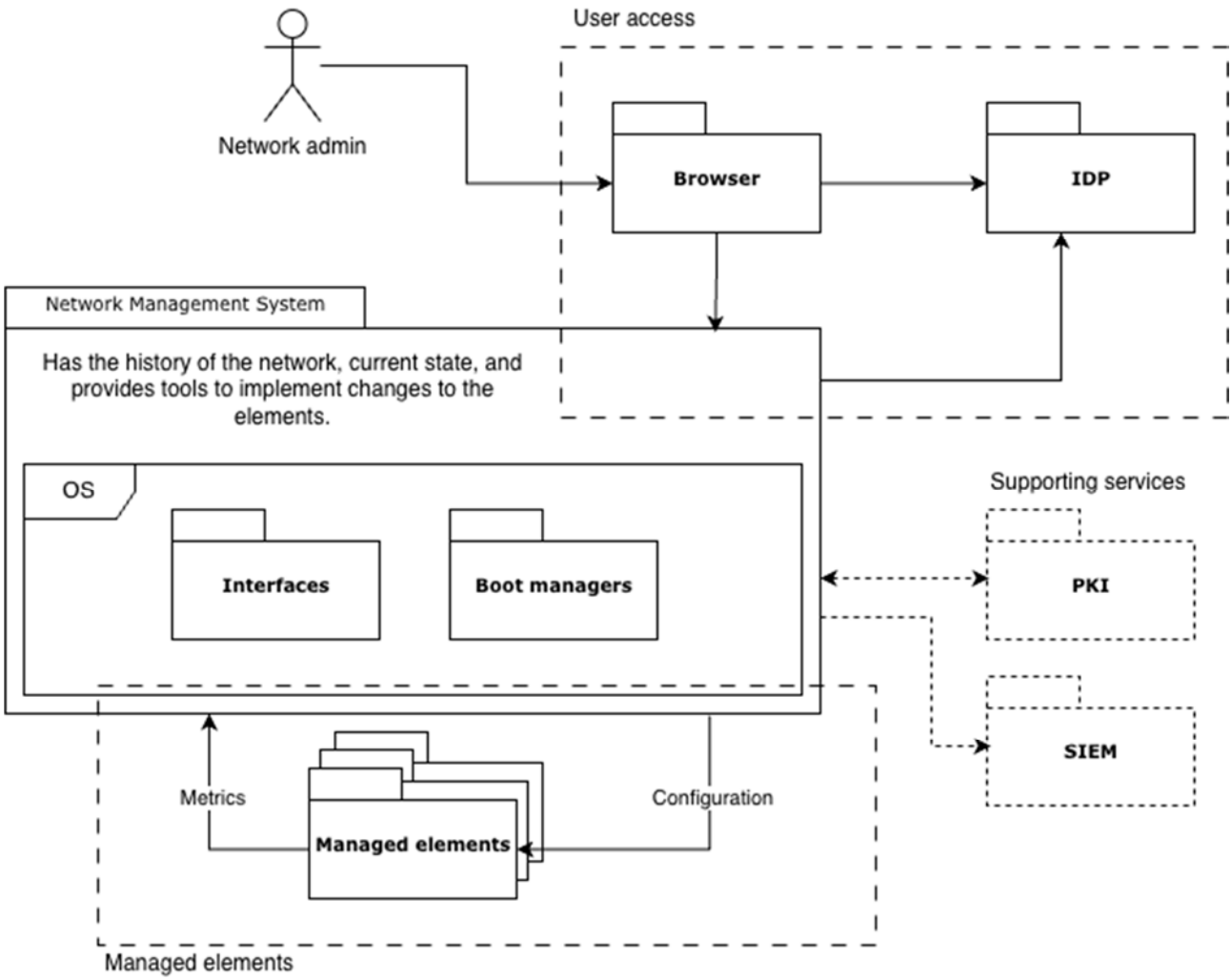


Figure 4.2.0-1: Product overview and architecture

Network management systems are operated by system users or by applications that interface with an API. These programs can be internal or external to the system depending on the product design and deployment context.

The system is often accessed with a browser using an identity outside of the installation context. Identity Provider (IdP) can be used as a base for the user's identity. In an enterprise setting, or equivalent, the high number of users and the volume of role changes has led to adoption of dedicated identity management platforms.

The system typically runs on hardware and software components that provide the necessary operating environment and network connectivity. The Operating System can be part of the deliverable and hence, part of the product. The OS best practices and requirements are defined outside of the scope of the present document.

Where relevant to the deployment context, the product may interface with external services such as identity, cryptographic, logging, or event management systems, though cybersecurity requirements of these systems, even if integrated into the product, are not addressed by the present document.

The primary function of the product is to monitor, configure, administer, or otherwise manage connected network elements.

More about assets in clause B.1.

4.2.1 Network architecture

The network architecture operating with the NMS is in scope of the present standard when evaluating the threats, risks and their impact on the network. The network can be large with multiple managed elements or there can be multiple networks, with varying degrees of inter- and intra-connections.

The product can be deployed into the network it controls, or it can be outside of the managed network. Depending on the design, the local network can have a local controller complement the control of the product while providing higher availability of supporting services.

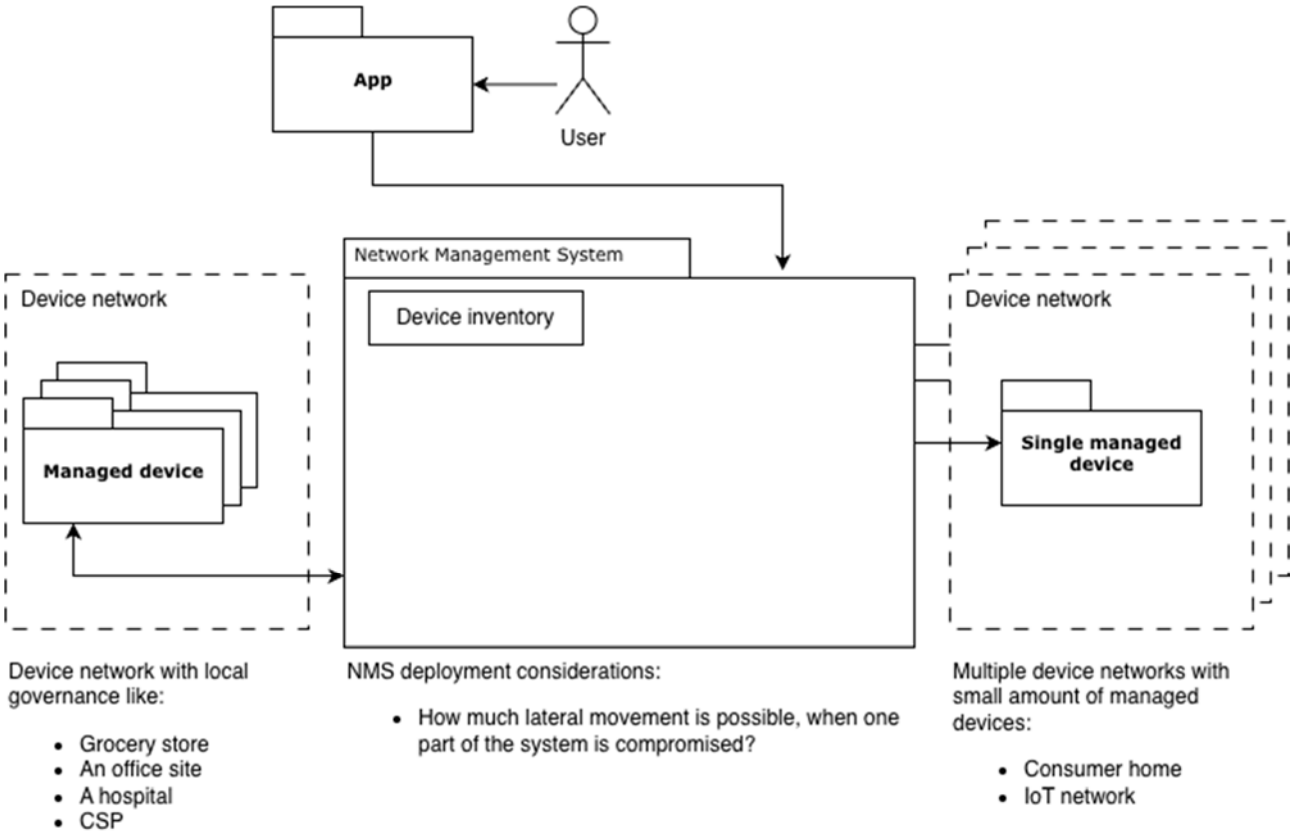


Figure 4.2.1-1: Network distribution design

When evaluating the product deployment operational environment risks, the network architecture, the product design and the product functionality needs to be understood. Physicality of the product deployment is addressed later in clause 4.3.

4.2.1.1 Software Defined Network

Early versions of Software Defined Networking (SDN) imitated the physical network structure by replacing the real-world devices with digital counterparts. The Virtual Machines uses Virtual Ethernet interface (veth) to transfer information in the same way that other networks would with a physical card. The veth is connected to a virtual switch, that handles ARP protocol mediation duties, and relies on the DHCP queries for IP assignment. The subnet virtual switch is connected to a virtual router acting as a gateway, enabling the virtual machine to communicate with the rest of the connected infrastructure.

This virtual infrastructure has been a digital copy of the physical world. All of these virtual devices can be independent instances of virtual machines running OS with a Linux kernel because over the years, Linux kernel modules have grown to support even the niche use-cases.

NOTE: The word "Linux" is a legally protected trademark owned by Linus Torvalds and managed by the Linux Foundation.

Just a few development iterations of scaled cluster based applications evolved the network requirements and the implementation of the virtual environment. The evolution is needed when applications increase their impact on the high availability of services and first faults become likely. That occurs in a flu-like, often container based environment, where computational nodes can terminate or cease operation without a warning. This of course, impacts or terminates the application context without warning. In such a cluster-changing scenario, the operators often expect that applications resume with minimal overhead and loss of progress in their new virtual environment. The new virtual environment can be a new node added into the pool, or the previous node rejoins the present cluster after a reboot.

Where applications are able to preserve their statuses despite their changing virtual environment, and where these applications can share their statuses with atomic execution containers, these instances can change the application statuses. These exchanges do not need the DHCP, and, the hosting OS container even does not need to request an IP address, as the OS container operates a preconfigured veth-interface ensuring the connectivity.

4.2.1.2 Application in a SDN

These application network design parameters are in the form of a configuration, and are presented as a request towards the runtime environment. The application describes its needs as how much distribution it requires, what parts of the different processes can be in the same or different computational context, and even how much capacity it expects from the backend. When the application changes, the configuration request changes, and the network changes with it.

The latest network control structures are utilising low level kernel features. While the Berkeley Packet Filter has been the stable base for Linux Netfilter stack, the extended version of it (eBPF) moves the computational decision making to the kernel. While the previous OS user level tools are now rendered useless, the packet routing decision is done before the packet is introduced to the host OS.

Decision, which was previously segregated to different OSI-model or TCP/IP-stack layers, can be now solved in a single context. The eBPF can provide answers to all of the requests by implementing the control of Transport-, and Internet-layers partially stepping into Application layer.

In a highly interconnected cluster, where multiple sites are used to host the workloads, this can mean that the virtual or physical port definition is made available only in the machine where the corresponding workload is located at. The implementation varies. Some accept all node facing traffic to all workloads that have requested outside connectivity routing the traffic through their own backend, while some perform a hot-potato routing directing the incoming connection directly to the machine that has the corresponding workload.

In an optimal case, there is no need for additional firewall configuration, as the node does not accept traffic for the services it is not hosting. This might be difficult to enforce if the cluster network controller is not the only one changing the routing table and the node configuration. In reality, multiple layers of firewalling are still used to limit accidental configurations exposing services undesirably. One in the outer perimeter of the infrastructure provider, one in the OS level accepting maintenance traffic to SSH server, one in the cluster level implementing the dynamic control.

In theory, the database can be in Portugal, when the business logic is driven in a Singaporean datacenter. These two services are often placed into a single namespace that often translates directly to an IP subnet that stays fixed within the cluster. This subnet is used in the application's internal routing and communication, and the application does not know how the subnet is implemented. The namespace and IP subnet follows seamlessly to the new datacenter location, if the application failover tolerates it and the cluster design makes it possible.

This highly abstract and fluid control scheme can host emergency services critical information, nations polling results or a non-profit organisations read-only website. Only the implementing entity's risk appetite sets the upper limit on what this structure can be used for.

4.2.1.3 Pocket deployment

A pocket deployment is a special combination of design criteria, where the product serves a single product user and the interconnectivity of the network is minimal. A connected network always requires at least one upstream gateway where to send packets to. Without that at least one upstream connection in the network, it is an air gabbed network.

The managed element functionality does not degrade, if the connectivity to the centralised command is lost. The element is placed in a network that is independent and self-sufficient. The local network devices using the connectivity are not affected by outages and the product's role is more like a convenience for the product user, rather than operational necessity.

The local network does not expect to be connected to other similar remote sites. Its inter-connectivity requirements are low. The network user might have VPN services enabled, but the expectation is to be connected only to the isolated environment of their own home for example.

When a single element is compromised, the exposure is limited to the elements in that same network.

4.2.1.4 Devices using provided connectivity

Relying on provided connectivity is common for devices that are part of some ecosystem where the main function of the managed element is not necessarily to serve Service Requesting Users with connectivity, but to provide the user higher level application features.

Provided connectivity is also used with ICT device management, where the management control can vary between partial OS configuration to full ownership.

The product control therefore does not extend to the surrounding network. Part of the initialisation of the managed element is to configure local network access for example when wireless access is used.

The managed elements can be like:

1) Simple embedded device like coffee machines, fridges, toasters, lightbulbs and thermostats
2) Commercial system monitors like fridge temperature sensors
3) Entertainment devices like streaming devices and game consoles
4) ICT devices like phones, tablets, laptops and other mobile devices
5) Office equipment like printers and meeting systems

4.2.2 Controller design

The product is a network controller. The different user roles are defined later in clause 4.5.

When deployed into the operational environment, the product has a varying degree of inter- and intra-dependencies. Dependencies can be implemented as Remote Data Processing Solutions (RDPS) which are defined in more detail in annex R in combination of the related clause 4.6.

All of the following affects the risk likeliness and impact:

- How is the product hosted?
  - SaaS, IaaS, PaaS
  - Dedicated infrastructure
    - In cloud
    - On-premises
  - The product is a physical device
- How many SRUs a single product deployment controls? (system isolation)
  - Single SRU
  - Multiple SRUs
- What is the product's main purpose?
  - Provide connectivity to Service Requesting Users by managing the network functions
  - Control the ecosystem by providing configuration to application workloads
  - Manage connected ICT devices
  - Dynamically control the application execution environment or other connectivity
- How many devices are managed for a single product user?
- How complex are the managed elements?
- Is the managed element control complete or partial?

- What is the role of services that are implemented as RDPS and therefore partially external to the present document?

4.2.3 Applying encryption in IETF RFC 1122

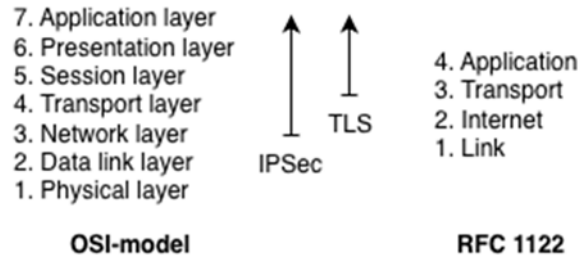


Figure 4.2.3-1: OSI-model and IETF RFC 1122

A product's Service Requesting Users are often identified from the ability to communicate with the managed element in the link layer. When considering the need for encryption, it is notable that encryption is often unavailable for fixed access network protocols operating in lower levels of the networking stack.

For example, subscriber line traffic is forwarded to the network without modifying the content or wrapping the traffic with layers of encryption.

Likewise, when a managed element is a router, it can often be configured to send and receive traffic from a Virtual Private Network. Addressing the VPN security is outside of the scope of the present document.

Encryption may also be beyond the control of the manufacturer. In the Radio Access Networking (RAN), the protocol family in use, like IEEE 802, defines what protocols are available and what cipher suites can be used to protect the traffic. Throughout the multiple possible links in the RAN backhaul, it is possible that the traffic traverses unencrypted. For example, routing a remote site traffic through satellites can end up in a situation, where trunk traffic is broadcasted to the ground station and near areas of it.

Considering these and similar scenarios, assuming that the lower level network traffic would be integrity and confidentiality protected by the fact that the product user who controls the operative environment owns the Fiber, is not feasible. An important system like the product in the present document needs multiple layers of defence.

When management traffic is classified to be Application level traffic, there is no reason to not use encryption with the served interfaces. This is noted later in **CYB_OPS-*** see clauses 5.2, 6.2.8, 6.2.9 and 6.2.10.

4.2.4 Inventory, device and subjects management

4.2.4.1 Identifying privileged subjects

As necessary functions as identification and authorisation are, the product can still serve traffic without performing an identification routine as long as that traffic is authorised in another way. For example, residential routers are often configured in a way that physical access to a local port is sufficient to identify a Service Requesting User (SRU).

Authorisation is provided by proximity and a user with physical access becomes the beneficiary of the provisioned configuration. This does not mean that every access channel should provide authorisation with physical access. A managed element can have a configuration port, a management API, a firmware update channel, and even a debugging interface, all of them classified as privileged and requiring complex authorisation depending on the managed element, and its use.

4.2.4.2 Device management

The connected managed element's design can be simple if there is support by the product with pushed configuration and firmware update services. On the other end of the spectrum, the managed element can be designed to operate as an autonomous agent that requires little or no input from the product to manage its functions to run the workload.

The product receives its definition through the management needs of the connected devices. The connected devices are outside the scope of the present document, but the product APIs communicating with them are included. This communication needs a trusted relation which needs to be established and maintained to ensure operational network security. This trust establishment with the connected elements is a core part of the product.

4.2.4.3 Inventory management

The function of the product can be to generate, keep, and maintain the inventory of the network. This inventory holds information about the connectivity, capabilities, and some form of mutual authentication for each networked device. When new devices are added and a trust is established, the new device extends the network and the inventory is amended.

Managing an accurate inventory is not always needed. Depending on the business logic, and the purpose of the network, the inventory can be a rolling list of devices the network has communicated during a 24 hour window for example.

Even such a simple list requires that the product exercise care when managed elements are removed from the network. When a rogue element is identified, it is important to be able to isolate the element, and mitigate the potential impact of its actions.

4.3 Operational Environment

4.3.1 General description

The technical requirements of the present document apply to the operational and environmental profiles of a Network Management System in accordance with its intended use.

The product is a system that interacts with other systems, devices and system users.

4.3.2 Physical/Hardware environment

The product can be engineered to work in a cluster which provides required redundancy and maintenance needs. The cluster the product is hosted at is often composed out of multiple nodes and scaled to fit into the operator's operational environment. The number of nodes and the composition of the hardware is designed to handle the expected load from the management function the product is performing.

Table 4.3.2-1: Logical separation of duties adjacent to IETF RFC 1122

Layer	Responsibility	Observability
Application	Development	Quality provided for the customer
Cluster	Platform engineering	API availability, metrics, logs and traces as a service
OS Maintenance	Regional teams	OS lineage, block storage, networking
Capacity	HW engineers	Application requests towards HW
Networking and facilities	Site manager	Is it on? Can I walk into the premises?

The product requirement can be defined with the abstraction layers as given in table 4.3.2-1, but the product is required to support the architectural design and conditions of the concrete operational environment. There are a variety of structures and responsibility separations supporting the actual use case possible. Also the product's shipment and delivery procedures usually follow the system users' needs and may also need to be conformant with critical infrastructure rules and requirements.

These responsibilities can be implemented with varying degrees of third party involvement in respected layers. Local delivery integration customisations could be also explored as an East-West integration plan, but for the purpose of the present document, all integration targets, apart from the managed elements, could be potentially implemented differently in the local delivery context, where the system user would like to use their own IdP for example, and addressed as RDPS to the product.

EXAMPLE: SIEM system operation requires access grants from the product Application-layer to be able to collect information from devices in the Networking and facilities-layer.

Table 4.3.2-2: Responsibility separation example in a larger scale deployments

Layer	In-house	Hyperscaler	On-site as a service
Application	Product customer	Product customer	Service provider
Cluster	Platform engineering	Hyperscaler	Service provider
OS Maintenance	Regional teams	Hyperscaler	Product customer
Capacity	HW engineers	Hyperscaler	Product customer
Networking and facilities	Site manager	Hyperscaler	Product customer

While it is possible to stay in a higher abstraction level of above layering while defining the product requirements, the provided product needs to acknowledge what designs are supported. There are different benefits in different responsibility separation structures. Often the selection of delivery style is guided by customer needs, where critical infrastructure requirements have to be matched in the product.

The physical deployment planning includes, but is not limited to:

- Always available basic services the product requires for operation: power supply, climate control, environmental impact protection against weather, fire, earthquake, other physical impact
- Available network connections to the digital services the product requires or can require for operation: certificate and signature validation, backup server, logging server, timestamp server
- Physical connectivity of the networks: optical, wired or radio based
- Physical access control to ensure access by authorised staff only

When designing an on-site delivery, the customer might have to understand the following:

- EMP protection of the installation facility
- Facility location in respect to other points of interest
- Distribution and redundancy

The site design is often guided by the national legislation and it varies between the EU countries.

The physical protection required is linked to the criticality of the use case.

4.3.3 Logical/Software environment

As the use of extremely large scale network services, or hyperscalers, becomes increasingly popular and the networked services perform an ever greater number of software functions, understanding network structures increasingly depends on how their connectivity is modeled. These complex networks can be modelled by how the functions are virtualised in the network like Logical network deployment without physical hardware or examining how much RDPS is involved in the design from Physical network deployment with RDPS.

Yet, the protocols used for all network deployments remain consistent. TCP and UDP dominate the network and transport layers in the OSI-model. DNS root servers are still trusted to point to the desired IP address and browser maintained TLS CA pools build trust beyond that provided by the DNS.

Encryption can be applied to the transport layer, but is rarely used in high traffic and low latency nodes as it imposes increased computational requirements, higher cost, and more complex management. Even with the emerging private networks popularised by the 5G slicing features, the transport layer rarely is fully encrypted throughout a private intranet. Only in networks that need greater integrity assurance, does the network need to be responsible for encrypting its own traffic.

4.3.4 Connectivity aspects

4.3.4.0 Introduction

Authorisation is the final step that assigns execution and access rights to resources to a user. The preparation for this step consists of identity verification and authentication. The user identity management can be an integral part of the product, but can also be provided as an external service. The relevance, availability, and correctness of the identity management system or service is crucial for the product and therewith for the entire network security, as it is the basis for the entire sequence from identity, over authentication up to the final user authorisation. As the natural user and machine user can sometimes be used interchangeably in the context the term subject in the present document refers to both unless specified.

Depending on the design of the product, authorisation to execute a single or a set of commands and general identity management can use the same system or two distinct systems. The choice to use a single or separate systems often relates to system and network size and in smaller systems identity management and authorisation are often combined.

Machine users can often have more exact limits on what functions they require. The interfaces designed for the machine users can be used by other privileged subjects. As administrator is often a privileged natural user, but the machine user making changes is not necessarily an administrator, the present document refers to both as privileged subjects who are often connecting to privileged interfaces.

The product can serve traffic that is not meant to be identified. For example, an in-home router often trusts that the physical access to its port is enough to identify the subscriber line. In addition, the managed element can have a configuration port, management API, firmware update channel, or debugging access, which are classified as privileged.

4.3.4.1 Identity management

An identity management system assures the identity of each subject which can be privileged or non-privileged within the system deployment context. The identity management system maintains a list of trusted sources, one or more, that describes what subjects are valid.

An up-to-date source of identity is essential. If a company internal employee directory is the source of the identity, its functionality is dependent on the accuracy and timeliness of its content. If an employee exits the company, their identity is expected to vanish or at least reflect the contractual status of the employee. The identity management [i.10] is often assessed as part of certification processes, and is outside of the scope of this standard.

Depending on the product design, the identity management referred in **AAC_AUTH-1** can be either part of the deliverable product, part of the deployment context as outside source or both, where redundancy is desirable or necessary. Integration into 3rd party identity management systems is preferred due to the higher likelihood that a dedicated identity management system is part of existing processes, up-to-date and can invalidate subject credentials when necessary.

The relevance, availability, and correctness of the identity management system or service is crucial for the product and therewith for the entire network security, as it is the basis for the entire sequence from identity, over authentication up to the final user authorisation. Therefore due diligence is required during integration development to assure that the supported structures meet the target security requirements in the intended or likely implementations of the product.

Role based authentication has been established to be a reasonable method to control a large pool of subjects by grouping them together for example to task based sub-groups that grants access to a partial set of functions. These groups can be for example *billing reader* or *project admin* to grant access to related operations in the product. For example, it is not feasible that a financial accountant needs access as the *project admin group*, but it is reasonable to assume that *project admin* would need to understand how much the performed actions cost while assessing if projects are within the budget. How the grouping is implemented is outside of the scope of present document.

4.3.4.2 Attribute-Based Access Control

Role based access control might be too coarse for some applications, like machine user access grants. Therefore industry has started to adopt more granular controls like Attribute-Based Access Control (ABAC), where the subject's authorisation to perform a function is determined by attributes associated with the request. This ABAC is also known as policy-based access control that complements Identity and Access Management (IAM). The attributes that formulate the identity portion of the grant are often matched with a target action.

EXAMPLE: An identified workflow execution A in a trusted environment B can amend the OCI registry C, under a project D, with a new container if the workflow is launched under trusted environment B organisation E, repository F.

In the above example, the trust relationship between policy holder and the source environment can be established in various ways with different implementations.

Attribute-Based Access Control design and implementation is outside of the scope of the present document.

4.3.4.3 Role based authorisation

When the identity of a subject is established, the system grants the subject access rights based on the subjects' role. The system can have multiple distinct roles, each is tailored to the subjects' perceived needs. There are many possible roles, with examples such as: monitoring data reader, interconnectivity administrator, or administrator. If the product's deployment context calls for an all-powerful superuser, this can be accomplished either with a single role with numerous responsibilities or by aggregating many available roles to that single subject.

Role Based Access Control design and depth is outside of the scope of the present document.

4.3.4.4 Trust initialisation

Secure network communication needs trust establishment among the communicating entities. The product initiates and establishes that trust and can operate multiple methods for this, including but not limited to: identity confirming certificates, unique serial numbers or stored credentials, usually in the form of pre-installed keys. These methods comprise credentials assigned to each entity, and those are used during the initialization to create the trust relation between the product, the managed elements, and, if present, with the IoT business logic.

Secure procedures to generate and enrol the credentials enable the product to initialise the trust relations. These procedures usually require physical access or proximity to the managed element, as, for instance, the human user of an IoT element can pair his element with the product through a wireless pairing mechanism or with a plugged-in wired connection.

As an alternative to preconfigured managed elements the manufacturer may provide element with a single DNS address that the managed element queries for configuration on element startup to launch a chain of events that registers the managed element to the correct network.

Methods of element enrolment - execution, maintenance, and how the system responds to changes, is one of the key aspects of the product.

On the basis of trusted relationships the product can provide cryptographically protected configuration and update services to the managed elements at runtime. In dependency of the product capabilities and the managed elements configurations, the configuration can reach the managed element either with a pull-request to the product, or the product can push the configurations to the managed elements. Once configured, the same channel and trusted status is used for secured identification, authentication, and communication with other applications on a managed element.

Independent of any of the host system's capabilities, the product can also be remotely accessible.

4.3.4.5 Risk management

The risk management is always use case dependent, and thus dependent on the actual conditions and operational environment. Therefore, it is essential to understand how the product can impact a network operation in its key areas. A not conclusive list as examples are: enrolment of network elements, trust relationships, isolation of control systems, management and depth of management of network element pools. The relevant areas are determined by the network purpose and the resulting security requirements in relation to the provisions of the operational environment and users.

For illustration, a managed home garden greenhouse monitoring system does not usually have similar high-availability requirements as the managed surveillance systems of an industrial mass production facility. If RDPS is deployed, outages thereof can - in the home garden case - easily be mitigated by local data storage so that the product can retrieve collected data at a later stage when the RDPS resumes. This would not be appropriate for the critical infrastructure. Here the RDPS needs more resilience, for example with redundancy and operation in proximity to the facility and the possibility for quick manual interactions. Such measures are typically subject for an enterprise use case.

4.4 Distribution of Security Functions

4.4.0 Introduction

The NMS provides the reliable availability of a network's operation, keeps control of its managed NEs, provides traffic meta data and metrics for the monitoring and verification of the correct network operation. The NMS can also act in cooperation with other defence systems in mitigating or repelling attacks and incidents on its managed NEs.

An inconclusive example would be a managed NE that reports to the monitoring system the current performance of network traffic throughput with related information about time, source, destination, and signals an alert in cases of overload or failure. In best cases, continuous monitoring data can allow intelligent analysis systems to forecast network issues and take action to resolve or at least mitigate those before those come to reality.

Therefore, what security functions are considered to be ancillary functions, and what are considered to be part of the core product, and what 3rd. party products depend on how the product is defined. A distributed service can in theory always be replaced, when the API design is stable, documented, and the authorisation of external components is done adequately. Therefore, the security functions listed below, do not necessarily fit under a single categorisation.

An NMS can be formed by a compilation or collaboration of different subsystems in a local distance but within the same management network and within the equal operational environment. The security functions may be implemented inside one or more of the subsystems that form the NMS. The product software packages can be installed, updated, and managed using an OS package manager or other similar mechanism outside of the control of the product.

Where the product relies on a Remote Data Processing Solution (RDPS) for the provision or support of one or more product functions, such reliance introduces a product-facing RDPS boundary between the local product side and the RDPS side. The applicability of the supplementary requirements specified in annex R should be considered in accordance with the requirement-applicability provisions of clause 5.

NOTE: Annex R applies to the product-facing RDPS boundary and to the RDPS-dependent product function. It does not replace the requirements applicable to the product function as such.

4.4.1 Ancillary functionality

The following functionalities can be implemented as part of the product or addressed as RDPS:

- **Product update channels** that external provided updates on secured channels that the product uses to update the managed elements and also itself.
- **Identity management systems** that provide mechanisms for identification and authentication. The system can include also the lifecycle management of identity credentials [i.2].
- **Provision of cryptographic keys** coming from a public key infrastructure or other key management system for services of key generation, provision, establishment, and for certificate services such as generation, signing, verification, validation or withdrawal [i.11].
- **Processing of monitoring data** that filters, aggregates and transforms metrics, logs, events, traces and provides administrative visibility to the system operation.

4.4.2 Related core functionalities

- **Virtual Private Network** providing access to a physical or virtual established network of managed elements that have strictly controlled access to authorised functions of the product [i.12] [i.13].
- **Security information and event management systems** that collect data from multiple sources, analyse and correlate that data and present it as actionable information for security-related purposes unless it is considered to be integral part of the product features [i.14].
- **Physical and virtual network interfaces** on the NMS-host and not used or accessed by users for the operation of the NMS.
- **Operating systems** Operating systems that act as abstraction layers for the hardware system(s) that host the product and are otherwise not involved in the internal functioning [i.15].

- **Element management** Device management system for managed elements such as, but not limited to, routers, modems, and switches [i.16].

Furthermore, it is essential to detail the generation and establishment of the trust relations between the NMS and the essential external services and systems.

4.4.3 Security functions provided to other products

The product can provide the following services to 3rd party applications and connected managed elements:

- Access to the collected data sets; raw or enriched.
- PKI services for the managed elements acting as Certificate Authority (CA).
- Access credentials and authorisation to the connected elements and system users.
- Proxy gateway connectivity to the connected elements.
- Mechanism to interact with the connected managed elements directly or indirectly.
- Software updates for the managed elements like printer, IoT device, etc.

EXAMPLE: A listed managed element in the NMS can be enriched with traffic meta data. For example, and inconclusive, when and with what performance there was relevant traffic throughput, when/from/to there was a managed element traffic overload, received failure reporting or similar.

4.5 Users

Product users are consumers or customers or entities like companies and institutions that operate the product in its intended and foreseeable use case. The definition can vary from single persons to nations. Product user hosts and operates the product in its present use case.

System users are natural persons. Administrators typically access the system through a HTTPS GUI, console, or by VPN connection. System users can include both integrators and end users (individual or group / consumer or organisation), as well as users with privileged rights or professional training such as administrators. System users can be professional users or consumers and may have different levels of cybersecurity knowledge. Both professional and less experienced users may also have disabilities and may be using assistive technology to access the product.

Machine users are servers or any other type of computer that are identified and authenticated by communication protocols that protect the communication between the product and the machine user. Once the protected communication has been established, the machine user receives the according authorisation by the product.

Service Requesting Users do neither have a direct interface to, nor could they interact or login via other ways to the product. SRUs are the beneficiaries of the product operation and do not participate in the configuration and control of the product. Typically the product does not classify the traffic source. The source can be a machine used by a human user, an application workload using the network. This group also includes children and elderly.

Subject is later used in the identity and access management requirements when both, product users and machine users are addressed as a group. The term subject should not be mismatched with product users or with service requesting users, because the use of subject is always clearly defined within the concrete context.

4.6 Use Cases

4.6.0 Introduction

The purpose of a use case is to create defined sets of technical requirements (clause 5) that may be used to treat the risks found by the manufacturer's independent cybersecurity risk analysis.

Use cases are defined by their risk factor levels. The risk factor levels are used by the informative Security Analysis in Annex B to select the group of technical requirements associated with that use case.

Specific use cases are identified by their use case IDs, which are constructed in the following manner:

UC-[X]-[WORD]

Where "X" is a number and "WORD" is a short word that serves to remind the reader of one or more examples.

4.6.1 UC-1-HOME: Home NMS

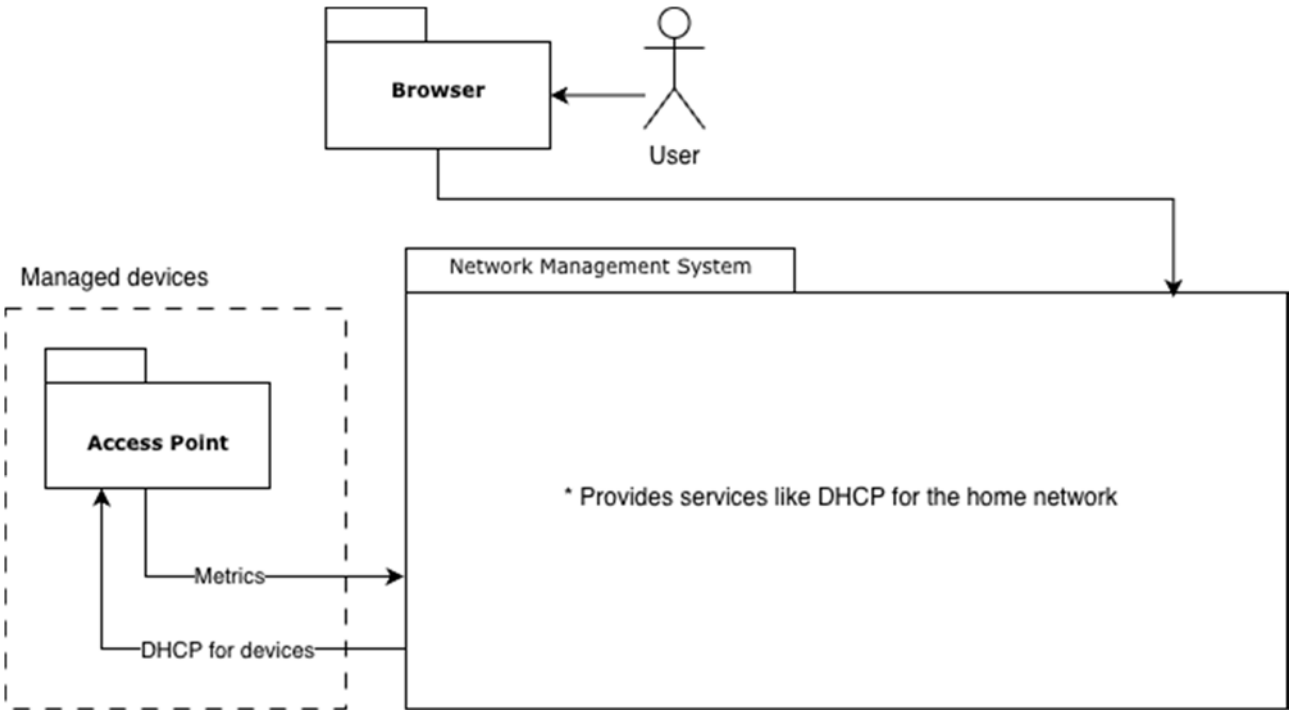


Figure 4.6.1-1: Home network deployment

In this use case, a home network device discovers or is being discovered by another device in the same subnetwork through provided network management functions. The device can act as a gateway or an access point providing connectivity for the user's home to outside networks, usually public. Access points are devices such as a router, switch, modem, or other wireless or wired device controlled and governed by the NMS and physically deployed to the service requesting users' home.

The device can make the upstream connection technology transparent to the user. Depending on the available infrastructure in the deployment location, connectivity can be through a variety of alternatives, including a mobile network or fiber optics network.

The NMS in this use case can be locally installed on the device but may be running on a different device within the same network, or is a RDPS.

Initial secret provisioning takes place during device initialization. A factory reset clears the existing state and restarts the discovery and provisioning process.

The managed elements can actively send metrics to the NMS which can serve multiple elements in the same network. The managed elements can be enabled for DHCP and DNS caching services, and further services including remote connectivity options like a VPN.

Metrics from the managed elements within the home network can be forwarded to the NMS, where the user can perceive these metrics and control the configuration of each managed element. In many deployments, the NMS provides actual configuration control and visualization of the collected metric data with an additional service or alternate piece of software. That is mostly a browser, but sometimes also other possibilities are deployed, such as a command-line interface.

- Goal: Manage network configuration for a small number of home devices.
- Examples: Home network manager, mesh network management.

- Function: Connect home devices to the local network and to the public network.
- Network connectivity: Filtered private network.

Table 4.6.1-1: UC-1-HOME classification

ID	Risk factor	Classification
RF-ACC_ASSETS	Accessibility to product	Medium
RF-COMPLEX_CONF	Complexity of configuration	Low
RF-COMPLEX_FUN	Complexity of functions	Low
RF-SENS_ASSETS	Sensitivity of elements	Low
RF-SENS_FUN	Sensitivity of functions	Low
RF-NUM	Number of elements	Low
RF-ADMIN	Administration skill	High

4.6.2 UC-2-ENTER-*: Enterprise network

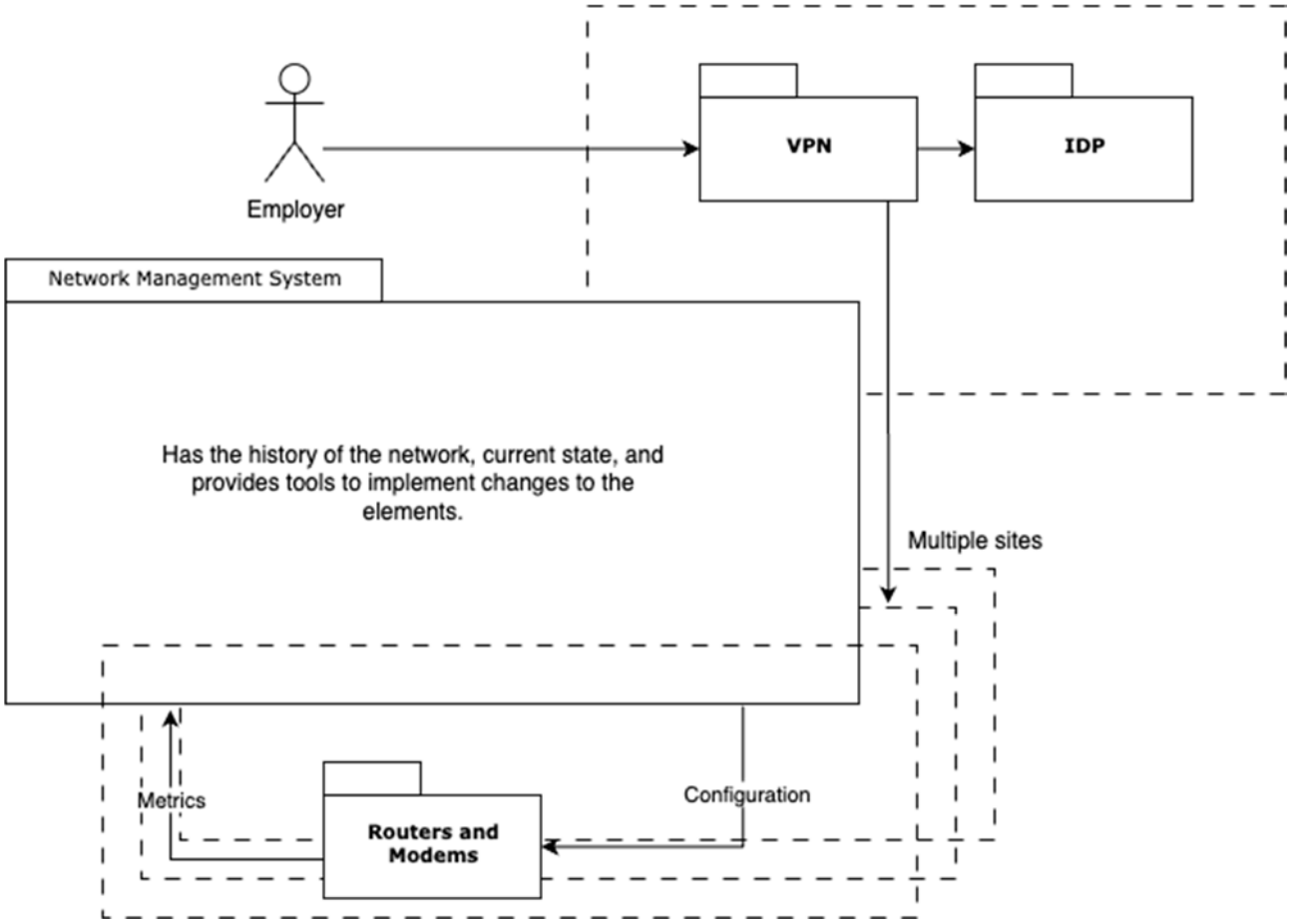


Figure 4.6.2-1: Enterprise network

A typical enterprise or office network has multiple service requesting users connecting simultaneously to a shared infrastructure.

Infrastructure may include multiple sites connected through a variety of technologies, including but not limited to: public networks, dedicated routing infrastructure like IP-MPLS-tunnel, massive-scale computing and storage systems via data centre (cloud systems), or third party service providers, or 5G slicing. An office network also typically operates for long periods, developing layered history of past versions and functions.

With modern remote working expectations, enterprise networks almost always include remote connectivity options, such as VPNs, that enable remote users to connect to the office network and work with the subset of curated services through a shared intranet environment.

User identity verification, authorisation, and the maintenance of a user is needed for each such intranet service or environment. This identity pool can be local for the service, shared within the same intranet, or provided as a service outside of the network context. In office environments, larger identity pools provide redundancy, but also complicate the administration of credentials, and reduce response time when credentials are rotated, such as when they are leaked and misused.

While it is possible to maintain the identities of all of available intranet services by hand, this is often impractical even with a moderate pool of users. A contemporary enterprise NMS deployment will instead rely on an Identity Provider (IdP) for most or all of its services. IdPs may be part of an NMS or separate, decoupled from the NMS. Likewise IdP's can be implemented locally or as a remote service, including as an RDPS. In all varieties the nature of the IdP deployed to the network is relevant to the present document as it is a major risk factor, especially if the NMS product does not support a relevant integration method or IdP technique.

As the importance of the operational context rises, so does the level of accuracy needed to securely manage identity. A larger enterprise has more staff, roles, job, and responsibility rotation, required services, data classes, levels of classified information, and working sites.

The increase in size and complexity contribute to increasing multiple risks that require more elaborate management structures. While many small businesses can perform the credential cleanup on former employees by hand, a large enterprise is likely to find this difficult, and see the value of deploying an administrator credential management service.

Additionally, entities within this context may store and work with extremely personal and sensitive data, such as a medical facility's patient records or a bank that needs to secure financial data. The type of deployment and actions of the service requesting users are not important to the NMS, except to the degree that the NMS need to ensure that the system has the features, hardware, and security to match operational needs.

The use-cases **UC-2-ENTER-S**, **UC-2-ENTER-M** and **UC-2-ENTER-L** reflects the size of the enterprise.

Table 4.6.2-1: UC-2-ENTER-S classification

ID	Risk factor	Classification
RF-ACC_ASSETS	Accessibility to product	High
RF-COMPLEX_CONF	Complexity of configuration	Low
RF-COMPLEX_FUN	Complexity of functions	Low
RF-SENS_ASSETS	Sensitivity of elements	Low
RF-SENS_FUN	Sensitivity of functions	Low
RF-NUM	Number of elements	Low
RF-ADMIN	Administration skill	High

Table 4.6.2-2: UC-2-ENTER-M classification

ID	Risk factor	Classification
RF-ACC_ASSETS	Accessibility to product	High
RF-COMPLEX_CONF	Complexity of configuration	Medium
RF-COMPLEX_FUN	Complexity of functions	Medium
RF-SENS_ASSETS	Sensitivity of elements	Medium
RF-SENS_FUN	Sensitivity of functions	Medium
RF-NUM	Number of elements	Medium
RF-ADMIN	Administration skill	Medium

Table 4.6.2-3: UC-2-ENTER-L classification

ID	Risk factor	Classification
RF-ACC_ASSETS	Accessibility to product	High
RF-COMPLEX_CONF	Complexity of configuration	Medium
RF-COMPLEX_FUN	Complexity of functions	Medium
RF-SENS_ASSETS	Sensitivity of elements	Medium
RF-SENS_FUN	Sensitivity of functions	Medium
RF-NUM	Number of elements	High
RF-ADMIN	Administration skill	Low

4.6.3 UC-3-TELCO: Telecommunications network

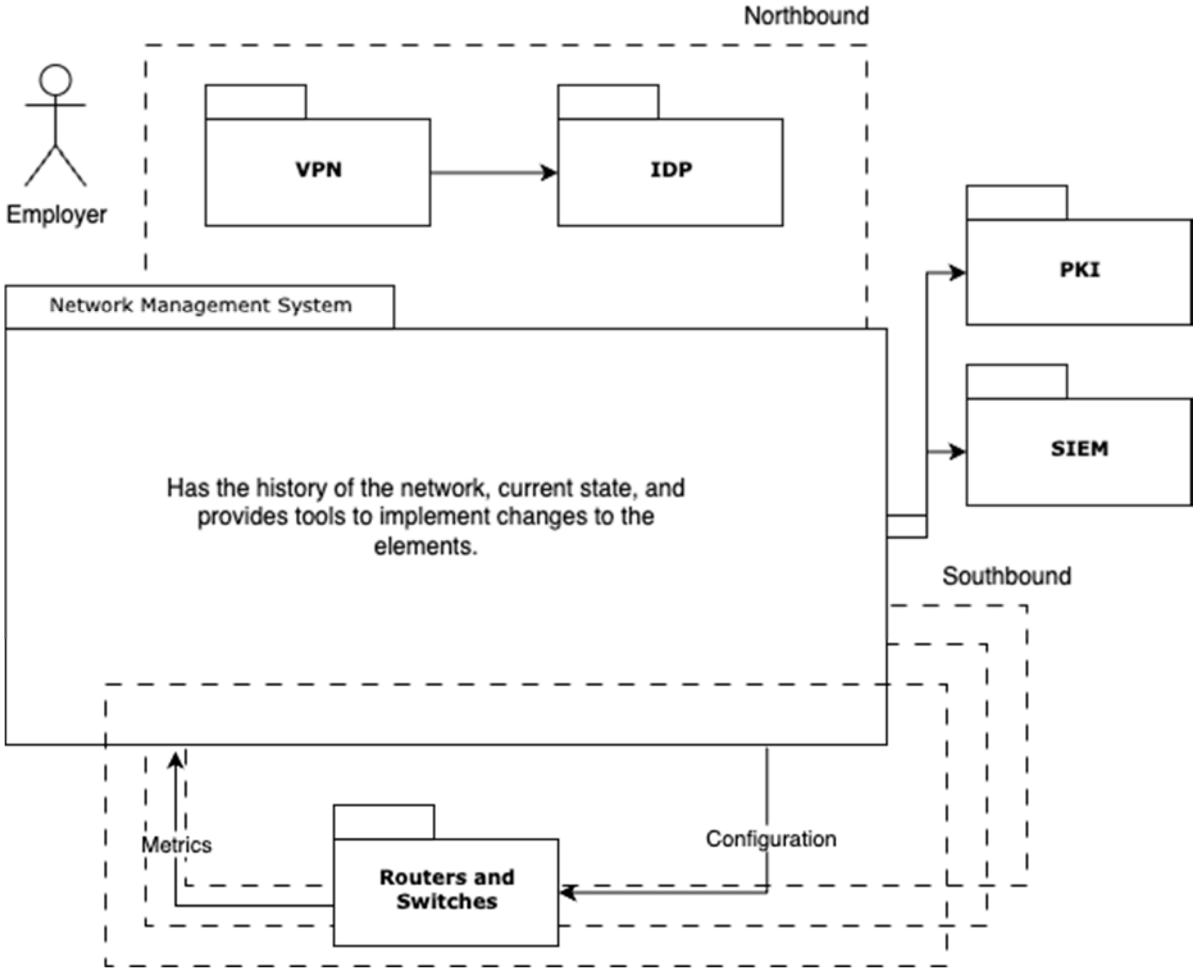


Figure 4.6.3-1: Telecommunications network

A telecommunications network resembles an enterprise network, with the obvious added complexity throughout. The telecommunications NMS will handle a greater load, including more users, devices, and identities. Identity Providers (IdPs) are often used to create segmentation and redundancy, and the network uses its routers and switches as base stations serving thousands of users simultaneously.

Telecommunications networks are modelled by division into northbound and southbound abstraction levels or descriptors, where southbound describes traffic from the NMS and hardware controlled by the network. Northbound traffic comes from lower layers of the network such as routers and switches and from the applications and users. Services supporting the telecommunications network, both internal and third party, are described as eastbound or westbound, depending on the objectives of the modelled architecture. In figure 4.6.3-1, SIEM is an example service that is adjacent to the NMS, and is often used in modern deployments.

In telecommunications deployments of NMS it is common to provide an in-house Public Key Infrastructure (PKI), that declares its own Certificate Authority (CA) or authorities deployed to the managed machines within the network. The number of these managed machines, number of CA's, and how the CA's are used is dependent on the design of the network. Alternatively, even at telecommunications scale, NMS can even provide its own certificates and form an independent and segregated trust domain.

- Goal: Manage telecommunications infrastructure.
- Examples: National phone and data telecommunications provider, virtual telco.
- Function: Manage network topology and device configuration.
- Network connectivity: Public.

Table 4.6.3-1: UC-3-TELCO classification

ID	Risk factor	Classification
RF-ACC_ASSETS	Accessibility to product	High
RF-COMPLEX_CONF	Complexity of configuration	High
RF-COMPLEX_FUN	Complexity of functions	High
RF-SENS_ASSETS	Sensitivity of elements	High
RF-SENS_FUN	Sensitivity of functions	High
RF-NUM	Number of elements	High
RF-ADMIN	Administration skill	Low

4.6.4 UC-4-SDN: Logical network deployment without physical hardware

A traditional simple network design has a single device listening on incoming connections from a public network facing port and allows selected traffic to pass through to subnets behind the device. A mesh network can be a set of these devices, physical or virtual, where multiple subnetworks are interconnected together, and the routing design is many-to-many instead of point-to-point. While it is often possible to manage the individual node configuration, and the authentication keys between the links, by hand, the configuration management becomes complex and error prone quite fast.

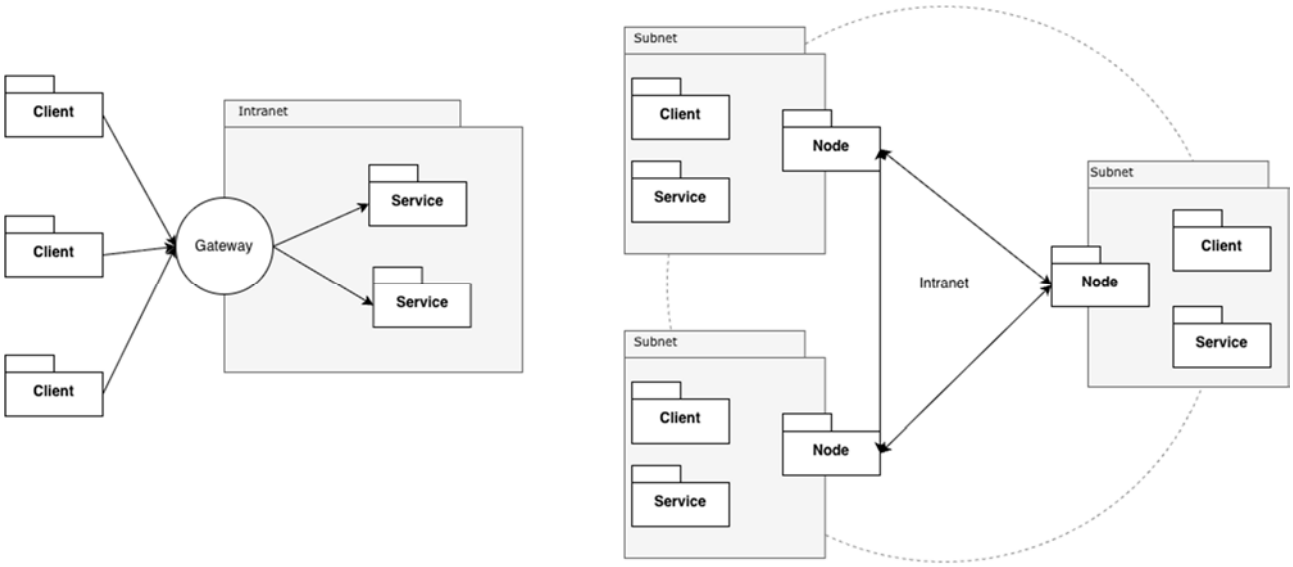


Figure 4.6.4-1: From classic gateway to mesh networking

Mesh network routing can be made more accurate, if the services are listed as routing targets, and the subjects who would like to have connectivity to those targets are identified. Combining the known locations of services and subjects connectivity grants, a custom routing table can be calculated for each subject. This custom routing table can be enforced on the network side by an added layer of control, that either provisions configuration changes to connected nodes firewalls, or provides other mechanisms to assert the authority of the connection.

Table 4.6.4-1: UC-4-SDN classification

ID	Risk factor	Classification
RF-ACC_ASSETS	Accessibility to product	High
RF-COMPLEX_CONF	Complexity of configuration	High
RF-COMPLEX_FUN	Complexity of functions	High
RF-SENS_ASSETS	Sensitivity of elements	High
RF-SENS_FUN	Sensitivity of functions	High
RF-NUM	Number of elements	High
RF-ADMIN	Administration skill	Low

4.6.5 UC-5-HYBRID: Physical network deployment with RDPS

When almost everything can be software, the minimum still remains: the user needs to have some form of User Equipment to be able to connect. This Network Interface can be a radio in the cell phone, a Wi-Fi® Access Point in the living room, or a router with SFP+ ports serving the local datacenter. How much the network structure has autonomy on control and local network routing the device has can be modelled in function of how much RDPS is involved in the design.

Inter-networking architecture with RDPS participating in the routing transforms a physical deployment into a logical deployment in the convergence point, which is the device installed into the site.

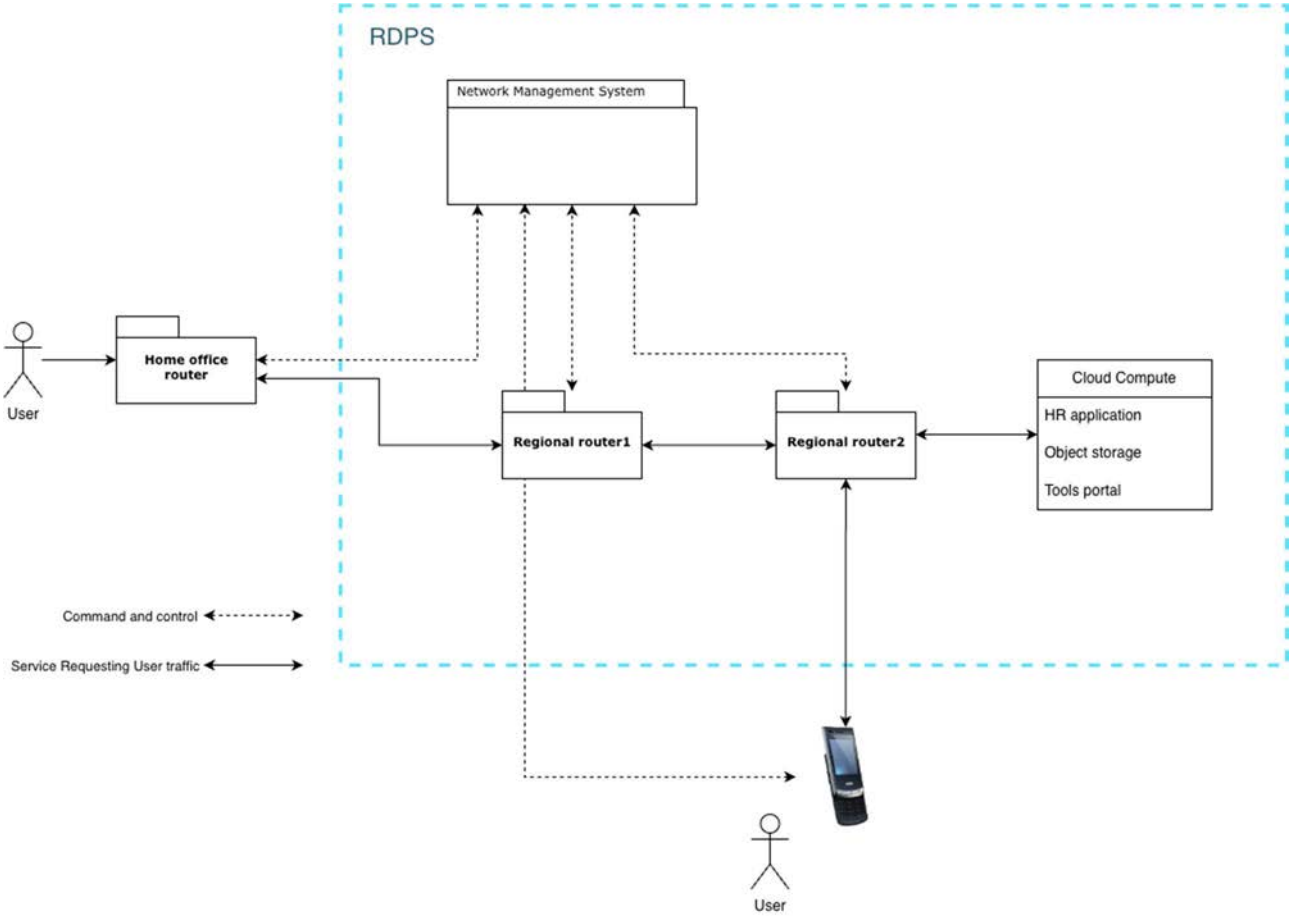


Figure 4.6.5-1: Maximum RDPS involvement

In figure 4.6.5-1, the maximum RDPS involvement, the network handles the connection like a hot potato: it is handed over to the RDPS immediately or as soon as possible. The local network is used as little as possible, and even the home office routing can take a detour through RDPS in order to provide an auditable trail of how the remote working employee is using the network.

Technologies like 5G slicing, enable for the flexibility of the closest point of return in respect to re-routing back to the user network: It could be the nearest base station or even the a forward proxy server on the other side of the world. These two scenarios result in a different user experience where the latter would most likely show as slow and unresponsive service, but both are valid designs that can be deployed.

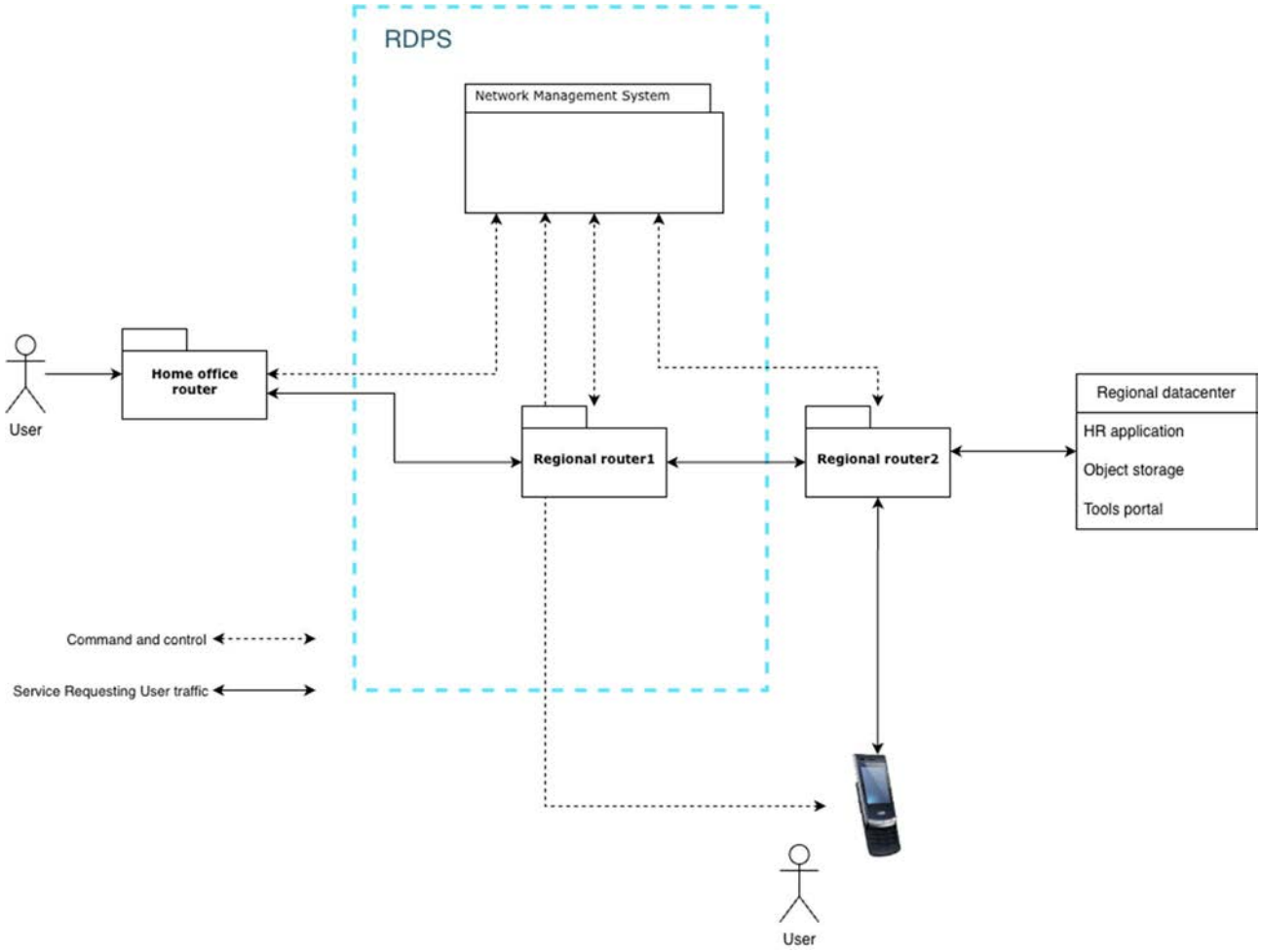


Figure 4.6.5-2: Medium RDPS involvement

Medium RDPS involvement is a common hybrid setup, where the company already has older assets that are grown into the enterprise, and are kept around as there is little or no need to change the infrastructure. Part of the network design is created with virtual assets, that could be the new IT infrastructure for the latest acquired company, while the still significant portion of networking assets are tied to the headquarters datacenter.

Control structures are different, device management strategies are varying, and even the physicality can extend to multiple nations. The balance of owned assets and bought services is often selected due to ease of deployment, while the partial reliance on headquarters datacenter offers resilience towards major outages in the connectivity. The end result might not be optimal, but often acceptable in the eyes of company risk management.

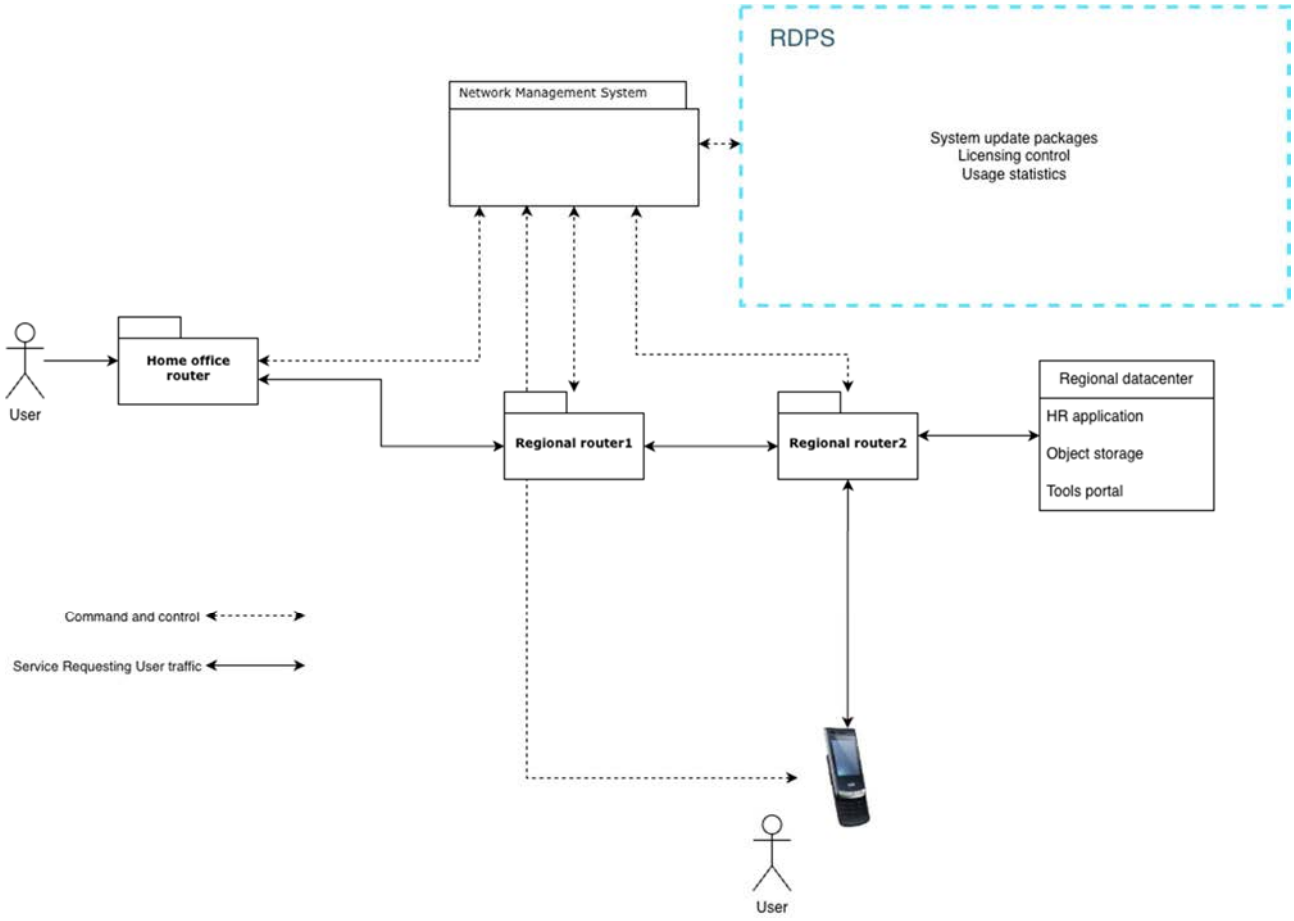


Figure 4.6.5-3: Minimal RDPS involvement

In a minimal RDPS involvement, all of the relevant infrastructure is not fulfilling the RDPS definition, and can be deployed to an underground infrastructure spanning multiple locations for example. Interconnection between the sites is either owned, or leased from a provider.

Some links can be through dedicated IP/MPLS tunnels, while some could be implemented through public connectivity with VPN tunnels. The RDPS mainly serves only update packages to the NMS, validates licensing if needed and can collect usage statistics for product development purposes.

While system updates are critical for the product, the installation is fully independent and no functionality is relying on the RDPS connectivity. The system updates can be delivered with a removable medium, if no connectivity to software repositories is available.

Table 4.6.5-1: UC-5-HYBRID classification

ID	Risk factor	Classification
RF-ACC_ASSETS	Accessibility to product	High
RF-COMPLEX_CONF	Complexity of configuration	High
RF-COMPLEX_FUN	Complexity of functions	High
RF-SENS_ASSETS	Sensitivity of elements	High
RF-SENS_FUN	Sensitivity of functions	High
RF-NUM	Number of elements	High
RF-ADMIN	Administration skill	Low

4.6.6 UC-6-IOT: IoT network with monitoring data collection

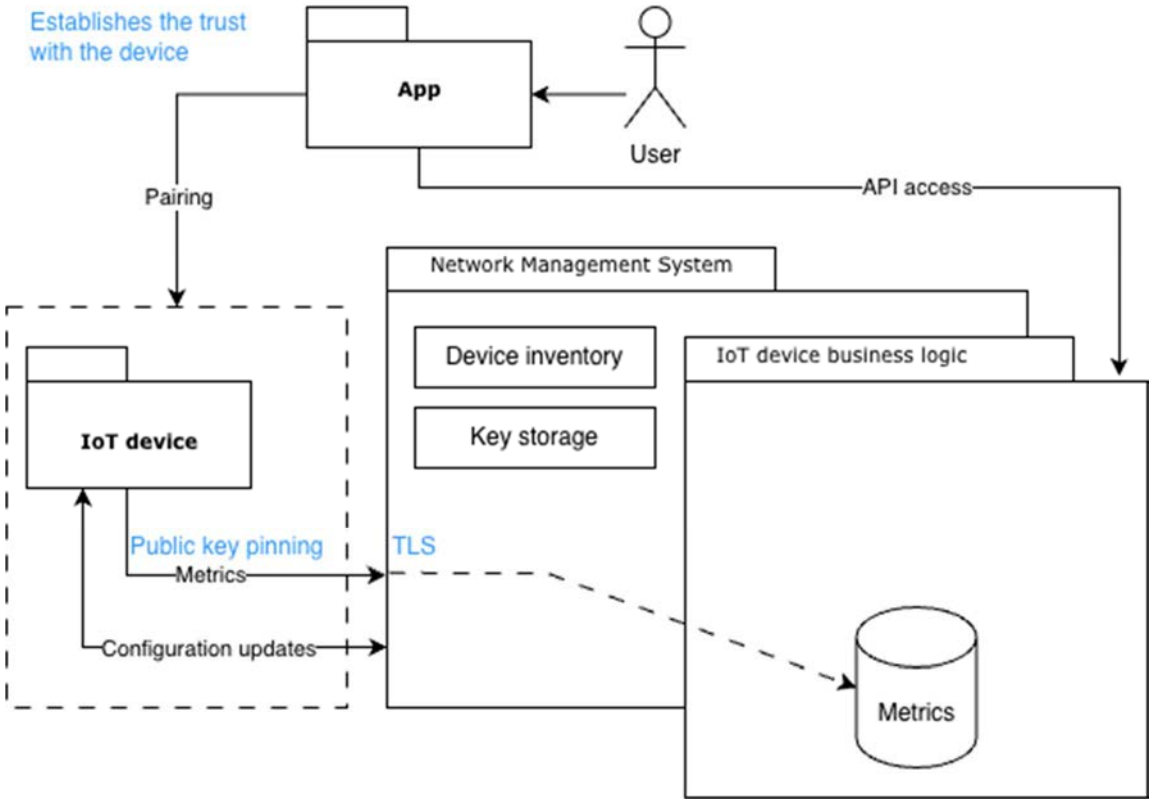


Figure 4.6.6-1: IoT network with monitoring data collection

Contemporary advancements in microcontroller features and related platforms used to build IoT devices blur the distinction between a simple device and a complex computation node, often reducing the description of a device as "IoT" to a branding decision from the manufacturer.

An IoT network is a network of devices, each of which almost always has limited computational capabilities and consumes a low amount of power. The exact purpose of these devices varies, but they are all connected to an NMS, and often to each other and to an IoT business logic, which may be a RDPS. The main focus of an IoT network is almost always data collection, and the NMS in this use case usually visualises the collected data metrics and provides them to the end-user. The NMS-analysis of the data metrics can be automated, including triggering warnings, alarms, or even taking actions based on discovered abnormal events. The IoT NMS also collects the meta traffic data and management related data from networked devices, and sometimes forwards it to other systems for processing and storage. It is not uncommon that the business logic and the NMS in this use case are offered together as a single product, providing a full networking ecosystem.

Even when data collection is the main focus of an IoT network, the network and NMS functions of this use case are not limited to it. An IoT network NMS also usually visualises the collected data metrics and provides them to the end-user while offering users ways to make actions based on the data provided. The NMS analysis of collected metrics can also be automated, including triggering warnings and alarms. In some implementations the NMS may even take actions based on its discovery of abnormal events.

Beyond collecting data from connected devices and preparing data metrics, the NMS controls the configuration of the connected devices, providing two minimum security functions:

1) Establishes trust between the system and the devices.

2) Maintain an inventory of devices that are part of the managed network.

- Goal: Manage large fleet of IoT devices.
- Examples: NMS for network-connected washing machines or toasters.

- Function: Manage network configuration for a large fleet of appliances.
- Network connectivity: Public network.

Table 4.6.6-1: UC-6-IOT classification

ID	Risk factor	Classification
RF-ACC_ASSETS	Accessibility to product	High
RF-COMPLEX_CONF	Complexity of configuration	Low
RF-COMPLEX_FUN	Complexity of functions	Low
RF-SENS_ASSETS	Sensitivity of elements	Medium
RF-SENS_FUN	Sensitivity of functions	Low
RF-NUM	Number of elements	High
RF-ADMIN	Administration skill	Medium

4.6.7 UC-7-ICT: ICT Network Elements

The ICT Element management is an enterprise-focused system to control and manage the configuration of the connected enterprise application on the ICT Elements. An ICT Element can encompass anything from routers, modems, switches up to mobile devices, tablets, smart phones, laptops, desktop PCs to servers. The use case describes a system that provides centralised governance of the enterprise application running on the ICT Elements within the scope of an organization.

ICT device management is in general subject to enterprises or larger organizations that equip their employees with the essential ICT elements they work with. The users usually do not have full administration rights and are restricted to the application level to manage personal look and feel.

Due to the broad functionality of the ICT Elements, the controls need also to be strongly extended, compared with the IoT use case, to ensure the centralised governance by the enterprise for the related application is maintained. That can be characterised as follows:

- Provision of preconfigured ICT elements or enterprise applications to the employees.
- Centralised ICT element or enterprise application update management.
- Trust establishment between the ICT elements, or the enterprise application, other communicating entities and the NMS, by the NMS.
- The NMS controls and sets the ICT element and the enterprise application configuration settings to manage:
  - The connectivity of the managed ICT elements and the enterprise application among each other, like VPN configuration.
  - The formation of user groups with their management in relation with dedicated access control management.
- Control software installation, reporting and individual permission on the ICT element respectively enterprise application.
- Backup and recovery controls for either the ICT element or the enterprise application.
- ICT Element respectively enterprise application status tracking and compliance control to enterprise guidelines and safeguards.
- Remote control of the ICT element or the enterprise application features if present.

The employees have only those administration rights the central administration granted before and which the NMS configures according to the enterprise rules. With that the ICT elements are an integral part of the business logic and enterprise processes running in the background.

Restrictions in the central governance are only present with relation to GDPR and locally applicable employee protection regulations for the enterprise owned parts. In all known cases, for the enterprise owned parts, connectivity and its execution of centrally controlled software are subject of the central administration. The NMS supports the central administration in their governance. The NMS operating the configuration of the enterprise owned parts usually also ensures the enforcement of enterprise guidelines, restricts user actions, and prevents unallowed connections to protect the enterprise from data disclosure by blocking interfaces and setting restrictions for applications.

The mobile device management need not be mismatched with the management functions that are subject to the radio network management functionality that ensures connectivity and performance with the RAN. These requirements are handled with the ETSI EN 304 642 [i.17] network functions.

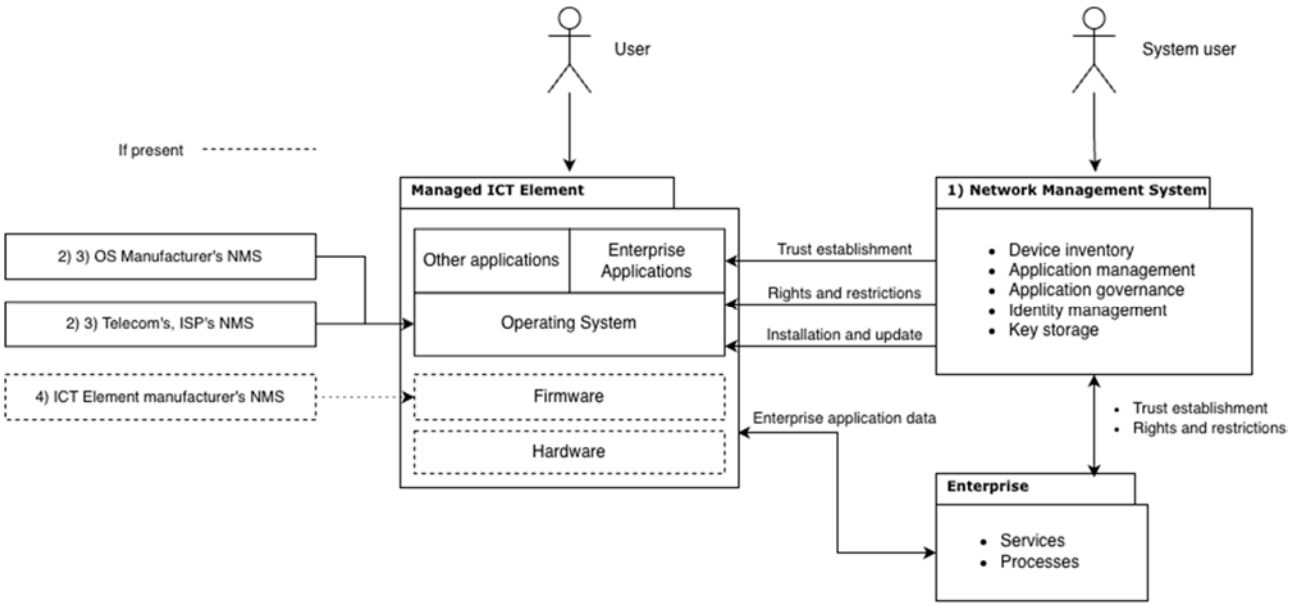


Figure 4.6.7-1: Multiple Network Management Systems

ICT Elements can have four managing entities at the same time as illustrated in figure 4.6.7-1:

1) The ICT element enterprise application management and the ICT Element owner decide about the enterprise application installations the employee needs. The installation configures the ICT element when the enterprise application is launched, and that sets the user and the enterprise application rights. The NMS can support the installation as well as the configurations. The NMS controlling the enterprise application is usually able to track the ICT element when the enterprise application runs according to the enterprise rules. That can also include support for automated application updates.

2) For a radio-connected ICT Element, the central radio network- or telecom's administration ensures connectivity and performance of the ICT element in connection to the RAN. A part of the RAN settings is static and provided by the (e)SIM, another is dynamic and subject to the concrete ICT Element situation in connection to the RAN. The ICT Element's operating system update is completely separated from the enterprise application and operates directly with the NMS of the operating system manufacturer. The enterprise application runs on a higher level. The radio-connected ICT Element can operate an automated update service in pull or push ways, the NMS of the operating system manufacturer can support this.

3) The similar holds for wired-connected ICT Elements but without the complexity of the RAN. The central telecom's administration or CSP ensures connectivity and performance of the ICT element in the wired connection. The ICT Element's operating system update is completely separated from the enterprise application and operates directly with the NMS of the operating system manufacturer. The enterprise application runs on a higher level. The wired-connected ICT Element can operate an automated update service in pull or push ways, the NMS of the operating system manufacturer can support this.

4) The mobile manufacturer can update the ICT elements to upgrade, update or mitigate vulnerabilities on the ICT element excluding applications that were installed after delivery. This manufacturer action can take various ways or methods, also push and pull style by the mobile ICT element itself. Usually, updates from the ICT Element manufacturer, such as firmware, use the way via the operating system manufacturer. In all cases, the owner of the mobile ICT element decides.

In all cases, application rights are managed and controlled, as the device management remains subject of the enterprise NMS, as the ICT elements are and remain in ownership of the enterprise.

Table 4.6.7-1: UC-7-ICT classification

ID	Risk factor	Classification
RF-ACC_ASSETS	Accessibility to product	High
RF-COMPLEX_CONF	Complexity of configuration	Medium
RF-COMPLEX_FUN	Complexity of functions	Medium
RF-SENS_ASSETS	Sensitivity of elements	Medium
RF-SENS_FUN	Sensitivity of functions	Medium
RF-NUM	Number of elements	Medium
RF-ADMIN	Administration skill	Medium

4.6.8 UC-8-FLEET: Fleet management

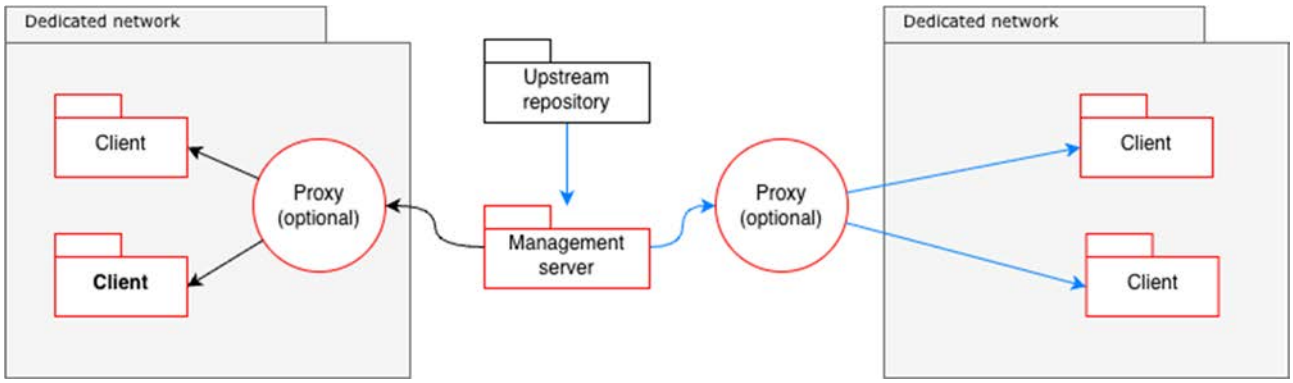


Figure 4.6.8-1: Fleet management

In this use case the NMS manages the software lifecycle and configuration state of a fleet of general-purpose hosts - typically Linux servers, but also workstations or virtual machines - rather than their network traffic. The product's role is to keep the managed hosts in a known, consistent, and compliant software state. This is the domain of dedicated configuration and systems management products, for example software repository and patch managers, configuration-as-code controllers, and provisioning systems.

The NMS in this use case implements the ICT device management functions and draws on ecosystem management for software delivery. Its characteristic functions are:

- Package, patch, and content/channel management, including mirroring software content from an upstream source and curating it into controlled channels before delivery to the managed hosts.
- Configuration management, where the desired state of a host is declared centrally and enforced on the host, often through an agent running on the host.
- Provisioning of hosts, including operating system installation and initial configuration.
- Inventory of installed software and hardware for each managed host, as described in clause 4.2.4.2.
- Compliance and audit, where hosts are evaluated against a security baseline and deviations are reported.
- Delivery of configuration and software to hosts in a push model (initiated by the NMS) or a pull model (requested by the host), in both cases with host-side verification of the integrity and authenticity of the delivered content, as described in clause 4.2.4.3.

Managed hosts typically run an agent that registers with the NMS during enrolment. Trust between the NMS and each host is established at enrolment, as described in clause 4.3.4.4, and is thereafter used to authenticate the host and to deliver configuration, content, and commands. The connectivity between the NMS and the managed hosts is, in this use case, usually provided by the surrounding network and is not controlled by the product, as described for devices using provided connectivity.

The NMS can be deployed as a single instance for a small estate, or scaled with intermediate proxies or hubs that cache content and relay commands to hosts in remote sites or segmented networks, following the distributed deployment pattern. The upstream software content source - and, depending on the product, subscription, licensing, or usage reporting - is commonly external to the product and is then a remote data processing solution, to which the provisions of annex R apply.

Because the NMS holds privileged, often root-equivalent, control over the installed software and configuration of every managed host, a compromise of the NMS or of its content delivery path has an impact radius potentially spanning the entire fleet. The integrity and authenticity of delivered content and configuration, the strength of host enrolment and authentication, and the isolation of the management plane are therefore the dominant risk factors in this use case.

NOTE: This use case concerns the system that manages the hosts. The intrinsic security of the operating systems running on the managed hosts is addressed by ETSI EN 304 626 [i.15].

- Goal: Manage network configuration in a controlled homogenous fleet of devices.
- Examples: Servers in a datacenter, phones in a test lab.
- Function: Configure network of managed elements, maintain simple network topology.
- Network connectivity: Filtered private.

Table 4.6.8-1: UC-8-FLEET classification

ID	Risk factor	Classification
RF-ACC_ASSETS	Accessibility to product	Medium
RF-COMPLEX_CONF	Complexity of configuration	Medium
RF-COMPLEX_FUN	Complexity of functions	Low
RF-SENS_ASSETS	Sensitivity of elements	High
RF-SENS_FUN	Sensitivity of functions	High
RF-NUM	Number of elements	Medium
RF-ADMIN	Administration skill	Low

4.6.9 UC-9-RESEARCH: Research NMS

- Goal: Provide minimum functionality for research or training.
- Examples: Simple NMS for a collection of containers used for research or training.
- Function: Configure network on simulated managed elements or operate a laboratory.
- Network connectivity: Isolated private network.

Table 4.6.9-1: UC-9-RESEARCH classification

ID	Risk factor	Classification
RF-ACC_ASSETS	Accessibility to product	Low
RF-COMPLEX_CONF	Complexity of configuration	Low
RF-COMPLEX_FUN	Complexity of functions	Low
RF-SENS_ASSETS	Sensitivity of elements	Low
RF-SENS_FUN	Sensitivity of functions	Low
RF-NUM	Number of elements	Low
RF-ADMIN	Administration skill	Low

4.6.10 UC-10-AIRGAP: Airgapped secure facility

- Goal: Control network configuration in an isolated network.
- Examples: Malware research lab, highly sensitive software development facility.
- Function: Configure devices and network configuration in highly controlled environment.

- Network connectivity: Isolated private.

Table 4.6.10-1: UC-10-AIRGAP classification

ID	Risk factor	Classification
RF-ACC_ASSETS	Accessibility to product	Low
RF-COMPLEX_CONF	Complexity of configuration	Low
RF-COMPLEX_FUN	Complexity of functions	Low
RF-SENS_ASSETS	Sensitivity of elements	High
RF-SENS_FUN	Sensitivity of functions	High
RF-NUM	Number of elements	High
RF-ADMIN	Administration skill	Low

4.6.11 UC-11-WATER: Management of distributed infrastructure

- Goal: Manage connectivity to widely scattered infrastructure devices of an important entity.
- Examples: Network configuration of water pumps and waste management entities.
- Function: Configure network of managed elements with occasional network topology changes.
- Network connectivity: Public.

Table 4.6.11-1: UC-11-WATER classification

ID	Risk factor	Classification
RF-ACC_ASSETS	Accessibility to product	Medium
RF-COMPLEX_CONF	Complexity of configuration	Medium
RF-COMPLEX_FUN	Complexity of functions	Medium
RF-SENS_ASSETS	Sensitivity of elements	High
RF-SENS_FUN	Sensitivity of functions	Medium
RF-NUM	Number of elements	Medium
RF-ADMIN	Administration skill	Medium

5 Technical requirements for products

5.1 Introduction - Applicability of the requirements

The technical documentation referenced in this clause is intended to describe the product design, dependencies, and implemented measures relevant to demonstrate conformity with the applicable requirements of the present document.

The technical requirements of the present document apply under the product context described in clause 4, which shall be in accordance with its intended use. The product shall comply with all applicable technical requirements of the present document at all times when operating in such a product context.

The requirements in this clause are unconditionally applicable, unless specifically indicated with a conditional phrasing, or the functionality is implemented with RDPS.

When requirements are divided into low-medium-high categories, the categories are cumulative. Medium requirement level shall implement also requirements listed in low level. High requirement level shall implement all requirements in the defined set of requirements as the requirements are cumulative.

Table 5.1-1: Mapping of UC-1-HOME, UC-2-ENTER-S, UC-2-ENTER-M, UC-2-ENTER-L and UC-3-TELCO to a requirement set based on annex B security analysis

Requirement set	UC-1-HOME	UC-2-ENTER-S	UC-2-ENTER-M	UC-2-ENTER-L	UC-3-TELCO
CYB_GENERAL	low	medium	high	high	high
CYB_OPS	all	all	all	all	all
KEV_EXPLOIT	all	all	all	all	all
SBD_TECH	all	all	all	all	all
SU_UPDATES	all	all	all	all	all
AAC_AUTH	all	all	all	all	all
AAC_MACHINE	all	all	all	all	all
CON_INGEST	all	all	all	all	All
CON_CRYPTO	all	all	all	all	All
CON_CHANNEL	all	all	all	all	All
INT_CONF	all	all	all	all	All
INT_ROTATE	all	all	all	all	All
DM_RETENTION	all	all	all	all	All
AP_HA	low	medium	medium	medium	high
IM_SEGMENT	low	medium	medium	medium	high
MAS_TECH	all	all	all	all	All
EMM_ROUTE	high	high	medium	medium	high
MON_LOG	low	medium	medium	medium	high
MON_METRICS	all	all	all	all	All
DRT_DELETE	all	all	all	all	All

NOTE: Because (RF-ADMIN is High or RF-NUM is High) is true for both UC-1-HOME and UC-3-TELCO, both use cases require high risk level from EMM_ROUTE requirements.

Table 5.1-2: Mapping of UC-4-SDN, UC-5-HYBRID, UC-6-IOT, UC-7-ICT and UC-8-FLEET to a requirement set based on annex A security analysis

Requirement set	UC-4-SDN	UC-5-HYBRID	UC-6-IOT	UC-7-ICT	UC-8-FLEET
CYB_GENERAL	high	high	Medium	high	medium
CYB_OPS	all	all	All	all	All
KEV_EXPLOIT	all	all	All	all	All
SBD_TECH	all	all	All	all	All
SU_UPDATES	all	all	All	all	All
AAC_AUTH	all	all	all	all	All
AAC_MACHINE	all	all	all	all	All
CON_INGEST	all	all	all	all	All
CON_CRYPTO	all	all	all	all	All
CON_CHANNEL	all	all	all	all	All
INT_CONF	all	all	all	all	All
INT_ROTATE	all	all	all	all	All
DM_RETENTION	all	all	all	all	All
AP_HA	high	high	medium	medium	High
IM_SEGMENT	high	high	medium	medium	Low
MAS_TECH	all	all	all	all	All
EMM_ROUTE	high	high	medium	medium	High
MON_LOG	high	high	medium	medium	High
MON_METRICS	all	all	all	all	All
DRT_DELETE	all	all	all	all	All

Table 5.1-3: Mapping of UC-9-RESEARCH, UC-10-AIRGAP and UC-11-WATER to a requirement set based on annex B security analysis

Requirement set	UC-9-RESEARCH	UC-10-AIRGAP	UC-11-WATER
CYB_GENERAL	low	low	medium
CYB_OPS	all	all	all
KEV_EXPLOIT	all	all	all
SBD_TECH	all	all	all
SU_UPDATES	all	all	all
AAC_AUTH	all	all	all
AAC_MACHINE	all	all	all
CON_INGEST	all	all	all
CON_CRYPTO	all	all	all
CON_CHANNEL	all	all	all
INT_CONF	all	all	all
INT_ROTATE	all	all	all
DM_RETENTION	all	all	all
AP_HA	none	none	low
IM_SEGMENT	none	none	low
MAS_TECH	all	all	all
EMM_ROUTE	none	high	medium
MON_LOG	none	high	low
MON_METRICS	all	all	all
DRT_DELETE	all	all	all

The selection of required level for is described in annex B.

5.2 Appropriate level of cybersecurity

This clause addresses the requirements in the CRA [i.1] Annex I Part I (1).

For **low** risk:

- **CYB_GENERAL-1** The product shall define whether a service is completely fulfilled by the product itself.
- **CYB_GENERAL-2** The product shall describe the external services and systems that are required for product operation.
- **CYB_GENERAL-3** The product shall describe the dependencies to Operating System security capabilities.

For **medium** risk:

- everything in low risk, and
- **CYB_GENERAL-4** In the context of key management and accepting new elements to the management context the product shall support:

  1) initialisation of trust in a greenfield deployment, and in the connected element management;

  2) accepting managed elements into the network based on that trust;

  3) key rotation and replacement of all relevant cryptographic keys after trust has been established.

For **high** risk:

- everything in low risk; and
- everything in medium risk; and
- **CYB_GENERAL-5** The product shall provide functionality to replace user accessible and controlled cryptographic keys.
- **CYB_GENERAL-6** The product shall clearly indicate the purpose and usage of keys that are not user accessible, where present.

- **CYB_GENERAL-7** The product shall record all system time drift corrections as monitoring events.

NOTE: Modern software design can rarely ignore the impact of the changes to other components.

- **CYB_OPS-8** The product shall clearly indicate deployment, update, and upgrade instructions expected from the Operational Environment (OE).

- **CYB_OPS-9** The product shall describe the traffic related to the product operation, including at minimum, configuration, metrics, and API access, that is addressed as Application-level traffic as per IETF RFC 1122 [2].

- **CYB_OPS-10** The product shall satisfy the applicable remote data processing solutions requirements specified in annex R.

  - This requirement applies to the subset of products that rely on a Remote Data Processing Solution (RDPS) for the provision or support of one or more product functions.

5.3 No known exploitable vulnerabilities

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (a).

NOTE 1: A container hosting the product always has an operating system.

- **KEV_EXPLOIT-1** The product shall:

  1) have no known exploitable vulnerabilities; or

  2) have no known exploitable vulnerabilities that were reported to within the previous 14 days, or the time period permitted before public disclosure as described in the vulnerability handling procedure for the product; or

  3) have no known exploitable vulnerabilities that do not have associated publicly-available documentation explaining the risk and how that risk has been mitigated.

NOTE 2: An exploitable vulnerability's transition from "unknown" to "known" may be by its publication to the EU Vulnerability Database, an industry-specific vulnerability database, or direct notification to the manufacturer via its own vulnerability reporting process.

5.4 Secure by default configuration

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (b).

- **SBD_TECH-1** The product shall:

  1) implement accepted cryptographic methods as described in annex K on all interfaces that are available or reachable outside of localhost within the local processes; and

  2) by default only enable cryptographic mechanisms listed in annex K.

- **SBD_TECH-2** The product shall:

  1) exclusively use interoperability-based cryptographic mechanisms as described in clause K.4; and

  2) provide a user notification or other informative function when using such methods; and

  3) inform the user which component requires the backwards compatible mechanism; and

  4) indicate an upgrade path to using more secure cryptography when available.

  This requirement applies to the subset of products that provide backward compatibility with cryptographic algorithms other than those listed in clause K.3.

- **SBD-TECH-3** The product shall provide a method with which to reset to a secure by default setting.

NOTE: The CRA essential requirement laid out in Annex I Part I (2) (b) provides for an applicability exception to the secure configuration by default Essential Cybersecurity Requirement in the scenario that the manufacturer and business user have an agreement in relation to a tailor-made product with digital elements. That exception does not exempt products from the requirement to provide a method to reset to a secure by default configuration.

5.5 Security updates

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (c).

- **SU_UPDATES-1** The product shall have the ability to receive security updates.
- **SU_UPDATES-2** The product shall have independent OS and application update procedures enabling the user to schedule the update following the operational needs and the High Availability targets.
- **SU_UPDATES-3** The product shall by default attempt to install security updates at the time of first use to address all known exploitable vulnerabilities which were discovered after the product's placement on the market and before first use.
  - This requirement applies to subset of products that are not updated by the OE.
- **SU_UPDATES-4:** The product shall verify authenticity and integrity of the update package using a cryptographic signature verification prior to installation.
  - This requirement applies to subset of products that are not updated by the OE
- **SU_UPDATES-5:** The product shall maintain a monotonic version counter or equivalent mechanism to prevent installation of updates with an older version.
  - This requirement applies to subset of products that are not updated by the OE
- **SU_UPDATES-6:** The product shall provide a mechanism to restore the system to the operational state after a failed update.
- **SU_UPDATES-7:** The product shall provide a way for the system user to postpone or re-schedule the application update.
  - This requirement applies to the subset of products that operate in an operational environment that allows for postponement or rescheduling of application updates.
- **SU_UPDATES-8:** The product shall require explicit authorization and emit an auditable event containing metadata when intentional rollback is invoked.
  - This requirement applies to products that support intentional version rollback.
- **SU_UPDATES-9:** The product shall automatically recover from a failed update and resume operation if applicable or otherwise achieve a secure state.
- **SU_UPDATES-10:** The product shall inform the system user about update availability if applicable.
- **SU_UPDATES-11:** The product shall track the relevant component versions of the product and the managed elements if applicable.
- **SU_UPDATES-12:** The product shall log start and finish of the update download if applicable.
- **SU_UPDATES-13:** The product shall perform an automatic update of the product.
  - This requirement applies to products that support automatic updates.
- **SU_UPDATES-14:** The product shall enable automatic updates by default.
  - This requirement applies to products that has automated update functionality.
- **SU_UPDATES-15:** The product shall perform an update without impacting the defined availability targets.

5.6 Authentication and access control

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (d).

These requirements apply to the product, regardless of the product's use case and without variation for different tiers or risk.

- **AAC_AUTH-1** The product shall support identity management through at least one of the following approaches:

  1) integration of the product into an external state-of-the-art Identity Management System; or

  2) integration of an external Identity Management System into the product; or

  3) a dedicated Identity Management module built into the product.

- **AAC_AUTH-2** The product shall not allow for default credentials or keys to be used to identify subjects.

  - This requirement does not apply to tailor-made products, where product user requests changes as per CRA [i.1] Annex I Part I (2) (b).

  - This requirement does not apply to UC-1-HOME, where the initial password is unique between instances of the product, and is provided to the product user in a confidential manner.

- **AAC_AUTH-3** The product shall eliminate default credentials by either:

  1) generating credentials during the first use; or

  2) enforcing mandatory credential creation during the initial setup of a new system user or a managed element.

- **AAC_AUTH-4** The product shall use multi-factor authentication to authenticate system users.

- **AAC_AUTH-5** The product shall limit a system user's session validity duration via a configurable setting that shall initially be limited to a default of, at maximum, one day.

- **AAC_AUTH-6** The authorization model shall enforce separation of privileges in a way that minimises subjects access grants to protected functions within the system.

- **AAC_AUTH-7** The product shall require strong authentication of subjects, services, or integrated components to access privileged interfaces, control functions, and sensitive operations.

- **AAC_AUTH-8** The product shall protect privileged interfaces with state-of-the-art cryptographic libraries as described in annex K.

- **AAC_AUTH-9** The product shall report all relevant events related to authorisation including, at minimum:

  1) successful and unsuccessful use of identity,

  2) object access,

  3) policy change,

  4) privileged function use,

  5) data access and deletions, and

  6) data changes and permission changes.

- **AAC_AUTH-10** The product shall explicitly authorise any privileged action before its execution can modify, including, at minimum:

  1) managed-element configuration

  2) control-plane behaviour routing or forwarding state

3) security policy

4) identity or authorisation configuration

5) cryptographic trust material

6) software state

7) availability

8) network reachability.

- **AAC_AUTH-11** The product's authorisation decision shall be bound to, and made available in, auditable event data, including at minimum:

  1) source of the identity

  2) the acting identity

  3) whether natural user or machine user

  4) role or permission set

  5) target managed element or elements

  6) requested operation

  7) material request parameters

  8) policy version or rule identifier

  9) and validity interval.

- **AAC_AUTH-12** The product shall prevent the execution of any privileged action when the authorisation decision is absent, expired, inconsistent with current policy or context, or cannot be recorded as an auditable event, except where the action aims to enable or restore auditability of the product.

- **AAC_MACHINE-13** The product shall provide authentication for machine users such as certificates or tokens where a expiration is not undefined or, by default, over a year in the future.

- **AAC_MACHINE-14** The product shall minimise access for the machine user to privileged interfaces like APIs.

NOTE: **AAC_AUTH-2** applicability exclusion for UC-1-HOME is a necessary trade-off when RF-ADMIN is high.

5.7 Confidentiality protection

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (e).

- **CON_INGEST-1** The product shall protect the confidentially and integrity of the collected network element monitoring data.

- **CON_INGEST-2** The product shall cryptographically protect relevant data at rest and in transit, including at minimum:

  1) secrets

  2) confidential configuration data

  3) metrics that can expose confidential data

- **CON_CRYPTO-3** To prevent rollback or downgrade the product shall:

  1) enforce a monotonic cipher suite policy configuration (or equivalent mechanism);

2) prevent the re-enabling of deprecated algorithms or the disabling of security checks via a rollback operation without having an explicit logged administrative override in place.

NOTE: More details for **CON_CRYPTO-3** in ETSI EN 304 642 [i.17].

- **CON_CHANNEL-4** The product shall ensure that the secure channel uses cryptographic functions and configuration according to annex K.
- **CON_CHANNEL-5** Endpoints within the product shall cryptographically verify all other endpoints in a secure channel using mutual authentication.

5.8 Integrity protection

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (f).

- **INT_CONF-1** The product shall interface only as defined in **CON_CHANNEL-5**.
- **INT_CONF-2** The product shall ensure that:

  1) product configuration is protected against unauthorised modification and disclosure; and

  2) only the intended managed element can obtain the relevant configuration; and

  3) the element can verify the integrity of the configuration.

  This requirement applies products that distribute or make available configuration to managed elements.
- **INT_CONF-3** The configuration interfacing design shall enable the managed element to cryptographically verify the authenticity of the product.
- **INT_ROTATE-4** The product shall support and implement an on-demand rotation of cryptographic keys.
- **INT_ROTATE-5** The product shall support the initialisation of trust with the managed elements.
- **INT_ROTATE-6** The product shall not trust expired secrets.

EXAMPLE: Every PKI tree starts from the creation of the Certificate Authority. The administrator intervention is then to distribute the public part of the CA to all targets, which needs to trust the derived keys from this CA.

5.9 Data minimisation

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (g).

- **DM_RETENTION-1** The product shall define what is logged, and how long that record is kept by default, in group level accuracy.
- **DM_RETENTION-2** The product shall define which metrics are gathered, and how long those records are kept by describing, at minimum:

  1) metric name

  2) metric description

  3) metric cadence, if relevant for the collected metric

  4) default storage time
- **DM_RETENTION-3** The product shall not collect data unrelated to the purpose of the product operation.

EXAMPLE: Group-level accuracy may resemble * application debug output * application output labelled warning or critical * privilege escalations in the application operation * network configuration changes.

5.10 Availability protection

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (h).

For **low** risk:

- **AP_HA-1** Operating system, if part of the product, or product updates and changes shall not be considered as exceptions in the product general availability definition.
- **AP_HA-2** The product shall emit security events about detected issues that affect the availability of the product and its provided services.

NOTE: **AP_HA-1** clarifies a common measurement misrepresentation. The requirement extends the **SU_UPDATE-2**. Updates are part of the product availability regardless of what layer is being updated.

For **medium** risk:

- everything in low risk; and
- **AP_HA-3** The product shall tolerate loss of external resources within the limits of the defined availability;
- **AP_HA-4** The product shall minimise the impact to other systems when anomalies occur.

For **high** risk:

- everything in low risk; and
- everything in medium risk; and
- **AP_HA-5** The product shall implement coordinated brute-force and overload protection mechanisms that not only detect excessive authentication attempts or inbound traffic surges, but also enforce active mitigation actions, including at minimum:
  1) temporary IP blocking; and
  2) message buffering; and
  3) QoS parameterisation.
- **AP_HA-6** The product shall implement recovery or failover mechanisms.
- **AP_HA-7** The product shall implement DDoS mitigations including at minimum:
  1) detection and logging of volumetric or protocol abuse affecting product availability;
  2) active mitigation actions that preserve or restore essential management functions within a configurable timeframe;
  3) rate limiting, traffic shaping, connection throttling, or temporary blocking of abusive sources;
  4) controlled degradation, traffic redirection, or temporary suspension of non-essential services or interfaces for a configurable time;
  5) coordination with external DDoS defence or scrubbing systems where documented as part of the operational environment (see CYB_OPS-1).

  This requirement applies to products which can be exposed to DDoS.

5.11 Non-interference

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (i).

For **low** risk:

- **IM_SEGMENT-1** The product shall support network segmentation for management traffic where applicable.

For **medium** risk:

- everything in low risk; and
- **IM_SEGMENT-2** Available management APIs shall accept traffic only from reasonably limited known sources.

EXAMPLE: A reasonably limited known source would be IETF RFC 1918 [i.8] private subnet.

NOTE 1: The requirement **IM_SEGMENT-2** is designed to be combined with **EMM_ROUTE-2** to reach the required level of protection.

For **high** risk:

- everything in low risk; and
- everything in medium risk; and
- **IM_SEGMENT-3** Available interfaces shall accept traffic only from a dedicated virtually or physically connected subnet.

NOTE 2: In default configuration applies to all interfaces regardless of the connectivity.

NOTE 3: The requirement **CYB_OPS-2** classifies management traffic to be Application level traffic making the low level OT designs incompatible with the present document.

5.12 Attack surface minimisation

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (j).

- **MAS_TECH-1** The product shall:
  1) document all communication interfaces; and
  2) refrain from exposing any interfaces or initiating connections other than those documented; and
  3) disable by default interfaces not required for the intended use.
- **MAS_TECH-2** The product shall not connect to undocumented RDPS services.

5.13 Exploit mitigation

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (k).

For **low** risk:

- **EMM_ROUTE-1** Where management connections to managed elements are not wholly contained within a dedicated trusted management segment documented per **IM_SEGMENT** and **CYB_OPS-1**, the product or documented operational environment shall enforce controls that limit management traffic by managed element or server identity and destination address, appropriate to the intended and reasonably foreseeable use.

For **medium** risk:

- everything in low risk; and
- **EMM_ROUTE-2** The product shall only permit traffic that is validated and explicitly authorised to transit the management connection.

For **high** risk:

- everything in low risk; and
- everything in medium risk; and

- **EMM_ROUTE-3** The product shall emit an auditable event from out-of-place traffic.

5.14 Monitoring

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (l).

For **low** risk:

- **MON_LOG-1** The product shall protect log data of events from unauthorised access.
- **MON_LOG-2** The product shall protect log data of events from modification including their deletion, except if the modification relates to an execution of planned rotation policy in the product.
- **MON_LOG-3** The product shall protect the confidentiality of events within log data.
- **MON_LOG-4** The product shall include, at minimum, the following fields in a machine-readable format in its log data:
    1) event timestamp;
    2) actor identity;
    3) action type;
    4) affected non-sensitive scope; and
    5) object identifiers.
- **MON_LOG-5** The product shall log all received relevant events from its managed elements in a machine readable format including, at minimum:
    1) incidents;
    2) alarms;
    3) time shift alarms.
- **MON_LOG-6** The product shall generate auditable events including, at minimum:
    1) successful and failed authentication events;
    2) session establishment attempts with source details;
    3) session termination events with a reason;
    4) session validation checks like number of concurrent sessions;
    5) privilege and role changes;
    6) configuration changes;
    7) element enrolment and unenrolment;
    8) trust-anchor changes;
    9) policy changes;
    10) credential changes;
    11) events described by clause 5.5;
    12) installation successes and failures in the managed elements, if that information can be extracted from the targets;
    13) installation successes and failures in the product itself.

        This requirement applies to the subset of products that support the corresponding function for each item.

- **MON_LOG-7** The product shall log boot or initialisation events including at minimum:

  1) timestamped boot stage progression;

  2) software component verification and initialisation actions; and

  3) recovery mode activations if in use.

  This requirement applies to the subset of products that support the corresponding function for each item.

NOTE 1: **MON_LOG-7** Writing a log record in case of an error during the booting process might not be possible in all cases, as the product is not completely functional when the booting process has not successfully completed. The event recording function is made available during the booting process.

For **medium** risk:

- everything in low risk; and
- **MON_LOG-8:** The product shall actively schedule backups for log information;
- **MON_LOG-9:** The product shall maintain tamper-evident audit logs.

For **high** risk:

- everything in low risk; and
- everything in medium risk; and
- **MON_LOG-10** The product shall support forwarding of relevant administrative events to an external logging or SIEM system.
- **MON_LOG-11** The product shall produce logs, SIEM event data transfer format, field attributes and event descriptions in a machine readable format.
- **MON_LOG-12** The product shall export logs as data artifacts that preserve essential fields, at minimum:

  1) timestamp when the event occurred;

  2) actor;

  3) action type;

  4) affected scope;

  5) result.

- **MON_LOG-13** The product shall record sufficient provenance information to attribute a change to an actor and context information related to, at minimum:

  1) authoritative subject;

  2) automated workflow if relevant for the event context;

  3) policy or rule identifier; and

  4) triggering event reference.

NOTE 2: **MON_LOG-13** describes privilege escalations that are done in computation. A common tactic to infiltrate a system is to trick it to escalate attacker access rights.

- **MON_METRICS-14** The product shall prevent alteration of collected and stored metrics data.
- **MON_METRICS-15** The product shall dispatch an event noting the import of previously recorded metric data if that data will overwrite existing data.
- **MON_METRICS-16** The product shall record metrics name, purpose, and value interpretation shall in a manner accessible to the product user.

NOTE 3: **MON_METRICS-16** leaves open how the information is conveyed to the product user. It could be a dedicated portal within the product or machine readable output having the same information.

- **MON_METRICS-17** The product shall collect, track, and store metrics on, at minimum:

  1) availability and status changes, like process and service crashes and restarts;

  2) incidents, warning and notification events reported by the target;

  3) relevant operative information like CPU, memory, disk utilisation;

  4) relevant networking metrics like throughput and protocol errors;

  5) relevant databases and storage health metrics like queries per second, latency and throughput;

  6) GUI and API latencies, where available from the following targets:

     - managed elements, where such metrics are available or can be reasonably synthetised;
     - provided services;
     - the system itself.

5.15 Factory reset and data portability

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (m).

NOTE: Due to complexity, and industry wide use of various protocols and best practices, the support for data transfer is not required.

- **DRT_DELETE-1** The product shall:

  1. provide a function to remove all data and settings, or
  2. support full re-installation to restore to its secure-by-default state.

- **DRT_DELETE-2** If import and export of data is available, the related data transfer shall implement **INT_CONF-1**.

6 Assessment criteria for compliance with technical requirements

6.1 Introduction to the assessment and compliance criteria

6.1.0 Assessment guide

This clause provides objective and reproducible assessment criteria to determine whether a product complies with the technical security requirements of clause 5.

For each cybersecurity requirements defined in clause 5, the following clauses specify assessment criteria to determine if the technical requirement is met.

The assessment criteria for each security requirements are described in a structured manner, as follows:

- **Assessment reference:** Refers to the identifier of the concerned technical requirement.
- **Assessment objective:** Defines the security property or capability that shall be verified, ensuring that the assessment remains focused on the intent of the requirement.

- **Assessment preparation:** Describes the environment, setup, and preconditions required before executing the test with a view to guaranteeing consistent evaluation results. It includes the following elements as applicable:
  - Test environment: Describe the hardware, software, and network setup used for the assessment, including versions, topology, and any relevant dependencies.
  - Preconditions: Specify any configurations, credentials, or operational states that should be established before the test (e.g. product initialised, certificates loaded, user roles created).
  - Required tools: Identify the tools or software necessary to perform the assessment (e.g. vulnerability scanners, protocol fuzzers, traffic analysers, static code analysers, cryptographic test suites).
  - Required information/documentation for the assessment: Specify all information that is necessary to perform the assessment.
  - Reference any vendor-provided setup guides, configuration instructions, or operational manuals, as well as any relevant standards or technical notes, that define how the product shall be configured or operated for the assessment.
- **Assessment activities:** Provides execution steps to be performed such that the same assessment verdict would be reached when repeating these steps now or at a later point in time. Assessment activities may include, as applicable:
  - Review information/documentation for the assessment to confirm that the described implementation matches the requirement (e.g. verify that the security architecture document specifies TLS 1.2 or higher for all external interfaces, or that the password policy aligns with the defined threshold).
  - Perform security functional tests to verify the completeness and correctness of the information/documentation for the assessment.
  - Perform security functional or penetration tests to verify that implemented controls are correctly implemented e.g. to prevent unauthorised access or data modification (e.g. via attempting to log in with invalid credentials to test lockout enforcement or trying to modify protected configuration files without administrative privileges).
  - Analyse code or binaries to identify potential security weaknesses or misconfigurations (e.g. perform static analysis to detect hardcoded credentials or use dynamic analysis tools to identify buffer overflow or injection vulnerabilities).
  - Inspect configurations to ensure that required security parameters are correctly applied (e.g. check that weak cipher suites are disabled, two-factor authentication is enabled, and least-privilege access controls are configured in the system).
  - Observe runtime behaviour to confirm that protections such as encryption, authentication, and integrity verification operate as intended (e.g. monitor network traffic to ensure data in transit is encrypted or observe system logs to verify successful validation of digital signatures during startup).
- **Assessment verdict:** Defines the pass/fail criteria.
  - **Pass:** The assessment is considered passed if the product demonstrably fulfils the requirement and meets the defined security thresholds. Examples of such thresholds include:
    - Minimum cryptographic strength (e.g. AES-128 or higher).
    - Password policy limits (e.g. minimum of 12 characters).
    - Login protection mechanisms (e.g. account lockout after five consecutive failed attempts).
    - Resistance to a specified attack potential (e.g. equivalent to CSA High/AVA_VAN.3 or higher).
  - **Fail:** The assessment is considered failed if the requirement is not fulfilled, or if the defined security thresholds are not achieved (e.g. insufficient key length, missing authentication enforcement, or inadequate resistance to the required attack potential).

- **Assessment evidence:** Defines the artefacts and documentation collected to demonstrate that the requirement has been assessed and fulfilled. The evidence shall be sufficient to enable independent verification of the assessment results and to demonstrate compliance with the relevant CRA [i.1] essential requirements. The supporting evidence include, where applicable:
  - Test or assessment reports showing the steps performed and results obtained.
  - Logs, configuration files, or audit traces demonstrating the implementation of the requirement.
  - Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
  - Relevant vendor or design documentation describing the applied security measures.

6.2 Appropriate level of cybersecurity

6.2.1 CYB_GENERAL-1

Assessment objective: Product functionalities, interface operations and interactions with external services are documented and understood.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

Assessment activities:

1) Study the technical documentation;
2) Cross-reference the product documentation to the external system operations;
3) Monitor the network traffic and capture all targets the system is trying to initiate a connection with;
4) Operate at least a sample selection of the product's most comprehensive or complex core functions for the managing of the external elements to verify its functional correctness.

Assessment verdict:

1) Pass if product dependencies or external systems are named and their purpose and provisions are described; and
2) the services or external systems are clearly expressed as part of the architecture description; and
3) the monitored network traffic targets match the documentation; and
4) the sample selection of core functions operated and resulted in what is claimed.
5) Fail otherwise.

Assessment evidence:

- Screenshots of the conduct and results, before and after operation of the core functions.
- References to the documentation sections.
- Listing of discovered targets and an explanation of those targets.

6.2.2 CYB_GENERAL-2

Assessment objective: Product dependencies to external services and systems are documented and understood.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

Assessment activities:

1) Study the technical documentation;
2) Cross-reference the product documentation to the external system operations;
3) Monitor the network traffic and capture all targets the system is trying to initiate a connection with.

Assessment verdict:

1) Pass if product dependencies or external systems are named and their purpose and provisions are described; and
2) the services or external systems are clearly expressed as part of the architecture description; and
3) the monitored network traffic targets match the documentation.
4) Fail otherwise.

Assessment evidence:

- References to the documentation sections.
- Listing of discovered targets and an explanation of those targets.

6.2.3 CYB_GENERAL-3

Assessment objective: Dependencies to OS capabilities are documented and understood.

Assessment preparation: None.

Assessment activities:

1) Study the technical documentation.

Assessment verdict:

1) Pass if important and essential OS services and concepts are named; and
2) their usage to run the application workload is clearly expressed as part of the architecture description.
3) Fail otherwise.

Assessment evidence:

- References to documentation sections.

6.2.4 CYB_GENERAL-4

Assessment objective: New elements added into the management pool are able to adopt the trust initialised with the system.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Have a not yet and not enrolled managed element available for testing.

Assessment activities:

1) Investigate how the system initialises trust.
2) Perform necessary actions defined in the technical documentation.
3) Join the new element into the product and make it a managed element.
4) Rotate the keys used in previous steps.

5) Repeat in all connections where such trust is used.

Assessment verdict:

1) Pass, all tests pass without issues.

2) and they keys are changed to the new ones in a way that survives interruptions.

3) Fail otherwise.

Assessment evidence:

- References to documentation sections.

6.2.5 CYB_GENERAL-5

Assessment objective: To understand and to be able to take control over the keys used in confidentiality and integrity protection.

Assessment preparation: None.

Assessment activities:

1) Study the technical documentation.

2) Cross reference to the architectural description of how the encryption is used in different parts of the system.

Assessment verdict:

1) Pass, if the system user has an ability to change user controllable cryptographic keys in the system except the ones that are reasonably made immutable.

2) Fail otherwise.

Assessment evidence:

- References to documentation sections.

6.2.6 CYB_GENERAL-6

Assessment objective: To understand and to distinguish user accessible and manufacturer keys.

Assessment preparation: None.

Assessment activities:

1) Study the technical documentation.

2) Cross reference to the architectural description whether user accessible and manufacturer keys are declared.

Assessment verdict:

1) Pass, if the technical documentation matches with the user accessible keys in the product installation; and

2) the reasoning used to justify the used non-accessible keys is reasonable in the context of the product's foreseeable and intended use.

3) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.

- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.2.7 CYB_GENERAL-7

Assessment objective: Where multiple monitoring targets are operating, all shall have consistent times. Any received alarm of a drift or asynchrony correction shall be accurately documented and notification provided to administrator.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Have a system node in operation.
3) Have a managed element in operation.

Assessment activities:

1) Set the node and the chosen managed element to a wrong time that is off by at least an hour.
2) Set connected system service to a wrong time that deviates from real time by at least one hour.

Assessment verdict:

1) Pass, if the product detects the drift correction; and
2) creates a notification about the event.
3) Fail otherwise.

Assessment evidence:

- System notification from the logs.

6.2.8 CYB_OPS-8

Assessment objective: The product user is able to meet the expectations of the product with the operational environment.

Assessment preparation:

1) Study the technical documentation.

Assessment activities:

1) Cross-reference the provided deployment instructions to describe target environment design guidelines.

Assessment verdict:

1) Pass, if the deployment, update and upgrade instructions are aligned with the target environment functionalities.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.2.9 CYB_OPS-9

Assessment objective: The product user understands the different kinds of connectivity the product can use.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation.

Assessment activities:

1) Dump all relevant connectivity information from the product.
2) Cross-reference to the technical documentation.
3) Identify potential low level protocol usage that is not able to operate with adequate confidentiality.

Assessment verdict:

1) Pass, if no low level protocol usage is detected; and
2) the technical documentation matches the implementation.
3) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.2.10 CYB_OPS-10

This assessment is done based on the definitions in annex R.

6.3 No known exploitable vulnerabilities

6.3.1 KEV_EXPLOIT-1

Assessment objective: Automatic or other vulnerability scans at the assessment day prove that the product is without known exploitable vulnerabilities that are not addressed and mitigated.

Verify that:

1) Known exploitable vulnerabilities affecting the product are identified and the scanning delivered no additional results.
2) For each identified known exploitable vulnerability, one of the following applies:
   - the vulnerability assessment demonstrates that the vulnerability is not exploitable in the product; or
   - specific user guidance is provided to prevent exploitation.
3) No known exploitable vulnerability remains in the product without one of the above justifications.

Assessment preparation:

- Product documentation identifying components contained in the product (components may include software, firmware, or hardware components, as applicable).

- Component inventory, bill of materials, or equivalent software identification information, including version and patch-level information where available.
- Access to the product, or to relevant components such as binaries, packages, images, firmware, containers, or file systems, sufficient to perform vulnerability scanning where technically feasible.
- Vulnerability scanning tools and associated vulnerability databases suitable for identifying candidate vulnerabilities in the product.
- Access to recognised public vulnerability sources:
  - Public databases e.g. EUVD, CISA Known Exploited Vulnerabilities (KEV) Catalog, the CVE List, the NIST National Vulnerability Database (NVD) and relevant vendor advisories.
  - Complementary sources that may support identification of relevant vulnerabilities, where relevant, for example technical research papers, conference papers and other publicly available security research.

Assessment activities:

1) Review the product documentation, component inventory, bill of materials, or equivalent information to identify the components contained in the product (which may include software, firmware, or hardware components, as applicable) and their relevant versions or patch levels, where available.
2) Perform vulnerability scanning, where technically feasible, on the product or relevant components to identify candidate vulnerabilities affecting the product.
3) Assess, in accordance with prEN 40000-1-3 [i.6], the vulnerabilities identified through correlation of scanning results, product identification information, vendor advisories, and recognised public vulnerability sources.
4) For each identified known exploitable vulnerability, review the vulnerability assessment and verify whether it demonstrates that the vulnerability is not exploitable in the product.
5) Where the treatment of an identified known exploitable vulnerability relies on user guidance, review the user guidance and verify that it specifically addresses the conditions to prevent exploitation.
6) Verify that no identified known exploitable vulnerability affecting the product remains without:
   - a vulnerability assessment demonstrating non-exploitability in the product; or
   - specific required user guidance to prevent exploitation.

Assessment verdict:

1) Pass, if no known exploitable vulnerabilities affecting the product are identified; and
2) each of them is identified and covered either by a vulnerability assessment, demonstrating non-exploitability in the product, or by specific user guidance preventing exploitation.
3) Fail otherwise.

Assessment evidence:

- Vulnerability scanning results, including the tools and vulnerability databases used with snapshot date information.
- Recognised public vulnerability sources, vendor advisories, and product identification information used in the assessment.
- Vulnerability assessment records and conclusions produced in accordance with prEN 40000-1-3 [i.6].
- Product user guidance relied upon to prevent exploitation, where applicable.

6.4 Secure by default configuration

6.4.1 SBD_TECH-1

Assessment objective: The data on the product are cryptographically protected.

Assessment preparation: None.

Assessment activities:

1) Study the technical documentation.
2) Identify the structures where data is transferred as described in the requirement.
3) Study the deployment guidance and the protocols used.
4) Compare the cryptographic implementation of the product and of the technical documentation.

Assessment verdict:

1) Pass, if the data flow and transmission are identifiable from the technical documentation; and
2) testing the implementation of interfaces matches the documentation; and
3) the interfaces deploy the protocols operating the cryptographic means protecting the data in accordance to annex K.
4) Fail otherwise.

Assessment evidence:

1) Listing of tested interfaces and the protocol replies that show that cryptography as of annex K is used.
2) Listing of the interfaces, their deployed protocols with the invoked cryptographic means.

6.4.2 SBD_TECH-2

Assessment objective: The system user has the ability to leave the default configuration in order to enable for backward compatibility.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation.

Assessment activities:

1) Study the technical documentation.
2) Enable a by default disabled, backward compatible protocol or other cryptographic implementation.

Assessment verdict:

1) Pass, if the listed requirements are implemented when backward compatibility is offered.
2) Pass, if no backward compatibility is offered and the cryptography on the product is state-of-the-art as defined in annex K.
3) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.

- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.4.3 SBD_TECH-3

Assessment objective: The system user has the ability to restore secure default settings.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation.

Assessment activities:

1) Make configuration changes that negatively impact overall product cybersecurity.
2) Use the product function to restore default configuration.

Assessment verdict:

1) Pass, if the configuration changes have been reverted to a secure setting and settings unrelated to cybersecurity are unchanged.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.5 Security updates

6.5.1 SU_UPDATES-1

Assessment objective: The product has functionality to be securely updated.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Provide an update package on the foreseen source.

Assessment activities:

1) Either the product notifies the system user after the update package is made available, or, the assessor notifies the administrator about the availability.
2) Either the product itself or the system user updates the product with the package.
3) The product writes the event in the log file.

Assessment verdict:

1) Pass if the secure update completes successfully; and
2) the log entry is present; and
3) the documentation includes all the required information; and

4) the instructions are noting the custom requirements of the application, if any; and

5) the interfaces connected during the update procedure are known; and

6) the integrity of the content is ensured during the update procedure.

7) Fail otherwise.

Assessment evidence:

1) Documentation of the update package provision and the system user notification.

2) Documentation of the update conduct.

3) Screenshot of the log entry.

6.5.2 SU_UPDATES-2

Assessment objective: Responsibility of OS level upgrades can be elsewhere outside of the system control. Updates of the product OS and security relevant updates are divorced and can be scheduled according to the operational needs and the application is designed to tolerate this behaviour without compromising the service availability.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

Assessment activities:

1) Study the technical documentation about the separation of security relevant updates.

Assessment verdict:

1) Pass if cross referencing OS and Application update instructions makes it possible to maintain High Availability requirements defined in the technical documentation.

2) Fail otherwise.

Assessment evidence:

- References to documentation sections.

6.5.3 SU_UPDATES-3

Assessment objective: Products placed in the market at a specific date may have a new version of its software before the product is acquired, for this reason the newest product software version needs to be installed before its first use. This assessment verifies this condition is properly applied.

Assessment preparation:

1) Program a test source providing an authentic and integrity correct update package.

Assessment activities:

- Operate the test update server.
- Study the technical documentation.
- If needed, activate the update mechanism and check whether the mechanism is configurable.
- Check if the update mechanisms can be configured to check itself for updates, conduct the update on trigger, or run at first use.
- Configure the update mechanisms with respect to point in time of conduct.
- Powerup the product to simulate first use.

Assessment verdict:

- The technical documentation describes the update mechanism in sufficient practical detail to conduct the update.
- The test update is operated as configured on action, prior, or as part of the first use.
- The test update was operated as configured with respect to the point of time of conduct.

Assessment evidence:

- References to document sections.
- Screenshots from the update configurations and of the corresponding conducts.

6.5.4 SU_UPDATES-4

Assessment objective: The alteration of an update package is detected.

Assessment preparation:

1) Study the technical documentation.

Assessment activities:

1) Fetch a product update package from upstream source;
2) Verify the package.
3) Alter the package.
4) Verify the package.

Assessment verdict:

1) Pass, if package signature is valid and the used signature is implemented according to **CON_CRYPO-1**.**; and
2) alteration of the update package is detected.
3) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.5.5 SU_UPDATES-5

Assessment objective: Prevent accidental installation of older packages.

Assessment preparation:

1) Study the technical documentation.

Assessment activities:

1) Ensure update package repository continuous versioning lineage.

Assessment verdict:

1) Pass, if there is no out of order version numbering used within the implemented scheme.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.5.6 SU_UPDATES-6

Assessment objective: The product outage time after a failed update is minimised.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation.

Assessment activities:

1) Start an update.
2) Kill the process performing the update or otherwise, from the system side, interrupt the process unexpectedly.
3) Perform the instructed measures.

Assessment verdict:

1) Pass, if the system is able to recover from the test.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.5.7 SU_UPDATES-7

Assessment objective: The product allows to schedule or postpone updates that meet the high availability needs.

Assessment preparation:

1) Study the interface and how scheduling or postponing of an update works.
2) Study the technical documentation.

Assessment activities:

1) Study the interface and how the post-pone of an update works.

Assessment verdict:

1) Pass, if the system user controls the point in time the update is made.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.5.8 SU_UPDATES-8

Assessment objective: Any rollback operation is authorised and generates a log entry.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation.

Assessment activities:

1) Check that the user role to operate the rollback is authorised.
2) Login and perform a rollback to a previous version.
3) Observe the emitted audit record.

Assessment verdict:

1) Pass, if rollback is done successfully; and
2) an audit event is emitted.
3) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.5.9 SU_UPDATES-9

Assessment objective: The product recovers after a failed update either to the operational, or a secure state that cannot be exploited.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation.

Assessment activities:

1) Initiate update;

2) Interrupt the update by killing the active update process.

Assessment verdict:

1) Pass, if the system recovers to a functional operational or a secure state.

2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.5.10 SU_UPDATES-10

Assessment objective: The system user receives information when a product update is made available.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

2) Study the technical documentation.

Assessment activities:

1) Study the system and the notification mechanism.

Assessment verdict:

1) Pass, if the notification mechanism functions as expected, which is either with on-product mechanism, or verify that there are direct manufacturer-to-system-user notifications on available updates.

2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.5.11 SU_UPDATES-11

Assessment objective: The product can provide a list of the components it is constituted from and provide a list of the managed elements.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

2) Study the technical documentation.

Assessment activities:

1) Investigate the version information.

2) Cross-reference the components to the technical documentation and identify which can be updated and are subject to versioning.

Assessment verdict:

1) Pass, if no important components are left out from the versioning.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.5.12 SU_UPDATES-12

Assessment objective: The product user understands when the system is in update operation.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation.

Assessment activities:

1) Investigate the system log trail about updates.
2) Initiate a download if not performed.

Assessment verdict:

1) Pass, if the logs show the update package being transferred to the system.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.5.13 SU_UPDATES-13

Assessment objective: The product operates with the latest available updates.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Launch an old version of the product.
3) Study the technical documentation.

Assessment activities:

1) Have an old version of the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation and the logs.

Assessment verdict:

1) Pass, if update happens without user interaction.
2) Fail otherwise.

NOTE: System time distortion is allowable for testing purposes.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.5.14 SU_UPDATES-14

Assessment objective: If the product has automated update functionality, then this functionality is activated by default.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation.

Assessment activities:

1) Investigate the configuration options.

Assessment verdict:

1) Pass, if automatic updates are turned on by default.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.5.15 SU_UPDATES-15

Assessment objective: The update process does not decrease the availability of the product.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation.

Assessment activities:

1) Investigate the update functionality.
2) Test the update.

Assessment verdict:

1) Pass, if the update strategy used is expected to finish successfully without impacting the availability of the product; and
2) if the update of a layer defined in clause 4.3.2 does not impact the availability of the product.
3) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.6 Authentication and access control

6.6.1 AAC_AUTH-1

Assessment objective: Identity management as basis for authentication is supported.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation how to interact with the system.

Assessment activities:

1) Study the documented deployment guidance.

Assessment verdict:

1) Pass if one of the listed methods is supported.
2) Fail otherwise.

Assessment evidence:

- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.6.2 AAC_AUTH-2

Assessment objective: Any subject receives an individual key, either on board generated or imported.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation how to interact with the system.

Assessment activities:

1) Study the documented deployment guidance.

Assessment verdict:

1) Pass if no predefined secrets or keys are used to identify the first subject.
2) Fail otherwise.

Assessment evidence:

- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.6.3 AAC_AUTH-3

Assessment objective: Subject identification is not relying on pre-determined defaults.

Assessment preparation:

1) Study the technical documentation how to interact with the system.

Assessment activities:

1) Investigate the product how it is take into use.
2) Take the product in to use for the first time.

Assessment verdict:

1) Pass, if the product mechanism does not rely on pre-determined secrets, and
2) the credential creation is forced as part of the first use.
3) Fail otherwise.

Assessment evidence:

- Screenshots, captures, or console outputs confirming the correct authentication with MFA.
- Logs from the authentication and rejection events.
- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.

6.6.4 AAC_AUTH-4

Assessment objective: System users are identified with multi-factor authentication.

Assessment preparation:

1) Study the technical documentation how to interact with the system.

Assessment activities:

1) Investigate the multifactor authentication implementation.
2) Try to access with a wrongly applied authentication method.

Assessment verdict:

1) Pass, if MFA is used and is required from the authenticating human user; and
2) if the authentication with the wrongly applied method was rejected.
3) Fail otherwise.

Assessment evidence:

- Screenshots, captures, or console outputs confirming the correct authentication with MFA.
- Logs from the authentication and rejection events.
- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.

6.6.5 AAC_AUTH-5

Assessment objective: Have an ability to adopt the system users entity context practices.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation how to interact with the system.

Assessment activities:

1) Investigate the product and the documentation.
2) Check and set the duration of a session to a duration suitable for the assessment.
3) Launch the session and keep it passive while measuring the time elapsing.

Assessment verdict:

1) Pass, if default is set to the required limit and the user has an ability to reconfigure it; and
2) the session gets terminated after reaching the set time and that meets the applied setting.
3) Fail otherwise.

Assessment evidence:

- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.6.6 AAC_AUTH-6

Assessment objective: Authorised users have assigned execution and resource access rights.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation how to interact with the system.

Assessment activities:

1) Investigate the product and the documentation.
2) Try to execute commands not assigned to the present user role.

Assessment verdict:

1) Pass, if the user roles defined or other structures match with the assigned rights, and
2) the command execution beyond the present user role gets rejected.
3) Fail otherwise.

Assessment evidence:

- Screenshots, captures, or console outputs proving the users execute commands and access only those records that are permitted to their role.
- Evidence from the command rejection.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.
- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.

6.6.7 AAC_AUTH-7

Assessment objective: All interfaces, controls and sensitive operations are protected by authorisation.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation how to interact with the system.

Assessment activities:

1) Investigate the product and the documentation;
2) Identify all interfaces that are used to interface with users, other systems or components.

Assessment verdict:

1) Pass if authentication and authorisation is performed on discovered interfaces.
2) Fail otherwise.

Assessment evidence:

- List of the tested product user interfaces and assigned evidence of the authentication and authorisation operation and their results;
- Metrics output relevant for the activities, if available;

- Relevant vendor or design documentation describing the applied measures;
- Test reports showing the steps performed and results obtained;
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour;
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.6.8 AAC_AUTH-8

Assessment objective: The authentication and communication on all product user interfaces is cryptographically appropriately protected:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation how to interact with the system.

Assessment activities:

1) Investigate the product and the documentation.
2) Identify all interfaces that are used to interface with users, other systems or components.
3) Check whether each interface deploys a protocol with appropriate cryptography from annex K.

Assessment verdict:

1) Pass if the discovered interface implements cryptography based on annex K in the default settings.
2) Fail otherwise.

Assessment evidence:

- List of interfaces and their operated protocols with assigned cryptographic methods.
- Screenshots, captures, or console outputs confirming the matched protocol execution.
- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.6.9 AAC_AUTH-9

Assessment objective: Any event in relation with user authorisation gets a logging record.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation how to interact with the system.

Assessment activities:

1) To trigger listed Assessment activities:
    1) Login to a user role that does not have access to the listed activities.
    2) Try to escalate the authorisation by calling a command not allowed for the present role.

Assessment verdict:

1) Pass, if the activity is rejected; and

2) an auditable event is emitted.

3) Fail otherwise.

Assessment evidence:

- Log record from the command rejection.
- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.

6.6.10 AAC_AUTH-10

Assessment objective: All privileged actions receive an authorisation before their execution.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

2) Study the technical documentation how to interact with the system.

Assessment activities:

1) Login to a user role.

2) Try to escalate the authorisation by calling a command not allowed for the present role.

3) Execute at least listed activities.

Assessment verdict:

1) Pass, if the execution is rejected; and

2) an auditable event is emitted for each different activity.

3) Fail otherwise.

Assessment evidence:

- Evidence like screenshots and logs about login procedure, escalating command call and the product reaction.
- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.

6.6.11 AAC_AUTH-11

Assessment objective: The authorisation for a privileged action is recorded in the log files.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

2) Study the technical documentation how to interact with the system.

Assessment activities:

1) Investigate the system.

2) Login and trigger a security policy change as privileged action.

Assessment verdict:

1) Pass if an auditable event is emitted with the listed information.

2) Fail otherwise.

Assessment evidence:

- Printout of logging records documenting the authorisation permission for the security policy change.
- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.6.12 AAC_AUTH-12

Assessment objective: Any privileged action has received its authorisation prior execution, except the action is to restore the logging functionality.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

2) Study the technical documentation how to interact with the system.

Assessment activities:

1) Investigate the system.

2) Login as privileged user.

3) Disable intentionally all auditable event collection systems from outside the product by either:

    1) making the file based system read only; or

    2) by disrupting the connectivity to a centralised system;

4) Trigger listed activities.

Assessment verdict:

1) Pass, if execution of privileged action fails in the described conditions or audit log records for all the executed actions are not lost and available in the external log storage when operational activity is restored.

2) Fail otherwise.

Assessment evidence:

- Evidence of system about the rejection of the command and that it is not executed.
- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.6.13 AAC_MACHINE-13

Assessment objective: Within machine-to-machine communications the authentication does not use passwords.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation how to interact with the system.

Assessment activities:

1) Investigate the system.
2) Setup a communication with a managed element and verify the used authentication method.

Assessment verdict:

1) Pass if an alternative to preshared keys or passwords is provided.
2) Fail otherwise.

Assessment evidence:

- Metrics output showing detected system or managed element when setting up a communication channel;
- Evidence confirming the functionality like:
  - Relevant vendor or design documentation describing the applied measures.
  - Test reports showing the steps performed and results obtained.
  - Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
  - Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.6.14 AAC_MACHINE-14

Assessment objective: The machine user operates with the lowest necessary privileges.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation how to interact with the system.

Assessment activities:

1) Investigate the system.

Assessment verdict:

1) Pass if the machine access credentials do not inherit wider access rights than the purpose of the interaction requires within reasonable limits.
2) Fail otherwise.

Assessment evidence:

- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.

- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.7 Confidentiality protection

6.7.1 CON_INGEST-1

Assessment objective: The integrity and confidentiality of the ingested data is protected.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation.

Assessment activities:

1) Study the monitoring data ingestion:
    1) The reception and/or querying mechanism.
    2) The ingestion workflow steps.
    3) Intermediate storages used in the processing.
    4) The enrichment and filtering of data ingestion.
    5) The communication between the systems involved in the processing.
2) The storage systems used to serve the data for later use.

Assessment verdict:

1) Pass, if means for confidentiality and integrity are effective for the ingested data.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.7.2 CON_INGEST-2

Assessment objective: Relevant data types as listed are cryptographically protected at rest and in transit.

Assessment preparation:

1) Extending the assessment defined in clause 6.7.1.

Assessment activities:

1) Study the listed relevant data handling.

Assessment verdict:

1) Pass, if the data in rest and in transit follows annex K guidance with the default configuration.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.7.3 CON_CRYPTO-3

Assessment objective: Attackers cannot version-rollback, downgrade or shorten key length of the actually deployed cipher suite.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation.

Assessment activities:

1) Study the product operation.
2) Try to rollback to an older cryptographic version.

Assessment verdict:

1) Pass, if the listed requirements are implemented; and
2) if the rollback trial is rejected with corresponding log entry.
3) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the rejection of the rollback trial.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.7.4 CON_CHANNEL-4

Assessment objective: The implementation and operation follows the Agreed Cryptographic Mechanisms specification and annex K.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

Assessment activities:

1) Study the technical documentation.
2) Identify the patterns from architectural documentation where encryption is required.
3) Study the implementation from the product or from the technical documentation.

Assessment verdict:

1) Pass if the documentation describes with enough details how and where the cryptographic features and functions are used, and

2) handling of data is identified and protected with cryptography as defined in annex K.

3) Fail otherwise.

Assessment evidence:

1) References to documentation sections.

6.7.5 CON_CHANNEL-5

Assessment objective: All communicating entities are mutually authenticated with cryptographic means.

Assessment preparation: None.

Assessment activities:

1) Study the technical documentation.

2) Identify the structures where administrative, PII or otherwise privileged information is transferred.

3) Study the implementation from the product and from the technical documentation.

Assessment verdict:

1) Pass, if the mechanism for mutual authentication is implemented.

2) Fail otherwise.

Assessment evidence:

1) References to documentation sections.

6.8 Integrity protection

6.8.1 INT_CONF-1

Assessment objective: All management actions and interactions between the product and the managed elements use only secure channels.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

Assessment activities:

1) Study the technical documentation.

2) Study the product and all available interfaces in operation.

3) Monitor all network activity.

Assessment verdict:

1) Pass, if a secure channel is used in interfacing with the system.

2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.

- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.8.2 INT_CONF-2

Assessment objective: The configuration data provided from the product to the managed element is protected against tampering and its integrity can be verified.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Have a managed element connected to the system.
3) Have a second managed element connected to the system.
4) Have a third element that is not enrolled to the managed network.

Assessment activities:

1) Study the technical documentation.
2) Initiate configuration transfer to the first managed element.
3) Repeat transfer, and distort the configuration if it is possible by editing the content while keeping a valid schema.
4) Attempt to transfer of the configuration to the second element that is intended for the first one.
5) Attempt to transfer of the configuration to the third element that is not enrolled.

Assessment verdict:

1) Pass, if the configuration transfer in step 2 succeeds; and
2) the configuration transfer attempt in steps 3, 4 and 5 fails.
3) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.8.3 INT_CONF-3

Assessment objective: The product supports authenticity requests received from its management elements.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Have a managed element connected to the system.

Assessment activities:

1) Study the technical documentation.
2) Study the connection towards the product from the managed element side.

Assessment verdict:

1) Pass, if the product supports the managed element's cryptographic authenticity verification.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.8.4 INT_ROTATE-4

Assessment objective: When employees and administrators roles change, the related keys are rotated.

Assessment preparation: None.

Assessment activities:

1) Study the technical documentation.
2) Cross reference the instructions how and how often to do rotation of important keys to industry state-of-the art policies.

Assessment verdict:

1) Pass, if key rotation can be made on demand; and
2) the instructed rotation policy matches with the foreseeable use of the product; and
3) the keys can be initialised when the product is taken into use for a first time or after a reset to factory settings.
4) Fail otherwise.

Assessment evidence:

1) References to documentation sections.

6.8.5 INT_ROTATE-5

Assessment objective: New managed elements are initialised with shared secrets, trust anchors and with the product support.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Have an untrusted network element to test with.

Assessment activities:

1) Study the technical documentation.
2) Reset the managed element to factory defaults.
3) Integrate the untrusted element as new managed element into the network.

Assessment verdict:

1) Pass, if a integrated managed element has the cryptographical keys and trust structures in use after the test actions.

2) Fail otherwise.

Assessment evidence:

1) References to documentation sections.

6.8.6 INT_ROTATE-6

Assessment objective: The product operates only with valid keys.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

Assessment activities:

1) Configure the product with an expired key.

2) Reboot the necessary services.

Assessment verdict:

1) Pass, if an event is emitted to logs and the system operation is halted if the key is significant for the operation or the service.

2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.9 Data minimisation

6.9.1 DM_RETENTION-1

Assessment objective: Ensure that the product user understands what data is being collected.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

2) Study the technical documentation on how to deploy the system.

Assessment activities:

1) Cross-reference the product settings and output to the documentation.

2) List the event types the product collects from managed elements out of present log files.

Assessment verdict:

1) Pass the presented categories matches the product operation; and

2) the listed retention times of the log records match with the expected use of the product.

3) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.9.2 DM_RETENTION-2

Assessment objective: The product collects only those metric data that are documented to the product user.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation on how to deploy the system.

Assessment activities:

1) Cross-reference the product settings and output to the documentation.

Assessment verdict:

1) Pass, if the listed metric data types are available in the technical documentation; and
2) the collected metrics and the stored metric records matches the documentation.
3) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.9.3 DM_RETENTION-3

Assessment objective: The product collects only those metric data types that are defined in the technical documentation.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation on how to deploy the system.

Assessment activities:

1) Study the information provided by **DM_RETENTION-2** and **DM_RETENTION-3**.

Assessment verdict:

1) Pass, if the ingested data follows the requirement definition.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.

- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.10 Availability protection

6.10.1 AP_HA-1

Assessment objective: Events by changes of the product itself that impact the product availability do not render the product behaviour unpredictable. The product keeps the availability time definitions.

Assessment preparation:

1) Study the technical documentation.

Assessment activities:

1) Study the metrics definition and define what would happen if a operating system update outside of the product context as defined in **SU_UPDATE-2**.

Assessment verdict:

1) Pass, if the product availability definition does not list exceptional events that are not counted towards availability.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.10.2 AP_HA-2

Assessment objective: A product and product-services outage, or a performance decrease trigger a security event.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation.

Assessment activities:

1) Study the technical documentation;
2) Disconnect or make unavailable a service, a compute node, a rack, or a datacenter based on the tolerable disturbances provided in the technical documentation.

Assessment verdict:

1) Pass, if an event is emitted as a result of the test activity.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.10.3 AP_HA-3

Assessment objective: Even during the specified tolerable loss of essential external resources, the product remains operational.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

Assessment activities:

1) Study the availability definition from the documentation.
2) Disconnect or make unavailable a service, a compute node, a rack, or a datacenter based on the tolerable definitions provided in the technical documentation.
3) Wait for stability.
4) Reconnect or make available the previously removed resource.
5) Wait for stability.

Assessment verdict:

1) Pass if recovery expectations are clearly defined; and
2) the system returns to stability after removal of the maximum capacity mentioned in the toleration description; and
3) the deleted or removed resources returns operation after they are reintroduced to the system; and
4) the defined high availability is held.
5) Fail otherwise.

NOTE: The selection of the resource to be removed should meet the principal of the most needed or having the highest priority resource for the expected product operations.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.10.4 AP_HA-4

Assessment objective: In case of product anomalies the product limits its impact on the managed elements or other dependent systems operation.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

Assessment activities:

1) Terminate arbitrarily one or more processes operated on the product.

2) Check whether such disruption impacts the managed element operation or other dependent systems operation.

Assessment verdict:

1) Pass, if the affected product disruptions do not impact the managed element or other dependent systems operation; and

2) the product resumes services after the disruptions have been removed.

3) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.10.5 AP_HA-5

Assessment objective: The product defences itself against brute-force and overload attacks, and enforces countermeasures.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

2) Ensure brute force and overload protections available are enabled and configured as per manufacturers instructions.

Assessment activities:

1) From a test host, generate repeated login attempts without valid credentials exceeding the expected threshold.

2) Observe detection and expected reaction to the generated traffic.

Assessment verdict:

1) Pass if the expected reaction is made by the system.

2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.10.6 AP_HA-6

Assessment objective: The product recovers in total or in parts from crashes or achieves a secure failover state in case the failure persists.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Identify queues/handlers that can buffer incoming work (Eg: task queues, batch operations).
3) Identify the failover mechanisms in place.

Assessment activities:

1) Feed the system with large volume of batch jobs or messages.
2) Execute concurrent operations in accordance.
3) Confirm the operations are batched and system is still serving requests and is not unresponsive.
4) Repeat the task flooding and kill a process, node or a datacenter that within the toleration of the availability and time the disturbance to the moment processing is ongoing.
5) Verify the successful completion of the test jobs.

Assessment verdict:

1) Pass if buffering and task queuing is performed within the queue depth or metrics as per the manufactured defined limits; and
2) the system load reduces as the tasks complete; and
3) the failover mechanisms function without intervention.
4) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.10.7 AP_HA-7

Assessment objective: The product protects itself from denial of service attacks with present countermeasures.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Ensure DDoS protections available are enabled and configured as per manufacturers instructions.

Assessment activities:

1) Flood the product with data packages from a simulator.
2) Check that the defined DDoS protection mechanisms get triggered.
3) Observe the mechanism operation and the resulting effects.
4) Confirm the system is still serving requests and is not unresponsive.

Assessment verdict:

1) Pass, if all relevant features are available as defined and mitigates DDoS attack is mitigated.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.11 Non-interference

6.11.1 IM_SEGMENT-1

Assessment objective: Protect the interface against unclassified traffic.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation on how to deploy the system.

Assessment activities:

1) Study the implementation of the product and determine if the management traffic would be possible to segregate to its own physical or virtual interface or subnet where a layer of authorisation could be used to segregate the traffic towards the product from other uses of the network served with the product.

Assessment verdict:

1) Pass the product **instructs** the product user how to deploy and communicate management traffic via a separated network segment.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.11.2 IM_SEGMENT-2

Assessment objective: Protect the interface against unclassified traffic.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation on how to deploy the system.

Assessment activities:

1) Study the implementation of the product and determine if the management traffic would be possible to segregate to its own physical or virtual interface or subnet where a layer of authorisation could be used to segregate the traffic towards the product from other uses of the network served with the product.

Assessment verdict:

1) Pass if the product **supports** utilising dedicated physical port for the management traffic or the product supports dedicated virtual subnet to be connected to the serving workload that is segregated from SRU traffic; and

2) the product instructs the product user how to deploy and use the provided product features.

3) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement;

6.11.3 IM_SEGMENT-3

Assessment objective: Protect the interface on unclassified traffic.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

2) Study the technical documentation on how to deploy the system.

Assessment activities:

1) Study the implementation of the product and determine if the management traffic would be possible to segregate to its own physical or virtual interface or subnet where a layer of authorisation could be used to segregate the traffic towards the product from other uses of the network served with the product.

2) Study the implementation of the product and determine if the management API is designed to reject unclassified network traffic.

3) Simulate unclassified network traffic on the management API.

Assessment verdict:

1) Pass, if the product **requires** utilising dedicated physical port for the management traffic or the product supports dedicated virtual subnet to be connected to the serving workload that is segregated from other traffic; and

2) the product reject network traffic that is not conformant to the connected networks and subnetworks; and

3) the simulated unclassified network traffic is rejected; and

4) the product instructs the product user how to deploy and connect to the networks and subnetworks in classified ways.

5) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.12 Attack surface minimisation

6.12.1 MAS_TECH-1

Assessment objective: The product user knows entirely all external product interfaces.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

Assessment activities:

1) Study the technical documentation.
2) Study the listed documented communication endpoints.
3) List all the interfaces the product is listening to or writing to.
4) Cross-reference the open interfaces to the documentation.

Assessment verdict:

1) Pass, if all interfaces used for communication are documented.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.12.2 MAS_TECH-2

Assessment objective: How the product communicates with RDPS is documented and made known to the product user.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

Assessment activities:

1) Study the technical documentation.
2) Study the listed dependencies to RDPS systems.
3) Capture all network traffic metadata that occurs by the product RDPS communication.
4) Trigger all possible actions that might result in a communication with RDPS services, like update, licensing verifications, etc.
5) Identify all systems with the help of the technical documentation.

Assessment verdict:

1) Pass, if the product does not initiate a connection with an undefined target.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.

- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.13 Exploit mitigation

6.13.1 EMM_ROUTE-1

Assessment objective: Protect the network from compromised elements.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation.

Assessment activities:

1) Investigate the implementation.

Assessment verdict:

1) Pass, if documented controls demonstrably limit management traffic by managed element identity and destination for the deployment model, or if non-applicability is justified per **IM_SEGMENT** and CYB_OPS-1.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.13.2 EMM_ROUTE-2

Assessment objective: Protect the network from compromised elements.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation.

Assessment activities:

1) Investigate the implementation and check whether communication is established and occurs only between the product and authorised manged elements that are permitted to address the management interface.

Assessment verdict:

1) Pass, if only management and control traffic is allowed in the link between the product and the managed element.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.13.3 EMM_ROUTE-3

Assessment objective: Enable product user investigations in case of occurring out-of-place-traffic.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation.

Assessment activities:

1) Investigate the implementation.
2) Send maliciously crafted packets toward the interface.
3) Perform actions that are not classified as management traffic to the management API.

Assessment verdict:

1) Pass, if an event is emitted summarising the detected rogue traffic.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.14 Monitoring

6.14.0 Logging tests

6.14.1 MON_LOG-1

Assessment objective: The logs are protected from disclosure and alteration.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation how to interact with the system.

Assessment activities:

1) Access the collected logs the expected way.
2) Access the collected logs the expected way without valid authorisation.

3) Access the collected logs un-expected way without valid authorisation.

Assessment verdict:

1) Pass if access is denied; and
2) if the event is detected and logged.
3) Fail otherwise.

Assessment evidence:

- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.14.2 MON_LOG-2

Assessment objective: The logs are protected from alteration including their deletion.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation how to interact with the system.

Assessment activities:

1) Access the collected logs the expected way.
2) Access the collected logs the expected way with valid authorisation, make an alteration to one and try to delete another log entry.

Assessment verdict:

1) Pass, if the product detects the alteration of logs and prevents the deletion.
2) Fail otherwise.

Assessment evidence:

- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.14.3 MON_LOG-3

Assessment objective: Protect the logs leaking information.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation how to interact with the system.

Assessment activities:

1) Study the product and the implementation.

Assessment verdict:

1) Pass, if the logging system protects the reading access to the log data in transit and at rest.
2) Fail if the data stored in local disk is accessible by all locally authenticated users without restrictions.
3) Fail otherwise.

Assessment evidence:

- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.14.4 MON_LOG-4

Assessment objective: Each log entry contains a minimum set of information enabling for an analysis of the logged event.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation how to interact with the system.

Assessment activities:

1) Study the log output.

Assessment verdict:

1) Pass if listed information is available in the log event systemically in the same machine readable manner.
2) Fail otherwise.

Assessment evidence:

- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.14.5 MON_LOG-5

Assessment objective: All defined event notifications received from the managed elements are recorded in a machine-readable format and enable for machine-based analysis.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

2) Have the managed element initialised and available with the required credentials.

3) Study the technical documentation on how to interact with the system.

Assessment activities:

1) Emit listed events from the managed element.

2) Study the log output.

Assessment verdict:

1) Pass if listed information is available in the log event systemically in a machine readable manner.

2) Fail otherwise.

Assessment evidence:

- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.14.6 MON_LOG-6

Assessment objective: The product's logging records enable for the analysis of the product behaviour.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

2) Have the managed element initialised and available with the required credentials.

3) Study the technical documentation on how to interact with the system.

Assessment activities:

1) Interact with the system to create all described events.

2) Study the log output.

Assessment verdict:

1) Pass if all required information is available in the log systemically in a machine readable manner.

2) Fail otherwise.

Assessment evidence:

- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.14.7 MON_LOG-7

Assessment objective: The log records allow to analyse whether the product has achieved the operational status or whether an error occurred in dependency of the achieved booting stage.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Have the managed element initialised and available with the required credentials.
3) Study the technical documentation on how to interact with the system.

Assessment activities:

1) Interact with the system to create described event.
2) Study the log output.

Assessment verdict:

1) Pass if required information is available in the log systemically in a machine readable manner.
2) Fail otherwise.

Assessment evidence:

- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.14.8 MON_LOG-8

Assessment objective: Even attackers who managed to gain access to the logging records cannot alter or eliminate the history as the logging has a scheduled external backup.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation on how to interact with the system.

Assessment activities:

1) Check whether the product provides a product user-set scheduled backup of the log records.
2) Verify that the scheduling of the backups is indeed applied.

Assessment verdict:

1) Pass if backup is scheduled and working.
2) Fail otherwise.

Assessment evidence:

- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.

- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.14.9 MON_LOG-9

Assessment objective: Even attackers who managed to gain access to the logging records cannot alter or eliminate the history.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation on how to interact with the system.

Assessment activities:

1) Identify how the logging mechanism works.
2) Change the logging storage outside of the product control while maintaining the schema.

Assessment verdict:

1) Pass if modification was noticed.
2) Fail otherwise.

Assessment evidence:

- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.14.10 MON_LOG-10

Assessment objective: Administrative events can be audited within the logs or at a SIEM system.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation on how to interact with the system.
3) Have an external logging SIEM system available and configured to receive events.

Assessment activities:

1) Make an action that is expected to generate an auditable event.
2) Study the event notification and cross reference the content to the technical documentation.
3) Check whether the event is externally made available in the logging or SIEM system.

Assessment verdict:

1) Pass, if the event notification is product-external available.
2) Fail otherwise.

Assessment evidence:

- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.14.11 MON_LOG-11

Assessment objective: Logging records, product-internal and on external systems, are machine readable and can be analysed in automated ways.

Assessment preparation: None.

Assessment activities: None.

Assessment verdict:

1) Pass, if the logging records are available product-external and are in a machine-readable format.
2) Fail, if evidence cannot be exported or loses critical context.
3) Fail otherwise.

Assessment evidence:

1) Pointers to the documentation.
2) Screenshot of machine-readable logging records.
3) References to the belonging documentation of record contents and formats.

6.14.12 MON_LOG-12

Assessment objective: The exported logging records provide a minimum set of information about the basic data of the event as defined to enable the product user for event analysis.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation on how to interact with the system.

Assessment activities:

1) Make an action that is expected to generate an auditable event.
2) Study the log output.

Assessment verdict:

1) Pass if all required information is available in in each logging record.
2) Fail otherwise.

Assessment evidence:

- Screenshot or console output of the logging records with identification of the minimum information parameters.
- References to the belonging documentation of record contents and formats.

- Metrics output relevant for the activities, if available.
- Test reports showing the steps performed and results obtained.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.14.13 MON_LOG-13

Assessment objective: The recorded event data enable to analyse the actor and context of the event.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation on how to interact with the system.

Assessment activities:

1) Make an action that is expected to generate an auditable event.
2) Study the log output.

Assessment verdict:

1) Pass, if the action applied can be attributed to actor and context with retrievable references.
2) Fail if changes cannot be deterministically attributed.
3) Fail otherwise.

Assessment evidence:

1) References to the belonging documentation of record contents and formats.
2) Screenshot or console output of the logging records with identification of the minimum information parameters.

6.14.14 MON_METRICS-14

Assessment objective: The ingestion pipeline design protects the metric data integrity.

Assessment preparation: None.

Assessment activities:

1) Study the technical documentation.

Assessment verdict:

1) Pass if no unauthorised process before ingestion of collected metrics data can alter the metrics before storage; and
2) if the storage can not be altered outside of desired storage handling.
3) Fail otherwise.

Assessment evidence:

1) References to documentation sections.

6.14.15 MON_METRICS-15

Assessment objective: Stored data wiping or overwriting can always be recognised.

Assessment preparation:

1) Have the product initialised and available with the default configuration.

2) Create required authentication credentials for the test.

3) Prepare an import data set that represents normal operational metric data from a managed element.

4) Create a copy of the import data set and modify the data to change also related integrity protection values.

Assessment activities:

1) Begin a time series data collection.

2) Restart the collection of timeseries data with the modified data set.

Assessment verdict: Pass if systems detects the modified data set.

Assessment evidence:

1) Collect output showing the whether the current metrics data is being handled by the normal flow as expected;

2) Collect output showing how the modified data set was accepted or discarded.

6.14.16 MON_METRICS-16

Assessment objective: The user has explanations about the meaning of each metric and is enabled to interpret those. Furthermore, the explanations clarify the relevance of collected metric data.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

Assessment activities:

1) Study the monitoring data GUI.

2) Study the provided documentation.

3) Investigate the metrics storage.

Assessment verdict:

1) Pass if there are no unknown metrics displayed or collected; and

2) if there are commonly well-known metrics displayed or collected, like CPU usage, which can remain without explanation; and

3) if a metric is recognised and a pointer to the documentation is provided (managed element manufacturer's reference documentation).

4) Fail otherwise.

Assessment evidence:

1) Output samples showing how the information is conveyed for the user.

NOTE: Whether a modified data set gets accepted or discarded might not be the product's but an administrator decision.

6.14.17 MON_METRICS-17

Assessment objective:

Monitoring metrics fulfils multiple objectives, including:

- Support users or administrators ability to detect compromised, misconfigured, or harmful connected elements through unusual, excessive, or risky patterns of use.

- To detect availability issues;
- Out of the normal behaviour, metrics indicate failures or compromise of both the managed elements and the product.
- The error metrics enable for tracing and serve as entry point for the analysis and detection of abnormal behaviour in the managed element and in the system.
- Response latencies on the product queries or protocol errors on incoming data from managed elements enable it to detect defective or compromised managed elements.
- The product provides a recording of the listed minimum set of data types.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Have at least one managed element as part of the system the product operates.
3) Have the managed element initialised and available with the required credentials.
4) Study the deployment instructions about sizing of the operative environment.
5) Study the technical documentation how to interact with the collected metrics data.

Assessment activities:

1) Study the provided technical documentation how to interpret the monitoring data.
2) Simulate abnormal behaviour by intentionally cutting the connection with a managed element and observe the monitoring data.
3) Restart the managed element.
4) Purposefully crash a process or restart a connected element.
5) Purposefully crash a product process.
6) Generate large amount of traffic in a random location.
7) Send a correct API request from the product towards each managed element API endpoint.
8) Send a correct API request from the managed element towards the product API endpoint.
9) Send an incorrect API request towards each system API endpoint.
10) Send a momentary spike of requests that exceeds the reasonable and expected load of incoming requests.

Outcomes:

1) Study the product behaviour from the collected metrics in terms of:
    1) process recovery;
    2) how the listed test activities are displayed in the collected metrics.

Assessment verdict:

1) Pass if basic administrative metrics are tracked and displayed; and
2) if the product process or the product recovers to normal operation; and
3) if the connection loss to the managed element is recognised; and
4) if by observing the metrics a baseline of the system operation can be established; and
5) if anomalies like load spikes after a restart can be observed; and

6) if the product detects and displays or reports the test event on the managed element; and

7) if the product monitoring data shows the expected operation statuses where applicable for both, the product and for the managed elements:

   - success rate;
   - operation failure rate;
   - query execution time;
   - response size; and

8) if the monitoring data the expected operations and their statuses per connected element and relevant system processes; and

9) if the monitoring data and notifies the disconnection from the provided service; and

10) if the disconnected service can be identified in the metrics; and

11) if corresponding metrics matches the generated traffic; and

12) if all API endpoints responds as expected; and

13) if the response latency is recorded in defined accuracy, where reasonably available; and

14) if system tracks the number of successful requests, where reasonably available; and

15) if the incorrect API requests are identified and accounted; and

16) if the spike of high volume requests is handled gracefully.

17) Fail otherwise.

Assessment evidence:

- Metrics output relevant for the activities, if available.
- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.15 Factory reset and data portability

6.15.1 DRT_DELETE-1

Assessment objective: The product user can remove all of his data from the product.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.

2) Study the technical documentation.

Assessment activities:

1) Change the product state in a way that generates storable information to all data storage solutions.

2) Perform deletion as instructed.

3) Investigate the data storage used in the product.

Assessment verdict:

1) Pass, if generated data was removed from all storage solutions.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.15.2 DRT_DELETE-2

Assessment objective: If applicable, the product user can import or export data with a secure channel.

Assessment preparation:

1) Have the product initialised and available with the default configuration and required credentials.
2) Study the technical documentation.
3) Change the product state in a way that generates stored data and generate outside the product a data set.

Assessment activities:

1) Export the previously in-product generated data and verify that a secure protocol as out of annex K is deployed.
2) Import the externally present data set and verify that a secure protocol as out of annex K is deployed.

Assessment verdict:

1) Pass, if for import and export a protocol as of annex K is deployed.
2) Fail otherwise.

Assessment evidence:

- Relevant vendor or design documentation describing the applied measures.
- Test reports showing the steps performed and results obtained.
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour.
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

Annex A (informative): Relationship between the present document and the essential cybersecurity requirements of EU Regulation (EU) 2024/2847

The present document has been prepared under the Commission's standardisation request C(2025) 618 final [i.3] to provide one voluntary means of conforming to the requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) (CRA) [i.1].

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

Table A.1: Relationship between the present document and the requirements of Regulation (EU) 2024/2847 - the Cyber Resilience Act

Description	Essential Requirements of Regulation (EU) 2024/2847	Clause(s) of the present document	Remarks / Notes
Annex I, Part I, (1)	"Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks."	Clause 5 and 6. Annex R: Annex R threat model, assets, and requirements, in particular REQ-RDPS-L-AUTH, REQ-RDPS-L-INTEG, REQ-RDPS-L-CONF, REQ-RDPS-L-AVAIL, and the corresponding RDPS-side requirements REQ-RDPS-R-AUTH, REQ-RDPS-R-INTEG, REQ-RDPS-R-CONF, REQ-RDPS-R-AVAIL.	Annex R identifies RDPS-boundary assets, associated security properties, aligned threats, and corresponding technical requirements. It does not itself define the manufacturer's risk assessment, but provides a technical framework to address RDPS-boundary risks once identified.
Annex I, Part I, (2)(a)	"Products with digital elements shall be made available on the market without known exploitable vulnerabilities."	Clauses 5.3 and 6.3	This is a broader product security, lifecycle, and vulnerability management obligation, not specifically an RDPS-boundary control.
Annex I, Part I, (2)(b)	"Products with digital elements shall be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state."	Clauses 5.4 and 6.4	This concerns broader product configuration requirements. Annex R is focused on RDPS-boundary interactions and does not itself define general secure-by-default product configuration requirements.

Description	Essential Requirements of Regulation (EU) 2024/2847	Clause(s) of the present document	Remarks / Notes
Annex I, Part I, (2)(c)	"Products with digital elements shall ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them"	Clauses 5.5 and 6.5	This concerns broader product lifecycle and update capabilities and is not directly addressed by the RDPS-boundary requirement set of annex R.
Annex I, Part I, (2)(d)	"Products with digital elements shall ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access"	Clauses 5.6 and 6.6 Annex R: REQ-RDPS-L-AUTH and REQ-RDPS-R-AUTH.	The primary annex R contribution is protection against acceptance of interactions whose source or origin is not genuine.
Annex I, Part I, (2)(e)	"Products with digital elements shall protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by best practice mechanisms, and by using other technical means."	Clauses 5.7 and 6.7 Annex R on Confidentiality: REQ-RDPS-L-CONF and REQ-RDPS-R-CONF.	The confidentiality requirements protect exchanged RDPS interaction content where disclosure creates unacceptable risk.
Annex I, Part I, (2)(f)	"Products with digital elements shall protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions."	Clauses 5.8 and 6.8 Annex R on Integrity: REQ-RDPS-L-INTEG and REQ-RDPS-R-INTEG	The integrity requirements protect against modification, substitution, corruption, or injection of interactions.
Annex I, Part I, (2)(g)	"Products with digital elements shall process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation)."	Clauses 5.9 and 6.9	This concerns broader product-level data processing and minimisation requirements. Annex R does not specifically address minimisation of RDPS-boundary exchanged or processed data.
Annex I, Part I, (2)(h)	"Products with digital elements shall protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks."	Clauses 5.10 and 6.10 Annex R: REQ-RDPS-L-AVAIL and REQ-RDPS-R-AVAIL.	These requirements address detection of unavailability, delay, or intolerable degradation, use of timeout or timeliness controls, defined degraded behaviour or secure state, support for recovery, and, at the stronger level, continuity of operation through failover, redundancy, or equivalent resilience mechanisms where necessary.

Description	Essential Requirements of Regulation (EU) 2024/2847	Clause(s) of the present document	Remarks / Notes
Annex I, Part I, (2)(i)	"Products with digital elements shall minimise the negative impact by the products themselves or connected products on the availability of services provided by other products or networks."	Clauses 5.11 and 6.11	This concerns broader product or network impact beyond the RDPS boundary and is therefore addressed by the core part of the standard rather than by annex R.
Annex I, Part I, (2)(j)	"Products with digital elements shall be designed, developed and produced to limit attack surfaces, including external interfaces."	Clauses 5.12 and 6.12 Annex R: REQ-RDPS-L-AUTH, REQ-RDPS-R-AUTH.	The core part of the standard is expected to address general attack-surface limitation. Annex R contributes only indirectly at the RDPS boundary by verifying source authenticity.
Annex I, Part I, (2)(k)	"Products with digital elements shall be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques."	Clauses 5.13 and 6.13 Annex R: REQ-RDPS-L-AVAIL and REQ-RDPS-R-AVAIL.	This is broader than the RDPS-boundary scope of annex R. Annex R contributes indirectly through degraded behaviour, secure state, recovery support, and resilience measures, but does not provide a standalone exploitation-mitigation requirement family.
Annex I, Part I, (2)(l)	"Products with digital elements shall provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user."	Clauses 5.14 and 6.14	This concerns broader product-level logging, recording, monitoring, and user-facing control requirements.
Annex I, Part I, (2)(m)	"Products with digital elements shall provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner."	Clauses 5.15 and 6.15	This concerns broader product-level data and settings lifecycle management and is outside the RDPS-boundary interaction focus of annex R.
Annex I, Part II	Vulnerability Handling Requirements	N/A	The present document scope does not cover this topic, refer to [i.6] for the associated requirements, their conditionality and assessment.

For Annex I, Part I, (1), see mapping table on the applicability of the technical cybersecurity requirements in clause 5.1.

Key to columns:

Description A textual reference to the requirement.

Requirements of Regulation

Identification of point(s) defining the requirement in Regulation (EU) 2024/2847 - the Cyber Resilience Act.

Clause(s) of the present document

Identification of clause(s) addressing the requirement in the present document

Presumption of conformity stays valid only as long as a reference to the present document is maintained in the list published in the Official Journal of the European Union. Users of the present document should consult frequently the latest list published in the Official Journal of the European Union.

Other Union legislation may be applicable to the product(s) falling within the scope of the present document.

Annex B (informative): Security analysis

B.0 Overview

This annex applies state of the art methodology to identify assets, threats, identify and evaluate risk factors, and associate risk factor levels with different use cases identified in the product context. This security analysis informs the applicability of the technical requirements.

The security analysis in this annex represents a risk assessment done by the standardisers solely for the purpose of informing the applicability of technical requirements.

A list of product assets are used to identify potential threats to the product. The assumptions are used to define the scope of potential threats that are addressed by this security analysis.

Risk factor levels for each use case are determined by using the definition of the use case to choose a risk factor level that most accurately represents the highest risk for that use case. The use case is restricted by the intended purpose and reasonably foreseeable use as specified by the manufacturer.

For each threat, a formula based on the risk factor levels is used to calculate the Likelihood and Impact of the threat. This security analysis uses the Likelihood and Impact of each threat to identify specific technical requirements that treat that risk.

B.1 Assets

B.1.1 Data

NMS client:

- NMS client executable
- Configuration of NMS client
- NMS-managed configuration of managed element
- Cryptographic materials
- Logs and metrics
- Data stored on the device being managed

NMS server:

- NMS server executable
- Catalog of managed devices
- Configuration for managed devices
- Network topology configuration
- Cryptographic materials
- Logs and metrics

B.1.2 Hardware

- Server hardware for on-premises deployment

B.1.3 Product and managed element functions

- Manages the network configuration of devices
- Manages the overall network configuration
- Checks and records the status of devices
- Device discovery
- Inventory management of managed elements
- Creates alerts or notifications of anomalies
- Collects, manages, and provides access to metrics, logs, and network topology information
- Functions of managed elements controlled or dependent on product

B.2 Risk factors

B.2.1 Overview

The risk factor levels determine the impact and likelihood of each threat in this security analysis. Risk factor levels also specify which requirements reduce the risk of each threat to satisfy all of the technical cybersecurity requirements in clause 5.

Risk factors may increase the likelihood of an incident, increase the impact of an incident, or both. As a result, different mitigation strategies may be more or less relevant to different risk factors.

The overall risk related to each use case should be considered as a result of combining risk factors affecting both likelihood and impact of an incident.

B.2.2 RF-ACC_ASSETS: Accessibility of network connected to product assets

How publicly accessible the network is that the product and its assets are connected to.

Rationale: The more unrestricted the access to the connected networks is, the more likely a threat actor can compromise the product via the network.

- **RF-ACC_ASSETS-LOW** Foreseeable use is only in an isolated private network
- **RF-ACC_ASSETS-MED** Foreseeable use is in a private network with filtered connection to public network without an interface listening incoming requests from the public network
- **RF-ACC_ASSETS-HI** Foreseeable use requires at least one interface listening traffic from a public network

B.2.3 RF-COMPLEX_CONF: Complexity of network configuration

How much interconnectivity and details are in the managed network configuration.

Rationale: The more details and configuration options the network has, the more likely is to make configuration errors that leads to increased attack surface.

- **RF-COMPLEX_CONF-LOW** Foreseeable use is to manage simple networks as defined in clause 4.2.1.3.
- **RF-COMPLEX_CONF-MED** In addition to **RF-COMPLEX_CONF-LOW**, the product supports:
  - interconnectivity of managed elements by distributing secrets to the elements; or
  - collects network events from the managed elements for configuration and automation purposes.
- **RF-COMPLEX_CONF-HI** In addition to **RF-COMPLEX_CONF-MED**, the product implements complex features like:
  - parameter optimisation for managed elements; or
  - workload execution of 3rd. party applications.

B.2.4 RF-COMPLEX_FUN: Complexity of product functions

How complex the available product functions are in its secure-by-default configuration.

Rationale: More complex functions means increased likelihood of errors in the implementation and more attack surface.

- **RF-COMPLEX_FUN-LOW** Product implements minimal features necessary to configure network connections of managed elements on a single site
- **RF-COMPLEX_FUN-MED** In addition to **RF-COMPLEX_FUN-LOW**, the product implements features like:
  - managed element control in more than one site; or
  - redundant connectivity and other failover mechanisms
- **RF-COMPLEX_FUN-HI** In addition to **RF-COMPLEX_FUN-MED**, the product implements complex features for large network like:
  - different tiers for process execution based on network delay;
  - or dynamic routing decisions based on user end location

B.2.5 RF-SENS_ASSETS: Sensitivity of managed assets

Measures the impact of the compromise of product assets taking into account the impact of any compromise of the managed assets.

Rationale: The impact of an attack on the product includes the impact it has on the managed assets.

- **RF-SENS_ASSETS-LOW** Little or no impact of compromise of product function, such as temporary delay in unimportant changes to network configuration
- **RF-SENS_ASSETS-MED** Moderate impact of compromise of product function, such as gradual loss of connectivity of moderately sensitive managed assets to each other
- **RF-SENS_ASSETS-HI** High impact of compromise of product function, such as severe loss of availability of highly sensitive functions of managed assets

B.2.6 RF-SENS_FUN: Sensitivity of functions of product

Describes the likelihood and impact of a risk based on sensitivity of functions of the product.

Rationale: The more sensitive the functions of the product, the higher the impact of unavailability or degradation of its functions.

- **RF-SENS_FUN-LOW** Foreseeable use is for unimportant functions, such as a DHCP server for a small home or lab
- **RF-SENS_FUN-MED** Foreseeable use is for moderately sensitive functions, such as configuring servers and network topology in an internal datacenter
- **RF-SENS_FUN-HI** Foreseeable use is for highly sensitive functions, such as the overall functioning and security of a nation-wide communication infrastructure

B.2.7 RF-NUM: Number of managed elements

How many elements are managed by the product.

Rationale: A larger number of elements increases the attack surface and the consequences of an attack.

- **RF-NUM-LOW** Low number of managed elements, such as in a home
- **RF-NUM-MED** Moderate number of managed elements, such as in a single datacenter
- **RF-NUM-HI** High number of managed elements, such as in a nation-wide telecommunication infrastructure

B.2.8 RF-ADMIN: Availability and skill of administration

What the availability and skill of administration is for the product.

Rationale: Skilled, fully resourced administration allows more risk transfer and can reduce the impact of incidents.

Type: Affects likelihood and impact of all attacks.

- **RF-ADMIN-LO** Foreseeable use is with fully resourced professional administration
- **RF-ADMIN-MED** Foreseeable use is with professional administration with limited resources
- **RF-ADMIN-HI** Foreseeable use is with unskilled or no administration

B.3 Assumptions

Assumptions are used to define the scope of the potential threats addressed by this analysis:

- The platform the product is running on is trustworthy.
- The product administrator is not intentionally hostile and is engaging in good faith efforts to administer the product properly.
- An attacker will use limited resources in proportion to the value of the assets of the product in each use case.

B.4 Mapping of risk factors to use cases

The mapping is considered to be representative, as no two use-cases mirror the same risk factors except the **UC-4-SDN** and **UC-5-HYBRID** which are inheriting the evaluation of **UC-3-TELCO** as later described in the present document. The use-case **UC-8-FLEET** inherits **UC-3-TELCO** risk-factors only partially.

Table B.4-1: Mapping of all use cases to risk factors

Use case / Risk factor	RF-ACC_ASSETS	RF-COMPLEX_CONF	RF-COMPLEX_FUN	RF-SENS_ASSETS	RF-SENS_FUN	RF-NUM	RF-ADMIN
UC-1-HOME	Medium	Low	Low	Low	Low	Low	High
UC-2-ENTER-S	High	Low	Low	Low	Low	Low	High
UC-2-ENTER-M	High	Medium	Medium	Medium	Medium	Medium	Medium
UC-2-ENTER-L	High	Medium	Medium	Medium	Medium	High	Low
UC-3-TELCO	High	High	High	High	High	High	Low
UC-4-SDN	High	High	High	High	High	High	Low
UC-5-HYBRID	High	High	High	High	High	High	Low
UC-6-IOT	High	Low	Low	Medium	Low	High	Medium
UC-7-ICT	High	Medium	Medium	Medium	Medium	Medium	Medium
UC-8-FLEET	Medium	Medium	Low	High	High	Medium	Low
UC-9-RESEARCH	Low	Low	Low	Low	Low	Low	Low
UC-10-AIRGAP	Low	Low	Low	High	High	High	Low
UC-11-WATER	Medium	Medium	Medium	High	Medium	Medium	Medium

B.4.1 UC-1-HOME security analysis

Household use of the product is generally low risk operation across the factors. An exception would be, if the household joins a larger network context where interconnectivity and complexity would be outside what can be reasonably expected from a family home. Then a **UC-1-HOME** would not apply anymore, and the risks need to be evaluated based on other use-cases.

Administrative risk is considered to be high, because the home user is not expected to understand network configuration in detail. Exception to this rule would be **UC-9-RESEARCH** which is a similar situation, but the product user has the knowledge on how to configure the network correctly.

B.4.2 UC-2-ENTER security analysis

Enterprise risks scale with the complexity of the network, the number of users, the variety of devices, interconnectivity of the sites and with the criticality of the operating entity.

EXAMPLE 1: A water production facility might have a low staff count, but the operation is defined to be critical in the local legislation, the entity needs a system, where all mitigations are implemented to the highest standard.

EXAMPLE 2: A business that is just starting, where the operations are small, and relevancy is not significant to the society, at least yet, does not necessarily benefit from support for external auditing systems, like the one that is required from a CSP.

EXAMPLE 3: A growing enterprise, where there are under thousand devices in the network, a few office sites, moderate interconnectivity does not require the same level of details from metrics than a CSP would.

Each of the following is true independently:

- High number of SRUs increases the attack surface.
- A highly interconnected network exposes more services.
- Complexity in the managed elements or in the enterprise services complicates the monitoring and incident response.
- Sensitivity of the elements increases with the enterprise function

Therefore **UC-2-ENTER** is split to three sub-categories, small, medium and large.

Table B.4.2-1: Compilation of all possible use-cases

Risk factor	Classification	Reasoning
RF-ACC_ASSETS	High	Remote work and connectivity to shared resources is assumed.
RF-COMPLEX_CONF	Low/Medium	Scales with the business; Capped to medium, as complex operations are not needed.
RF-COMPLEX_FUN	Low/Medium	Scales with the business; Capped to medium, as redundancy of office sites can be assumed.
RF-SENS_ASSETS	Low/Medium/ High	Reflects on the business function.
RF-SENS_FUN	Low/Medium	Scales with the business; Capped to medium.
RF-NUM	Low/Medium/ High	Reflects on the business size.
RF-ADMIN	Low/Medium/ High	Risk scales with the business, but in reverse.

The use-case **UC-2-ENTER-S** differs from **UC-1-HOME** with **RF-ACC_ASSETS** because it is expected, that even a small business wants to have remote connectivity to shared resource guarded by the product.

NOTE: The larger enterprise is in a better position to have dedicated staff or contractors to run the network.

B.4.3 UC-3-TELCO security analysis

Communication System Provider, or in slang terminology telco, has the highest number of SRUs, the most interconnectivity using both public and private IP pools, the most complex equipment to manage, and the most critical infrastructure to operate. Therefore **UC-3-TELCO** receives the highest risk assessment in all categories.

B.4.4 UC-4-SDN security analysis

Software Defined Network can be a small home laboratory installation, or it can be used in CSP services. The variability of target market and flexibility in the design results to a security assessment, that needs to be performed like **UC-2-ENTER**.

There is no one size fits all mitigation set available, and the evaluation is done based on the risk factors with high water mark defining all the required mitigations.

UC-4-SDN inherits the assessment from **UC-2-ENTER-S**, **UC-2-ENTER-M**, **UC-2-ENTER-L** and **UC-3-TELCO**. The SDN products are commonly used in **UC-3-TELCO** environments and it is highly unlikely that the same manufacturer would develop totally different products for each of the segments it serves, the highest classification is assumed. The product can differentiate the products with feature gating, like event audit interface availability, but the core product is expected to be the same.

B.4.5 UC-5-HYBRID security analysis

The **UC-5-HYBRID** is a variation of **UC-4-SDN** with actual physical devices included in the mix. How much RDPS is involved in the design does not set less requirements to the importance of protecting the product.

The reasoning in clause B.5.4 applies.

B.4.6 UC-6-IOT security analysis

IoT network is less risky, as the devices are often running a single application stack, which is often controlled also by the same product that governs the ecosystem. Hundreds of thousands of compromised toasters can be utilised to mine crypto, and heat up the room in addition to the bread. The risk factor of IoT use-case is solely determined by the **RF_NUM**.

Table B.4.6-1: Reasoning for the use-case classification to a risk-factor class

Risk factor	Classification	Reasoning
RF-ACC_ASSETS	High	The devices use provided network to connect to the backend.
RF-COMPLEX_CONF	Low	Even in a large system, the network design in not complex.
RF-COMPLEX_FUN	Low	High number of sites is assumed, but the minimal features are used.
RF-SENS_ASSETS	Medium	IoT devices can be a vital component for the intended purpose, but do not have the highest impact.
RF-SENS_FUN	Low	IoT devices are not important.
RF-NUM	High	An IoT network can have tens of thousands devices.
RF-ADMIN	Medium	Administrative qualification follows the **RF-COMPLEX_CONF** and **RF-COMPLEX_FUN**, but is expected to be Medium due to **RF-NUM** is High.

Logic in clause B.5.4 is used to reason with **RF-NUM** classification.

B.4.7 UC-7-ICT security analysis

Table B.4.7-1: Reasoning for the use-case classification to a risk-factor class

Risk factor	Classification	Reasoning
RF-ACC_ASSETS	High	The product expects connections through other provided networks. The devices call home.
RF-COMPLEX_CONF	Medium	Devices are isolated to control regions based on the allowed operations and device user needs.
RF-COMPLEX_FUN	Medium	Changes in the devices are tracked and analysed to perform the assurance of defined operation.
RF-SENS_ASSETS	Medium	Business interruptions will occur as a result from a compromise, but the other methods can be used in replacement.
RF-SENS_FUN	Medium	Provided functions are moderately sensitive.
RF-NUM	Medium	Number of managed elements is medium at best in comparison to the high end.
RF-ADMIN	Medium	Medium risk from administration is assumed.

While the printers in office can be controlled by the locally deployed service, the highest level was selected to **RF-ACC_ASSETS** to accommodate different designs.

The device management **UC-7-ICT** is already expected to be performed in a context, where there is a need to keep track of multiple different managed elements. Unlike the present document, which uses the term managed element to refer to virtual devices and functions at the same time, these devices are physical, in the office, or in the employees pocket. Therefore the low level can be ruled out from **RF-NUM**.

The complexity of the devices varies from printer to cell phone. Printer being the medium complexity device and cell phone the high complexity device. Therefore the is assessed to be medium or high.

B.4.8 UC-8-FLEET security analysis

Table B.4.8-1: Reasoning for the use-case classification to a risk-factor class

Risk factor	Classification	Reasoning
RF-ACC_ASSETS	Medium	Remote connectivity to the fleet and to the controller is assumed.
RF-COMPLEX_CONF	Medium	Highly sophisticated functions are not required.
RF-COMPLEX_FUN	Medium	Fleet control can extend to multiple sites.
RF-SENS_ASSETS	High	A compromised controller stops making changes, but the existing infrastructure remains operational.
RF-SENS_FUN	High	Provided functions are moderately sensitive.
RF-NUM	Medium	Number of managed elements is medium at best in comparison to the high end.
RF-ADMIN	Low	Users of the product are dedicated to running an efficient deployment.

The lowest risk factor level can be eliminated from **RF-COMPLEX_CONF**, **RF-COMPLEX_FUN** and **RF-NUM** with the reasoning presented in clause B.5.7.

UC-8-FLEET can be used in a critical environment, and therefore the **RF-SENS_ASSETS** and **RF-SENS_FUN** risk level is inherited following the reasoning in clause B.5.4.

B.4.9 UC-9-RESEARCH security analysis

Research network or laboratory network is built for a specified purpose. It does not necessarily require outside connectivity, and can be implemented with little configuration. The network can be a single IETF RFC 1918 [i.8] address space with a DHCP. The loss of the product assets can be mitigated building the network from scratch as the administrator is expected to be capable of handling the configuration even without the help of the product.

This use-case is comparable to **UC-1-HOME** with the expectation of product user is considered to be fully resourced professional.

B.4.10 UC-10-AIRGAP security analysis

Air gapped networks are built for a reason. The inconvenience of not having connectivity to download update packages from upstream has a well defined reason.

Because of the protected nature of the operation environment, the evaluation of **RF-ACC_ASSETS**, **RF-COMPLEX_CONF**, **RF-COMPLEX_FUN** is low and **RF-SENS_ASSETS**, **RF-SENS_FUN**, **RF-NUM** is high while the **RF-ADMIN** is assumed to low due to dedicated personal running the network.

B.4.11 UC-11-WATER security analysis

Use-case **UC-11-WATER** highlight the exception to this classification. A water production facility might have a low staff count, but high sensitivity of the operation.

B.5 Threats and security analysis of threats

B.5.1 Security analysis methodology

Risk factor levels for each use case are determined by reading the descriptions for each risk factor level and choosing the one that most accurately represents the highest risk for the intended purpose and reasonably foreseeable use of the product, as specified by the manufacturer.

For each threat, a formula based on the risk factor levels is used to calculate the Likelihood and Impact of the threat, on a scale of Very Low, Low, Medium, and High.

For each threat, both likelihood and impact need to be Very Low before the risk is considered sufficiently mitigated. If the calculated levels are not already Very Low, then mitigations need to be applied until they are both Very Low. The set of requirements that will accomplish this are listed in each threat description.

For some threats, the risk analysis assigns the same requirements to treat more than one level of risk. When this occurs, it is because the same mitigation treats more than levels of risk and there is no lesser mitigation that treats the lower risk(s) but not the higher risk(s). Risk formulas like this could be simplified, but keeping the distinction between levels of risk may simplify the addition of new mitigations for lower risk cases.

B.5.2 List of threats, risk assessments, and mitigations

B.5.2.0 Introduction

When different risk formulas result in different levels of the same mitigation set, a higher level is selected. All mitigations are designed to be cumulative, and highest level is required to implement also the lower level mitigations.

B.5.2.1 TH-UEVU: Unknown exploitable vulnerabilities

Attacker may use unknown exploitable vulnerabilities in the product to harm the product's assets.

Table B.5.2.1-1: Risk formula for likelihood of unknown exploitable vulnerabilities

Risk formula	Likelihood	Use cases
RF-ACC_ASSETS is Low RF-COMPLEX_FUN is Low	Very Low	UC-9-RESEARCH, UC-10-AIRGAP
RF-ACC_ASSETS is Medium and RF-COMPLEX_FUN is Low	Low	UC-1-HOME, UC-8-FLEET
RF-ACC_ASSETS is High and RF-COMPLEX_FUN is Low	Medium	UC-2-ENTER-S, UC-6-IOT, UC-11-WATER
RF-ACC_ASSETS is High and RF-COMPLEX_FUN is not Low	High	UC-2-ENTER-M, UC-2-ENTER-L, UC-3-TELCO, UC-4-SDN, UC-5-HYBRID, UC-7-ICT

Table B.5.2.1-2: Risk formula for impact of unknown exploitable vulnerabilities

Risk formula	Impact	Use cases
RF-SENS_ASSETS is Low	Very Low	UC-1-HOME, UC-2-ENTER-S, UC-9-RESEARCH
RF-SENS_ASSETS is Medium	Low	UC-2-ENTER-M, UC-2-ENTER-L, UC-6-IOT, UC-7-ICT
RF-SENS_ASSETS is High and RF-SENS_FUN is Medium	Medium	UC-8-FLEET, UC-11-WATER
RF-SENS_ASSETS is High and RF-SENS_FUN is High	High	UC-3-TELCO, UC-4-SDN, UC-5-HYBRID, UC-10-AIRGAP

Mitigations for **Likelihood**:

- Low to Very Low:
  - CYB_GENERAL low risk
  - CYB_OPS
  - MAS_TECH
- Medium to Very Low:
  - Everything in Low to Very Low

  - CYB_GENERAL medium risk
- High to Very Low:
  - Everything in Low to Very Low
  - Everything in Medium to Very Low
  - CYB_GENERAL high risk

Mitigations for **Impact**:

- Low to Very Low:
  - INT_CONF
  - INT_ROTATE
  - CON_CRYPTO
  - CON_CHANNEL
  - EMM_ROUTE for low risk
  - MON_LOG for low risk
  - MON_METRICS
- Medium to Very Low:
  - Everything in Low to Very Low
  - EMM_ROUTE for medium risk
  - MON_LOG for medium risk
- High to Very Low:
  - Everything in Low to Very Low
  - Everything in Medium to Very Low
  - EMM_ROUTE for high risk
  - MON_LOG for high risk

B.5.2.2 TH-KEVU: Known exploitable vulnerabilities

Attacker may use known exploitable vulnerabilities in the product implementation to get unauthorised access to product assets.

Table B.5.2.2-1: Risk formula for likelihood of known exploitable vulnerabilities

Risk formula	Likelihood	Use cases
RF-ACC_ASSETS is Low	Very Low	UC-9-RESEARCH, UC-10-AIRGAP
RF-ACC_ASSETS is Medium and RF-COMPLEX_FUN is Low	Low	UC-1-HOME, UC-8-FLEET
RF-ACC_ASSETS is High and RF-COMPLEX_FUN is Low	Medium	UC-2-ENTER-S, UC-6-IOT, UC-11-WATER
RF-ACC_ASSETS is High and RF-COMPLEX_FUN is not Low	High	UC-2-ENTER-M, UC-2-ENTER-L, UC-3-TELCO, UC-4-SDN, UC-5-HYBRID, UC-7-ICT

Table B.5.2.2-2: Risk formula for impact of known exploitable vulnerabilities

Risk formula	Likelihood	Use cases
RF-SENS_ASSETS is Low and RF-COMPLEX_FUN is Low	Very Low	UC-1-HOME, UC-2-ENTER-S, UC-9-RESEARCH
RF-SENS_ASSETS is Low and RF-COMPLEX_FUN is Medium	Low	None
all others	Medium	UC-2-ENTER-M, UC-2-ENTER-L, UC-6-IOT, UC-7-ICT, UC-11-WATER
RF-SENS_ASSETS is High	High	UC-3-TELCO, UC-4-SDN, UC-5-HYBRID, UC-8-FLEET, UC-10-AIRGAP

Mitigations for **Likelihood**:

- Low to Very Low:
  - KEV_EXPLOIT
  - SBD_TECH
  - SU_UPDATES
- Medium to Very Low:
  - Everything in Low to Very Low
- High to Very Low:
  - Everything in Low to Very Low
  - Everything in Medium to Very Low

Mitigations for **Impact**:

- Low to Very Low:
  - INT_CONF
  - INT_ROTATE
  - CON_CRYPTO
  - CON_CHANNEL
  - EMM_ROUTE for low risk
  - MON_LOG for low risk
  - MON_METRICS
- Medium to Very Low:
  - Everything in Low to Very Low
  - EMM_ROUTE for medium risk
  - MON_LOG for medium risk
- High to Very Low:
  - Everything in Low to Very Low
  - Everything in Medium to Very Low
  - EMM_ROUTE for high risk
  - MON_LOG for high risk

B.5.2.3 TH-CACC: Circumvention of access control

Attacker may get unauthorised access to product assets by exploiting gaps or weaknesses in authorization or access control.

Table B.5.2.3-1: Risk formula for likelihood of circumvention of access control

Risk formula	Likelihood	Use cases
RF-ACC_ASSETS is Low	Very Low	UC-9-RESEARCH, UC-10-AIRGAP
RF-ACC_ASSETS is Medium and RF-COMPLEX_FUN is Low	Low	UC-1-HOME, UC-8-FLEET
RF-ACC_ASSETS is High and RF-COMPLEX_FUN is Low	Medium	UC-2-ENTER-S, UC-6-IOT, UC-11-WATER
RF-ACC_ASSETS is High and RF-COMPLEX_FUN is not Low	High	UC-2-ENTER-M, UC-2-ENTER-L, UC-3-TELCO, UC-4-SDN, UC-5-HYBRID, UC-7-ICT

Table B.5.2.3-2: Risk formula for impact of circumvention of access control

Risk formula	Impact	Use cases
RF-SENS_ASSETS is Low and RF-COMPLEX_FUN is Low	Very Low	UC-1-HOME, UC-2-ENTER-S, UC-9-RESEARCH
RF-SENS_ASSETS is Low and RF-COMPLEX_FUN is Medium	Low	None
all others	Medium	UC-2-ENTER-M, UC-2-ENTER-L, UC-6-IOT, UC-7-ICT, UC-11-WATER
RF-SENS_ASSETS is High	High	UC-3-TELCO, UC-4-SDN, UC-5-HYBRID, UC-8-FLEET, UC-10-AIRGAP

Mitigations for Likelihood:

- Low to Very Low:
  - AAC_AUTH
  - AAC_MACHINE
  - CON_INGEST
  - CON_CRYPTO
  - CON_CHANNEL
- Medium to Very Low:
  - Everything in Low to Very Low
- High to Very Low:
  - Everything in Low to Very Low
  - Everything in Medium to Very Low

Mitigations for Impact:

- Low to Very Low:
  - CON_CRYPTO
  - CON_CHANNEL
  - MON_LOG for low risk
  - MON_METRICS

- Medium to Very Low:
  - Everything in Low to Very Low
  - MON_LOG for medium risk
- High to Very Low:
  - Everything in Low to Very Low
  - Everything in Medium to Very Low
  - MON_LOG for high risk

B.5.2.4 TH-DSTP: Unauthorised access to data stored

Attacker may get unauthorised access to confidential data stored on the product through acquisition of a used platform containing the product.

Table B.5.2.4-1: Risk formula for likelihood of unauthorised access to data stored

Risk formula	Likelihood	Use cases
RF-ADMIN is Low and RF-NUM is Low	Very Low	UC-9-RESEARCH
RF-NUM is Low and RF-ADMIN is not High	Low	None
all others	Medium	UC-2-ENTER-M, UC-2-ENTER-L, UC-8-FLEET, UC-7-ICT, UC-11-WATER
RF-ADMIN is High or RF-NUM is High	High	UC-1-HOME, UC-2-ENTER-S, UC-3-TELCO, UC-4-SDN, UC-5-HYBRID, UC-6-IOT, UC-10-AIRGAP

Table B.5.2.4-2: Risk formula for impact of unauthorised access to data stored

Risk formula	Impact	Use cases
RF-SENS_ASSETS is Low	Very Low	UC-1-HOME, UC-2-ENTER-S, UC-9-RESEARCH
RF-SENS_ASSETS is Medium	Low	UC-2-ENTER-M, UC-7-ICT
RF-SENS_ASSETS is Medium and RF-NUM is High	Medium	UC-2-ENTER-L, UC-6-IOT
RF-SENS_ASSETS is High	High	UC-3-TELCO, UC-4-SDN UC-5-HYBRID, UC-8-FLEET, UC-10-AIRGAP, UC-11-WATER

Mitigations for **Likelihood**:

- Low to Very Low:
  - AAC_AUTH
  - AAC_MACHINE
  - DRT_DELETE
  - MAS_TECH
  - EMM_ROUTE for low risk
  - DM_RETENTION
- Medium to Very Low:
  - Everything in Low to Very Low
  - EM_ROUTE for medium risk

- High to Very Low:
  - Everything in Low to Very Low
  - Everything in Medium to Very Low
  - EM_ROUTE for high risk

Mitigations for **Impact**:

- Low to Very Low:
  - CON_CRYPTO
  - CON_CHANNEL
  - MON_LOG for low risk
  - MON_METRICS
- Medium to Very Low:
  - Everything in Low to Very Low
  - MON_LOG for medium risk
- High to Very Low:
  - Everything in Low to Very Low
  - Everything in Medium to Very Low
  - MON_LOG for high risk

B.5.2.5 TH-UADT: Unauthorised access to data transmitted

Attacker may use access to the connected network to compromise the confidentiality or integrity of data transmitted by the product.

Table B.5.2.5-1: Risk formula for likelihood of unauthorised access to data transmitted

Risk formula	Likelihood	Use cases
RF-ACC_ASSETS is Low and RF-ADMIN is Low	Very Low	UC-9-RESEARCH, UC-10-AIRGAP
RF-ACC_ASSETS is Medium	Low	UC-1-HOME, UC-8-FLEET, UC-11-WATER
RF-ACC_ASSETS is High and RF-COMPLEX_CONF is Medium	Medium	UC-2-ENTER-S, UC-2-ENTER-M, UC-2-ENTER-L, UC-6-IOT, UC-7-ICT
RF-ACC_ASSETS is High and RF-COMPLEX_CONF is High	High	UC-3-TELCO, UC-4-SDN, UC-5-HYBRID

Table B.5.2.5-2: Risk formula for impact of unauthorised access to data transmitted

Risk formula	Impact	Use cases
RF-SENS_ASSETS is Low	Very Low	UC-1-HOME, UC-2-ENTER-S, UC-9-RESEARCH
RF-SENS_ASSETS is Medium	Low	UC-2-ENTER-M, UC-2-ENTER-L, UC-6-IOT, UC-7-ICT
RF-SENS_ASSETS is High and RF-SENS_FUN is Medium	Medium	UC-8-FLEET, UC-11-WATER
RF-SENS_ASSETS is High and RF-SENS_FUN is High	High	UC-3-TELCO, UC-4-SDN, UC-5-HYBRID, UC-10-AIRGAP

Mitigations for **Likelihood**:

- Low to Very Low:
  - CON_CRYPTO
  - CON_CHANNEL
  - DM_RETENTION
  - INT_CONF
  - INT_ROTATE
- Medium to Very Low:
  - Everything in Low to Very Low
- High to Very Low:
  - Everything in Low to Very Low
  - Everything in Medium to Very Low

Mitigations for **Impact**:

- Low to Very Low:
  - DM_RETENTION
  - MON_LOG for low risk
  - MON_METRICS
- Medium to Very Low:
  - Everything in Low to Very Low
  - MON_LOG for medium risk
- High to Very Low:
  - Everything in Low to Very Low
  - Everything in Medium to Very Low
  - MON_LOG for high risk

B.5.2.6 TH-CONF: Access to assets via configuration errors

Attacker may use unintentional configuration errors to get unauthorised access to the product assets.

Table B.5.2.6-1: Risk formula for likelihood of access to assets via configuration errors

Risk formula	Likelihood	Use cases
RF-ACC_ASSETS is Low	Very Low	UC-9-RESEARCH, UC-10-AIRGAP
RF-ACC_ASSETS is Medium and RF-ADMIN is Low	Low	UC-8-FLEET
RF-ACC_ASSETS is High	Medium	UC-1-HOME, UC-11-WATER, UC-2-ENTER-S, UC-2-ENTER-M, UC-6-IOT, UC-7-ICT
RF-ACC_ASSETS is High and RF-COMPLEX_FUN is not Low and RF-NUM is High	High	UC-2-ENTER-L, UC-3-TELCO, UC-4-SDN, UC-5-HYBRID

Table B.5.2.6-2: Risk formula for impact of access to assets via configuration errors

Risk formula	Impact	Use cases
RF-SENS_ASSETS is Low	Very Low	UC-1-HOME, UC-2-ENTER-S, UC-9-RESEARCH
RF-SENS_ASSETS is Medium and RF-NUM is not High	Low	UC-2-ENTER-M, UC-7-ICT
RF-SENS_ASSETS is Medium and RF-NUM is High	Medium	UC-2-ENTER-L, UC-6-IOT
RF-SENS_ASSETS is High	High	UC-3-TELCO, UC-4-SDN, UC-5-HYBRID, UC-8-FLEET, UC-10-AIRGAP, UC-11-WATER

Mitigations for **Likelihood**:

- Low to Very Low:
  - SBD_TECH
- Medium to Very Low:
  - Everything in Low to Very Low
- High to Very Low:
  - Everything in Low to Very Low
  - Everything in Medium to Very Low

Mitigations for **Impact**:

- Low to Very Low:
  - MON_LOG for low risk
  - MON_METRICS
- Medium to Very Low:
  - Everything in Low to Very Low
  - MON_LOG for medium risk
- High to Very Low:
  - Everything in Low to Very Low
  - Everything in Medium to Very Low
  - MON_LOG for high risk

This threat includes harm to other systems the product is serving.

B.5.2.7 TH-AVAI: Denial of service attack on product

Attacker may use network access to product to reduce availability of product functions.

Table B.5.2.7-1: Risk formula for likelihood of denial of service attack on product

Risk formula	Likelihood	Use cases
RF-ACC_ASSETS is Low	Very Low	UC-9-RESEARCH, UC-10-AIRGAP
RF-ACC_ASSETS is Medium	Low	UC-1-HOME, UC-8-FLEET, UC-11-WATER
RF-ACC_ASSETS is High and RF-COMPLEX_CONF is not High	Medium	UC-2-ENTER-S, UC-2-ENTER-M, UC-2-ENTER-L, UC-6-IOT, UC-7-ICT
RF-ACC_ASSETS is High	High	UC-3-TELCO, UC-4-SDN, UC-5-HYBRID

Table B.5.2.7-2: Risk formula for impact of denial of service attack on product

Risk formula	Impact	Use cases
RF-SENS_ASSETS is Low	Very Low	UC-1-HOME, UC-2-ENTER-S, UC-9-RESEARCH
RF-SENS_ASSETS is Medium and RF-NUM is not High	Low	UC-2-ENTER-M, UC-7-ICT
RF-SENS_ASSETS is Medium and RF-NUM is High	Medium	UC-2-ENTER-L, UC-6-IOT
RF-SENS_ASSETS is High	High	UC-3-TELCO, UC-4-SDN, UC-5-HYBRID, UC-8-FLEET, UC-10-AIRGAP, UC-11-WATER

Mitigations for **Likelihood**:

- Low to Very Low:
  - AP_HA for low risk
  - IM_SEGMENT for low risk
- Medium to Very Low:
  - Everything in Low to Very Low
  - AP_HA for medium risk
  - IM_SEGMENT for medium risk
- High to Very Low:
  - Everything in Low to Very Low
  - Everything in Medium to Very Low
  - AP_HA for high risk
  - IM_SEGMENT for high risk

Mitigations for **Impact**:

- Low to Very Low:
  - MON_LOG for low risk
  - MON_METRICS
  - AP_HA for low risk
- Medium to Very Low:
  - Everything in Low to Very Low
  - MON_LOG for medium risk
  - AP_HA for medium risk
- High to Very Low:
  - Everything in Low to Very Low
  - Everything in Medium to Very Low
  - MON_LOG for high risk
  - AP_HA for high risk

B.5.2.8 TH-DDoS: Interference with other devices

Attacker may use product functions to interfere with other devices or services.

Table B.5.2.8-1: Risk formula for likelihood of interference with other devices

Risk formula	Likelihood	Use cases
RF-ACC_ASSETS is Low	Very Low	UC-9-RESEARCH, UC-10-AIRGAP
RF-ACC_ASSETS is Medium	Low	UC-1-HOME, UC-8-FLEET, UC-11-WATER
RF-ACC_ASSETS is High and RF-COMPLEX_CONF is Low	Medium	UC-2-ENTER-S, UC-6-IOT
RF-ACC_ASSETS is High	High	UC-2-ENTER-M, UC-2-ENTER-L, UC-3-TELCO, UC-4-SDN, UC-5-HYBRID, UC-7-ICT

Table B.5.2.8-2: Risk formula for impact of interference with other devices

Risk formula	Impact	Use cases
RF-ACC_ASSETS is Low	Very Low	UC-9-RESEARCH, UC-10-AIRGAP
RF-ACC_ASSETS is Medium	Low	UC-1-HOME, UC-8-FLEET, UC-11-WATER
RF-ACC_ASSETS is High and RF-COMPLEX_FUN is Low	Medium	UC-2-ENTER-S, UC-6-IOT
RF-ACC_ASSETS is High and RF_COMPLEX_FUN is not Low	High	UC-2-ENTER-M, UC-2-ENTER-L, UC-3-TELCO, UC-4-SDN, UC-5-HYBRID, UC-7-ICT

Mitigations for **Likelihood**:

- Low to Very Low:
  - AP_HA for low risk
  - IM_SEGMENT for low risk
- Medium to Very Low:
  - Everything in Low to Very Low
  - AP_HA for medium risk
  - IM_SEGMENT for medium risk
- High to Very Low:
  - Everything in Low to Very Low
  - Everything in Medium to Very Low
  - AP_HA for high risk
  - IM_SEGMENT for high risk

Mitigations for **Impact**:

- Low to Very Low:
  - MON_LOG for low risk
  - MON_METRICS
- Medium to Very Low:
  - Everything in Low to Very Low
  - MON_LOG for medium risk

- High to Very Low:
  - Everything in Low to Very Low
  - Everything in Medium to Very Low
  - MON_LOG for high risk

Annex C (informative): Relationship between the present document and any related ETSI standards

ETSI Standards referenced by the present document:

- ETSI EN 304 624: "Cyber Security (CYBER); CRA; Cybersecurity requirements for Public key infrastructure and digital certificate issuance software" [i.11]
- ETSI EN 304 620: " Cyber Security (CYBER); CRA; Cybersecurity requirements for Virtual Private Networks (VPNs)" [i.12]
- ETSI EN 304 622: "Cyber Security (CYBER); CRA; Cybersecurity requirements for Security information and event management (SIEM) systems" [i.14]
- ETSI EN 304 626: "Cyber Security (CYBER); CRA; Cybersecurity requirements for operating systems" [i.15]
- ETSI EN 304 627: "Cyber Security (CYBER); CRA; Cybersecurity requirements for routers, modems intended for the connection to the internet, and switches" [i.16]
- ETSI EN 304 642: " Cyber Security (CYBER); CRA; Cybersecurity Requirements for Network Functions of Telecommunications Systems" [i.17]

Annexes D to F:
Void

Annex G (informative): Guidelines on the implementation of the present document

G.0 Guidance on use-cases

It is not necessary to find a use case whose risks are identical to those identified by the product's cybersecurity risk assessment. If a use case has equal or higher risks to the product's, then it can be used. For example, a use case that includes the product being connected to a public network (a high level of this risk factor) can also be used for a product whose intended purpose is to be connected to a private network with a filtered connection to a public network.

New use cases may be added to the present document along with any new risks factors or requirements necessary to fully treat the risks, along with any necessary updates to the security analysis.

G.1 Guidance on no known exploitable vulnerabilities requirements

If the deliverable contains or requires an operating system the operating system is expected to be regularly updated and maintained. Depending on the chosen delivery method, the maintenance of the operating system can be provided by the customer of the product.

There may be vulnerabilities discovered between the time that a product is placed on the market and the time of that product's first use. A product should be free from known exploitable vulnerabilities at both points in time, when it is first made available on the market and when the user starts the product the first time. The post-release period of the product lifecycle is addressed in clause 5.5.

G.2 Guidance on secure by default configuration requirements

SU_UPDATE-3 is not conditional, because even in clustering environment, where product does not control its own deployed version, the documentation of installation might point to old sources.

Updates in high availability environment

System updates are essential to keep the number of known vulnerabilities at a minimum. A wide variety of threats related to secure updates may appear both prior to an update and during the update process.

Pre-update acquisition & distribution secure update threats:

- Tampered update packages during storage or transmission
- Update retrieved from an untrusted or unauthenticated source
- Use of revoked or compromised signing keys

Threats to secure update during installation & execution:

- Authenticity or integrity verification bypass
- Downgrade to an older version
- Rollback protections bypass
- Loss of availability if update fails or is interrupted

Therefore, application of updates needs to be performed in a manner that maintains the integrity of the software state and, where relevant, supports the availability objectives defined for the product keeping the system within the set High Availability targets.

SU_UPDATES-7 to SU_UPDATES-13

The requirements **SU_UPDATES-7** to **13** are conditional due to different operative management and ownership models.

A cell phone that is connected to a corporate inventory management often has its own update manager, and the device does not rely on the centralised control. Similarly in a modern cluster deployment, the application can not update itself, as the control is in the cluster, which makes the provisioning, scheduling and network shaping decisions for all applications running in the same context.

G.3 Guidance on authentication and access control requirements

The product assigns to each subject a role or attributes based on the subject's identity, to enable for the application of access control structures. Access rights are thereby minimised to allow only for those operations that are needed for the intended use or task. The assignment of access rights is the justification of the **AAC_AUTH-1** requirement, the matching of the control structure implementation with the intended use is covered with the requirement **AAC_AUTH-5**.

The requirement **AAC_AUTH-5:** is intentionally vague. The model can be complex, and there can be multiple different overlapping mechanisms in place that can be used to enable the same function.

While the requirement calls for active checking, in combination with **AAC_AUTH-4:** the wording leaves room to implement a fluent GUI experience when viewing the content and performing privileged actions are separated.

Credential rotation addressed by **INT_ROTATE-1** is one of the key elements that enable organisations to build resilience in a compromised network. The rotation can replace keys or tokens to limit exposure from compromised credentials. It can be built on top of existing authority structures, or it can re-run some parts of the element initialisation procedures. How the retake of the authority is implemented is between the product and the element.

G.4 Guidance on confidentiality protection requirements

Secure channel

When privileged information is transferred or accessed, the transport channel provides confidentiality, integrity protection, endpoint authentication, and protection against downgrading to less secure configurations. TLS may be used for this purpose, but other mechanisms may also be used where they provide an equivalent level of protection and are implemented as defined in annex K.

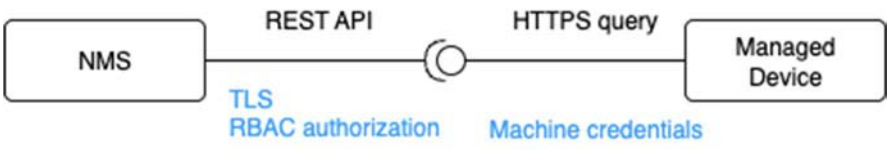


Figure G.4-1: Secure channel example with TLS

Figure G.4-1 is an illustration of a simple TLS protected communication between product and the managed element, where the element initiates the connection towards a reachable endpoint based on a DNS address configured into the managed element. The element validates the provided public certificate and logs in with machine credentials. The product authorises the query based on the role and identity of the element.

Conformity with this clause does not require use of DNS, TLS, certificate-based authentication, where equivalent security outcomes are achieved by other means appropriate to the product design and foreseeable use.

Other approaches are possible, including where the product is responsible for initiating the TLS connection towards the managed element and logging into the managed element. In this case, the managed element is responsible for authorizing the product based on the identity of the product.

G.5 Guidance on integrity protection requirements

For **INT_CONF-2**: where configuration is distributed through a staged system like file, URI, or intermediate store, a cryptographic signature, digest, or other integrity mechanisms is a good way to protect the integrity of that distribution method.

Trust is inherited from a parenting system or from an existing entity. Rollout automation and zero touch configuration approaches rely on concepts, which are not necessarily well established, and vendor specific. When nothing prior trust source exists, there is always an initialisation and manual acceptance that involves human intervention. This intervention enables the administrator to transfer the seed of trust.

G.6 Guidance on availability protection requirements

High availability starts from the running process. In a modern cluster runtime environment used in large system deployments, the process rarely can control the loss of underlying resources. Administrative actions can unexpectedly shut down the node without a preceding announcement. It is up to the software design whether such interruptions can be tolerated. Modern design is often distributed, but depending on the implementation and runtime context, a singular process can also provide the targeted service availability, if the process was implemented correctly, and a self-healing system can launch a replacement within a given time window.

Following general risks apply if the product can be reached by a DDoS attack: For the product in large deployment scenarios, e.g. telecom or enterprise use cases, a DDoS is not practical due to the physical separation of payload network and management network. An attacker would need to physically access a high number of the managed elements, manipulate them, build a bridge to the management network, and be able to orchestrate DDoS on the product. As this is considered not practical in real scenarios, such the product itself will not be affected by DDoS. Of course, such the product are able to detect DDoS scenarios on its managed elements. The product in these large scenarios are usually also part of the DDoS defence means: The product gets input from defence systems and executes then mitigating configurations on the managed elements affected by the DDoS attack. In these scenarios and for the CRA conformity, the product manufacturer can argue: a DDoS is not applicable.

For other scenarios, where the product itself can be affected by DDoS, the product may cease services for a configurable timeframe, apply predefined mitigation means, such as a reset, and return then to normal operation. Most DDoS scenarios last less than 10 minutes. However, such an event needs to be notified, reported and logged. Of course, for forensic analysis of this event, i.e. to identify the source of DDoS orchestration, sources of the flooding etc., a logging of all available data about this event is required.

Generally, DDoS attacks vary greatly in duration, but following some online statistics, 60-80 % last less than one hour, the most thereof less than 10 minutes. Nevertheless, single publicly known campaigns can last 12 hours, the longest known 2025/12 lasted more than 7 days, but those are usually rare. These are example data for which public statistics are available [i.18].

G.7 Guidance on non-interference requirements

The best practice is to use a dedicated network segment for network management and control traffic. Management traffic can be configuration updates, encryption keys, software updates, and others alike.

It is not uncommon that the product is used to manage the network the product is deployed into.

With segmentation, protection of management traffic is dependent on:

- design assumptions that translates to capabilities of the product
- deployment assumptions and instructions
- the operational environment capabilities

This is often implemented with:

- supporting more than one interface for the serving workload
- responding only to request that are coming from configured dedicated subnets

- protecting the subnet from rogue actors
- deployment guidance
- product architecture

Many of the items above are operational environment requirements, and often product user's responsibility to implement these means correctly. Using segmentation eases the detection of undesired traffic in the management network. And, segmentation limits the attack surface from other connected networks, but it does not remove integrity, confidentiality and authentication requirements.

Management traffic in this context refers to command and control instructions that change the product or the managed network element operation.

G.8 Guidance on exploit mitigation requirements

The managed element can be anything from a toaster to a base station. The present document assumes that those elements will get compromised.

G.9 Guidance on exploit mitigation requirements

For **MAS_TECH-1** in a home setting, the fancy wording can be implemented with a firewall. For a telco environment, this means a slightly more complex an more performance oriented methods.

G.10 Guidance on monitoring requirements

In many product deployments, privileged users manage monitoring tasks also with the analysis of product logging records. Especially when there are forensic demands, comprehensive and detailed logging becomes a larger challenge.

The logging requirements define baseline event recording and additional protections for retention, integrity, backup, and external forwarding.

The metrics requirements support security monitoring, operational visibility, fault detection, and verification of system behaviour. Fulfilment of these requirements is essential for all products in all use cases and all risk levels. Breaches can not be detected, if an attacker can hide its existence.

A number of metrics depend on the operational environment or used protocols.

The product can be a host to an ecosystem that exposes managed elements capacity for 3rd. party applications. The product can operate as a runtime for the workload, and effectively inherits operating systems like responsibilities and functionalities.

The **MON_METRICS-4** is defined expecting that the product hosts these services. When RDPS is used for these functions, the relevant metrics are different and "like queries per second" equivalent can be used.

What metrics and logs can be collected is defined in more detail in clause 5.9.

Annexes H to J:
Void

Annex K (normative): Generic cryptographic requirements and assessment

K.1 Cryptography

K.1.1 Requirement

The product's default configuration shall only use cryptographic mechanisms that meet at least one of the following criteria:

1) ACM-listed: the cryptographic mechanism is listed in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [i.8].

2) ACM-extended: the cryptographic mechanism is not listed in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [i.8] and meets at least one of the following conditions:

   a) the cryptographic mechanism is listed in clause K.3.2 as an ACM-extended cryptographic mechanism for the specific product function(s);

   b) where the cryptographic mechanism is not listed in clause K.3.2, the cryptographic mechanism meets all the following criteria:

      i) the cryptographic mechanism, or where applicable the ACM-listed cryptographic mechanism on which it is based, is not deprecated per the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [i.8];

      ii) the cryptographic mechanism has been specified, developed or maintained through a transparent process by a recognised European, international or sector-specific standards development organisation, or by an industry specification organisation accountable for the relevant specification, including CEN, CENELEC, ETSI, ISO, IEC, ISO/IEC JTC 1, IETF, IEEE, ITU-T, NIST, 3GPP, O-RAN Alliance, BSI, ACN, C2SP; or the cryptographic mechanism is listed as suitable in a publicly available cryptographic catalogue maintained by a recognised national or governmental cybersecurity authority, where the catalogue is maintained under a documented revision and retirement process, including BSI TR-02102-1 [i.21], BSI TR-02102-2 [i.22], BSI TR-02102-3 [i.23] and BSI TR-02102-4 [i.24];

      iii) the cryptographic mechanism is described in a valid, publicly available and uniquely referenceable specification;

      iv) the cryptographic properties of the cryptographic mechanism are known;

      v) no known weakness affects the cryptographic mechanism in a way that affects its cryptographic properties;

      vi) the cryptographic mechanism is required for a specific set of product functions.

3) Interoperability-based: the cryptographic mechanism is listed in clause K.4.2 as an interoperability-based cryptographic mechanism for specific product function(s) and external specification(s) or external requirement(s).

NOTE 1: The reference to the product's default configuration is intended to define a clear and assessable baseline, corresponding to the configuration in which the product is placed on the market. The product can provide several configurations that fulfil the requirement.

NOTE 2: For products supplied as hardware platforms or components to be configured by an integrator, references in this annex to the product's default configuration refer to the configuration specified for the intended operational use of the product after integration, including the relevant integration assumptions and configuration constraints.

NOTE 3: The applicable ACM catalogue version is identified in the normative references of the present document. The lifecycle treatment of mechanisms affected by ACM deprecation dates, expiry dates, migration conditions or usage limitations is addressed in clause K.2.

NOTE 4: In this clause, an external specification or external requirement means a specification or requirement that is imposed on the product, and which requires the use of a specific cryptographic mechanism for the product to interoperate with an identified system, platform or operational context. An external requirement can be a regulatory requirement, operational constraint, technical interoperability constraint, or platform compatibility requirement.

NOTE 5: Inclusion of a cryptographic mechanism under the interoperability-based criterion does not classify that mechanism as state-of-the-art cryptography.

EXAMPLE: Examples of product functions include secure communication based on TLS 1.3; authenticated encryption of communicated data based on AES-GCM; storage confidentiality based on AES-XTS; firmware signature verification based on Ed25519; and key derivation based on HKDF.

K.1.2 Assessment of product cryptographic configuration

K.1.2.0 General

The assessment in clause K.1.2 verifies the cryptographic mechanisms used in the product's default configuration against clause K.1.1.

For ACM-extended cryptographic mechanisms, the assessment verifies that the cryptographic mechanism is either listed in clause K.3.2 or fulfils the criteria specified in clause K.1.1 item 2.b. For interoperability-based cryptographic mechanisms, the assessment verifies that the cryptographic mechanism is listed in clause K.4.2. The assessment also verifies that the product uses the cryptographic mechanism in accordance with the relevant characteristics, product functions, use cases where applicable, external specifications or external requirements, and conditions specified in the present document.

K.1.2.1 Assessment of ACM-listed cryptographic mechanisms

K.1.2.1.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with clause K.1.1 item 1) and used in the product's default configuration are listed in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [1].

K.1.2.1.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under clause K.1.1 item 1), including the related product function, relevant parameters where applicable, and the relevant ACM entry.

K.1.2.1.3 Assessment activities

The assessment shall include verification that:

a) each cryptographic mechanism claimed under clause K.1.1 item 1) is identified by reference to a relevant ACM entry;

b) the ACM entry corresponds to the cryptographic mechanism used in the product's default configuration, including relevant parameters where applicable;

c) where the ACM entry includes lifecycle information, such as expiry date, deprecation date, migration condition or usage limitation, this information is reflected in the documentation.

K.1.2.1.4 Assessment evidence

The assessment evidence shall include, as applicable:

a) description of the product's default configuration;

b) list of cryptographic mechanisms claimed under clause K.1.1 item 1);

c) references to the relevant ACM entries;

d) relevant parameters, profiles, cipher suites or configuration constraints, where applicable;

e) relevant lifecycle information from the ACM catalogue, where applicable.

K.1.2.1.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.1.1 item 1).
- The verdict FAIL shall be assigned otherwise.

K.1.2.2 Assessment of ACM-extended cryptographic mechanisms

K.1.2.2.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with clause K.1.1 item 2) and used in the product's default configuration are either listed as ACM-extended cryptographic mechanisms in clause K.3.2 or fulfil the criteria specified in clause K.1.1 item 2.b, and are used for the claimed product function(s).

K.1.2.2.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under clause K.1.1 item 2), including the related product function, use case where applicable, relevant parameters where applicable, and at least one of the following:
    a) the relevant entry in clause K.3.2; or
    b) evidence that the cryptographic mechanism fulfils all applicable criteria in clause K.1.1 item 2)b).

K.1.2.2.3 Assessment activities

The assessment shall include verification that:

a) each cryptographic mechanism claimed under clause K.1.1 item 2) is either listed in clause K.3.2 as an ACM-extended cryptographic mechanism or supported by evidence demonstrating fulfilment of the applicable criteria in clause K.1.1 item 2)b);

b) the cryptographic mechanism used by the product corresponds to the mechanism listed in clause K.3.2 or described in the evidence provided under clause K.1.1 item 2)b);

c) the product function using the cryptographic mechanism, and the use case where applicable, correspond to the related product function and use case specified in clause K.3.2 or justified under clause K.1.1 item 2)b);

d) the relevant characteristics, parameters, profiles, cipher suites or configuration constraints of the cryptographic mechanism correspond to those specified in clause K.3.2 or justified under clause K.1.1 item 2)b), where applicable;

e) where clause K.3.2 or the justification under clause K.1.1 item 2)b) defines conditions or limitations for the use of the cryptographic mechanism, these conditions or limitations are reflected in the product's default configuration;

f) where technically feasible, the cryptographic mechanism, parameters and configuration identified in the documentation correspond to the assessed product configuration.

K.1.2.2.4 Assessment evidence

The assessment evidence shall include, as applicable:

a) description of the product's default configuration;

b) list of cryptographic mechanisms claimed under clause K.1.1 item 2);

c) reference to the relevant entry in clause K.3.2, where the mechanism is listed in clause K.3.2;

d) evidence that the cryptographic mechanism fulfils the criteria in clause K.1.1 item 2)b), where compliance with clause K.1.1 item 2 is claimed on the basis of those criteria;

e) identification of the related product function using the cryptographic mechanism and the use case where applicable;

f) relevant characteristics, parameters, profiles, cipher suites or configuration constraints, where applicable;

g) evidence that the cryptographic mechanism is used in accordance with the conditions or limitations specified in clause K.3.2 or in the justification under clause K.1.1 item 2)b), where applicable.

K.1.2.2.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.1.1 item 2).
- The verdict FAIL shall be assigned otherwise.

K.1.2.3 Assessment of interoperability-based cryptographic mechanisms

K.1.2.3.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with clause K.1.1 item 3) and used in the product's default configuration are listed as interoperability-based cryptographic mechanisms in clause K.4.2 and are used in accordance with the characteristics, product functions, use cases where applicable, external specifications or external requirements, and conditions specified in clause K.4.2.

K.1.2.3.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under clause K.1.1 item 3), including the related product function, use case where applicable, relevant parameters where applicable, the external specification or external requirement requiring its use, and the relevant entry in clause K.4.2.

K.1.2.3.3 Assessment activities

The assessment shall include verification that:

a) each cryptographic mechanism claimed under clause K.1.1 item 3) is listed in clause K.4.2 as an interoperability-based cryptographic mechanism;

b) the cryptographic mechanism used by the product corresponds to the cryptographic mechanism listed in clause K.4.2;

c) the product function using the cryptographic mechanism, and the use case where applicable, correspond to the related product function and use case specified in clause K.4.2;

d) the external specification or external requirement requiring the use of the cryptographic mechanism corresponds to the external specification or external requirement specified in clause K.4.2;

e) the relevant characteristics, parameters, profiles, cipher suites or configuration constraints of the cryptographic mechanism correspond to those specified in clause K.4.2, where applicable;

f) the conditions or limitations specified in clause K.4.2 for the use of the cryptographic mechanism are reflected in the product's default configuration;

g) where technically feasible, the cryptographic mechanism, parameters and configuration identified in the documentation correspond to the assessed product configuration.

K.1.2.3.4 Assessment evidence

The assessment evidence shall include, as applicable:

a) description of the product's default configuration;

b) list of cryptographic mechanisms claimed under clause K.1.1 item 3);

c) reference to the relevant entry in clause K.4.2;

d) identification of the related product function using the cryptographic mechanism and the use case where applicable;

e) identification of the external specification or external requirement requiring use of the cryptographic mechanism;

f) relevant characteristics, parameters, profiles, cipher suites or configuration constraints, where applicable;

g) evidence that the cryptographic mechanism is used in accordance with the conditions or limitations specified in clause K.4.2.

K.1.2.3.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.1.1 item 3).
- The verdict FAIL shall be assigned otherwise.

NOTE 1: The assessment of the external specification or external requirement itself is outside the scope of this assessment case. The assessment verifies that the external specification or external requirement is identified in clause K.4.2 and that the cryptographic mechanism is used by the product for the related product function.

NOTE 2: Documentation review is a minimum assessment activity under the present annex. Functional and/or resistance testing activities can be added by vertical standards where relevant for the product category, product function or cryptographic mechanism.

K.2 Crypto agility

K.2.1 Requirement

Where the product's default configuration uses a cryptographic mechanism for which the ACM catalogue, or the present document, specifies a deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product, the product shall provide means for addressing the affected cryptographic mechanism by one or more of the following:

a) updating the cryptographic mechanism;

b) using another cryptographic mechanism that complies with clause K.1.1 and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation;

c) disabling the use of the affected cryptographic mechanism; or

d) limiting the use of the affected product functions accordingly.

EXAMPLE: Where a security mechanism uses a hybrid cryptographic construction, for example a hybrid key-encapsulation mechanism combining a classical and a post-quantum primitive, the lifecycle status of each constituent primitive is relevant to the lifecycle status of the construction. Hybridization can be used as part of a planned migration strategy where permitted by the ACM catalogue or by the present document. However, hybridization does not, by itself, extend the recommended usage lifetime of a constituent primitive that has been deprecated.

NOTE 1: Where a hybrid cryptographic construction includes multiple cryptographic primitives, the lifecycle status of each constituent primitive is relevant to the lifecycle status of the construction. Hybridization is not assumed to mitigate the deprecation of a constituent primitive unless the ACM catalogue or the present document classifies the hybrid construction as suitable for the corresponding product function.

NOTE 2: Crypto agility supports maintaining appropriate cryptographic protection within the intended lifetime of the product, in addition to the capability of updating cryptographic mechanisms on the product in accordance with secure update and secure communication mechanisms.

NOTE 3: Deprecation information from sources other than the ACM catalogue or the present document can be considered as input to vulnerability management or security risk assessment but does not by itself trigger the requirement in clause K.2.1.

NOTE 4: Where the product provides cryptographic capabilities for use by other products, components or layers, the mechanism required by clause K.2.1 can consist of update, configuration, disabling, deprecation or limitation capabilities usable by the integrating product, system operator or user, where applicable.

NOTE 5: The applicability condition of this requirement can express exceptions based on product characteristics, e.g. cryptographic implementation based on immutable hardware co-processor(s) or hardware-based root of trust, or long-lived silicon used in a long-lived non-updateable environment.

K.2.2 Assessment of crypto-agility

K.2.2.1 Assessment objective

The purpose of this assessment case is to verify whether, where the product's default configuration uses a cryptographic mechanism for which the ACM catalogue, or the present document, specifies a deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product, the product provides means to address the affected cryptographic mechanism in accordance with clause K.2.1.

K.2.2.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall identify:

    a) the intended lifetime of the product;

    b) the cryptographic mechanisms used in the product's default configuration;

    c) the related product function(s) for each cryptographic mechanism;

    d) the lifecycle information applicable to each cryptographic mechanism, where specified by the ACM catalogue or the present document, including any deprecation date, expiry date, migration condition or usage limitation.

K.2.2.3 Assessment activities

The assessment shall include verification that:

a) for each cryptographic mechanism used in the product's default configuration, the lifecycle information specified by the ACM catalogue or the present document has been identified, where such information is specified;

b) where the ACM catalogue or the present document specifies a deprecation date, expiry date, migration condition or usage limitation for a cryptographic mechanism, this information is reflected in the documentation;

c) where a deprecation date, expiry date, migration condition or usage limitation falls within the intended lifetime of the product, the product provides an applicable mechanism for updating the cryptographic mechanism, using another cryptographic mechanism that complies with clause K.1.1 and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation, disabling the use of the affected cryptographic mechanism, or limiting the use of the affected product functions accordingly;

d) where another cryptographic mechanism is used, that cryptographic mechanism complies with clause K.1.1 and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation.

K.2.2.4 Assessment evidence

The assessment evidence shall include, as applicable:

a) documentation of the intended lifetime of the product;

b) list of cryptographic mechanisms used in the product's default configuration;

c) identification of the related product function(s) for each cryptographic mechanism;

d) references to the ACM catalogue entry or to the provision of the present document used to determine lifecycle information, where applicable;

e) identification of any deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product;

f) description of the means provided by the product, such as update of the cryptographic mechanism, use of another cryptographic mechanism that complies with clause K.1.1 and is not subject to the relevant lifecycle constraint, disabling the use of the affected cryptographic mechanism, or limitation of the use of the affected product functions.

K.2.2.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.2.1.
- The verdict FAIL shall be assigned otherwise.

K.3 ACM-extended cryptographic mechanisms

K.3.1 Requirement

Where the product's default configuration uses ACM-extended cryptographic mechanisms, these mechanisms shall comply with the ACM-extended criterion in clause K.1.1 item 2).

K.3.2 List of ACM-extended cryptographic mechanisms

No ACM-extended cryptographic mechanisms are specified.

K.3.3 Assessment

Compliance with the ACM-extended criterion in clause K.1.1 item 2) is assessed in clause K.1.2.2.

K.4 Interoperability-based cryptographic mechanisms

K.4.1 Requirement

Where the product's default configuration uses interoperability-based cryptographic mechanisms, these mechanisms shall be selected from the interoperability-based cryptographic mechanisms listed in clause K.4.2 for the specified product functions and external specifications or external requirements and shall be used in accordance with the conditions or limitations specified in clause K.4.2.

K.4.2 List of interoperability-based cryptographic mechanisms

No interoperability-based cryptographic mechanisms are specified.

K.4.3 Assessment

Compliance with the requirement in clause K.4.1 is assessed in clause K.1.2.3.

NOTE: The assessment of the external specifications or external requirements themselves is outside the scope of this assessment. Their relevance is deemed confirmed by their inclusion in the present document.

Annexes L to Q:
Void

Annex R (normative): Additional provisions for products relying on Remote Data Processing Solutions (RDPS)

R.1 Scope & Applicability

This annex specifies additional technical requirements and assessment provisions for products with digital elements that rely on Remote Data Processing Solutions ("RDPS") for the provision or support of one or more product functions.

The requirements applicable to the product functions remain specified in the core part of the concerned standard and continue to apply to the product as a whole, including where a product function is performed locally, supported by an RDPS, or performed in part through an RDPS.

This annex specifies supplementary requirements and assessment provisions for the product-facing RDPS boundary, i.e. for the additional attack surface, interactions, and dependency conditions introduced where a product function is performed or supported across the local product side and the RDPS side.

Where the product does not rely on remote data processing solutions for the provision or support of any product function, this annex is not applicable.

This annex does not extend to the full remote service environment or underlying third-party infrastructure, except to the extent necessary to define assumptions, dependencies, and assessment conditions relevant to the product-facing RDPS boundary and the secure operation of the RDPS-dependent product function.

R.2 RDPS as a product-boundary extension

When a product relies on RDPS for the provision or support of one or more product functions, the use of RDPS is considered, for the purposes of the present annex, to introduce an additional product-facing boundary and interface between the local product side and the RDPS side.

The present annex does not restate or replace the requirements applicable to the product function as such. It specifies only the supplementary requirements needed to address the increased attack surface introduced by the RDPS boundary.

The present annex therefore addresses the security implications introduced by that additional boundary and interface, including:

a) the exchanged interactions across the RDPS boundary;

b) the relevant product-side and RDPS-side endpoints; and

c) the dependency conditions arising where the secure operation of the product function relies on interactions across that boundary.

The scope of the present annex is limited to the RDPS interface between the local product side and the RDPS side.

For the purposes of the present annex:

- local product side means the product elements within the product boundary that participate in the interaction with the RDPS;
- RDPS means the remote data processing solution performing or supporting operations relevant to the RDPS-dependent product function;
- RDPS interface means the communication boundary between the product-side endpoint and the RDPS-side endpoint.

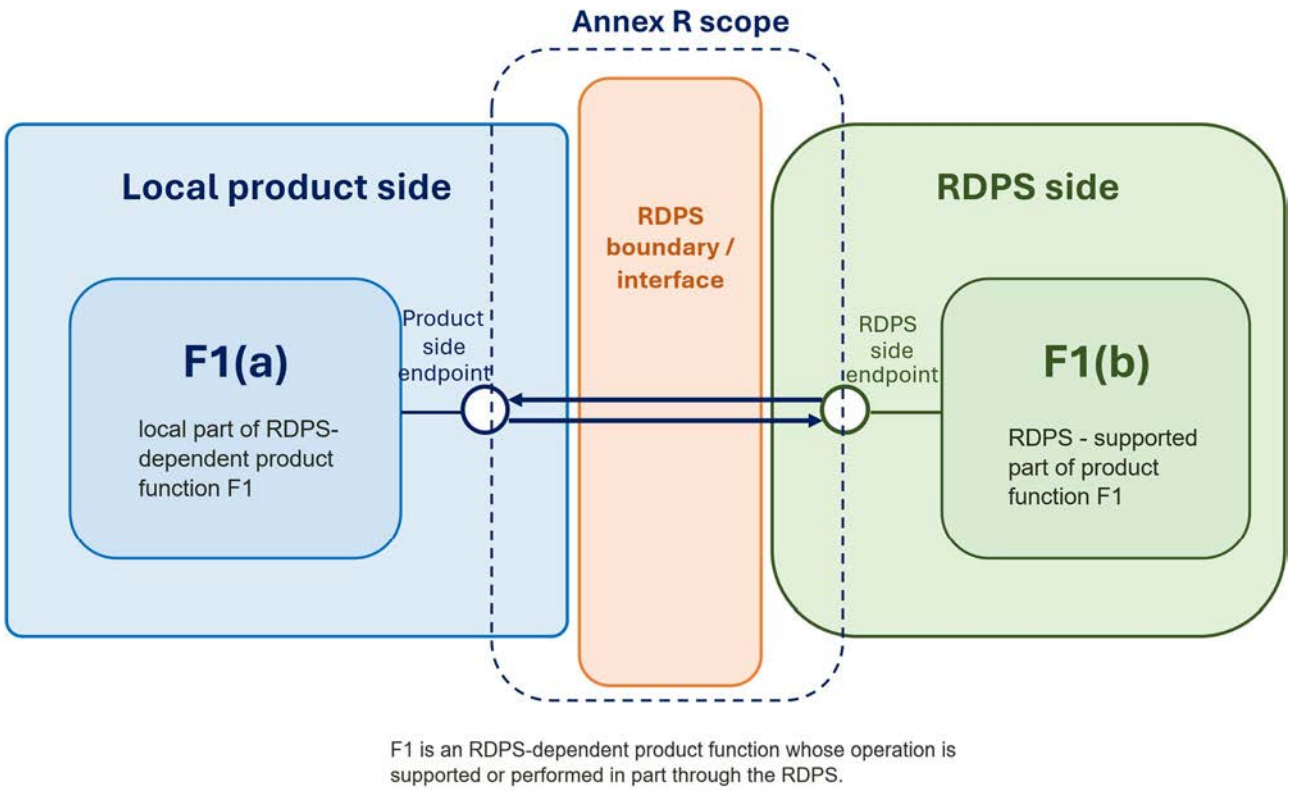


Figure R.2-1: RDPS model for annex R - scope focused on the product ↔ RDPS boundary

R.3 Threat Model

R.3.1 Introduction

This clause does not restate or replace threats for local product components that are already defined in the main clauses of the present document. Instead, it focuses on:

- threats introduced by the local product ↔ RDPS interface; and
- threats introduced by the RDPS as a remote service capability.

The threat model:

- identifies RDPS assets; and
- defines a set of threats applicable to RDPS.

R.3.2 Assets

The threat model considers the following assets:

DA-RDPS-001 - RDPS interaction content: The information exchanged across the RDPS boundary, including, as applicable, requests, commands, responses, decisions, configuration data, secrets, update-related data, and Personal Data where such data is exchanged.

For the purposes of DA-RDPS-001, table R.1 identifies potential categories of RDPS interaction content and indicates the security properties to be considered for each category when determining the applicable annex R requirement families.

Table R.3.2-1: Security properties for DA-RDPS-001

Content type	Data authenticity	Integrity	Confidentiality
Commands / requests & Responses / decisions	X	X	
Configuration data	X	X	
Secrets (e.g. keys)	X	X	X
Code or update data	X	X	
Confidential code or update data	X	X	X
Personal data		X	X

NOTE: In table R.3.2-1, "data authenticity" refers to the authenticity or trusted origin of the exchanged interaction content. It does not refer to authentication of the RDPS boundary endpoint.

DA-RDPS-002 – RDPS-dependent product function: product function for which one or more operations depend on an RDPS, including the associated security-relevant state, decisions, outputs, or configuration.

For the purposes of DA-RDPS-002, table R.3.2-2 identifies the security property relevant to the RDPS-dependent product function.

Table R.3.2-2: Security property for DA-RDPS-002

Content type	Availability
RDPS-dependent product function	X

R.3.3 Threat catalogue

R.3.3.1 Overview

The following threats constitute the baseline threat set considered for the RDPS boundary within the scope of annex R, covering the RDPS interaction content exchanged across the boundary and the availability of the RDPS-dependent product function.

R.3.3.2 T-RDPS-01 Loss of data authenticity of interactions across the RDPS boundary

An attacker causes an endpoint to accept interaction content across the RDPS boundary whose claimed source or origin is not genuine.

Threat type

Spoofing / impersonation

Security impact

The receiving endpoint may rely on interaction content that does not originate from the intended source, which can affect the behaviour, state, configuration, or security of the RDPS-dependent product function.

R.3.3.3 T-RDPS-02 Loss of integrity of interactions across the RDPS boundary

An interaction exchanged across the RDPS boundary is modified, substituted, injected, corrupted, or replayed before it is processed by the receiving endpoint.

Threat type

Tampering

Security impact

The receiving endpoint may act upon interaction content whose contents no longer correspond to what was sent or intended by the legitimate source, which can affect the behaviour, state, configuration, or security of the RDPS-dependent product function.

R.3.3.4 T-RDPS-03 Unauthorised disclosure of interactions across the RDPS boundary

Data exchanged across the RDPS boundary is disclosed to an unauthorised party.

Threat type

Information disclosure

Security impact

An attacker may obtain interaction content whose disclosure can affect the security or secure operation of the RDPS-dependent product function.

R.3.3.5 T-RDPS-04 Unavailability, unacceptable delay, or intolerable degradation of interactions across the RDPS boundary

The local product side or the RDPS side is unable to send, receive, or process interactions across the RDPS boundary, or receives interactions only after an unacceptable delay, or experiences degradation of communication performance across the RDPS boundary to an extent that is not tolerable for the successful operation of the RDPS-dependent product function.

Threat type

Denial of service

Security impact

The RDPS-dependent product function may fail to operate as intended, may operate with incomplete, outdated, or degraded information, may remain blocked, or may continue without the required interaction being available when needed.

R.3.4 Assets to Threats mapping

Table R.3.4-1: Assets to Threats mapping

Threat ID	Threat title	Related asset(s)
T-RDPS-01	Loss of data authenticity of interactions across the RDPS boundary	DA-RDPS-001
T-RDPS-02	Loss of integrity of interactions across the RDPS boundary	DA-RDPS-001
T-RDPS-03	Unauthorised disclosure of interactions across the RDPS boundary	DA-RDPS-001
T-RDPS-04	Unavailability, unacceptable delay, or intolerable degradation of interactions across the RDPS boundary	DA-RDPS-002

R.4 Security Requirements

R.4.1 Applicability of annex R requirements

The requirements in the present clause address the protection of the security properties identified for the assets in clause R.3.2.

Where a security property is identified as relevant for a given asset in the asset tables of clause R.3.2, the corresponding requirement family or families in the present clause shall be considered for applicability to that asset.

For **DA-RDPS-001**, the primary requirement families considered for applicability are:

a) data authenticity of interactions;

b) integrity of interactions; and

c) confidentiality of exchanged data.

For **DA-RDPS-002**, the primary requirement family considered for applicability is availability.

R.4.2 Local product side requirements

R.4.2.1 REQ-RDPS-L-AUTH Data authenticity of interactions received from the RDPS side

Before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, the local product side shall:

- verify that the interaction originates from the intended RDPS-side endpoint using mechanisms that provide assurance of origin commensurate with the security needs of the function, and
- detect and reject replayed or stale interactions where replay or reuse could affect secure operation.

Rationale

This requirement consolidates origin assurance and, where needed, replay protection into a single requirement.

R.4.2.2 REQ-RDPS-L-INTEG Integrity of interactions received from the RDPS side

The local product side shall verify that a received interaction has not been modified, substituted, corrupted, injected, or replayed in an unauthorised manner using integrity-protection mechanisms before acting upon it in a way that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function.

Rationale

This requirement provides stronger protection by requiring cryptographic integrity protection bound to the authenticated source, protects against loss of integrity of received interaction content, and protects from unauthorised modification or substitution of received interactions.

R.4.2.3 REQ-RDPS-L-CONF Confidentiality of data exchanged with the RDPS side

The local product side shall protect the confidentiality of data during exchange with the RDPS side where disclosure of data exchanged with the RDPS side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function.

Rationale

Confidentiality is not required for every exchange. However, where disclosure of data exchanged with the RDPS side could affect the security or secure operation of the RDPS-dependent product function, confidentiality protection is required.

R.4.2.4 REQ-RDPS-L-AVAIL Availability

The local product side shall detect unavailability of the RDPS side or unacceptable delay of an expected interaction where the availability or timeliness of interactions received from the RDPS side is necessary for the secure operation of the concerned product function, and apply a defined behaviour for the concerned product function.

NOTE 1: The defined behaviour may include, as defined for the concerned product function, denial of the affected interaction, limitation of the affected function, entry into a defined degraded mode, or transition to a secure state.

NOTE 2: Examples of such conditions include loss of connectivity to the RDPS side, failure to receive an expected response within the acceptable time, or repeated timeout of interactions required for the concerned product function.

Rationale

Where secure operation of the concerned product function depends on the availability or timely receipt of RDPS-side interactions, the local product side needs to detect unavailability or unacceptable delay and respond in a defined and secure manner.

R.4.3 RDPS side requirements

R.4.3.1 REQ-RDPS-R-AUTH Data authenticity of interactions received from the local product side

Before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, the RDPS side shall:

- verify that the interaction originates from the intended local product-side endpoint using mechanisms that provide assurance of origin commensurate with the security needs of the function, and
- detect and reject replayed or stale interactions where replay or reuse could affect secure operation.

Rationale

This requirement protects against acceptance of interaction content whose claimed source or origin is not genuine.

R.4.3.2 REQ-RDPS-R-INTEG Integrity of interactions received from the local product side

The RDPS side shall use integrity-protection mechanisms to verify that a received interaction has not been modified, substituted, corrupted, injected, or replayed in an unauthorised manner before acting upon it if that interaction could influence the behaviour, state, configuration, or security of the RDPS-dependent product function.

Rationale

This requirement protects against loss of integrity of received interaction content.

R.4.3.3 REQ-RDPS-R-CONF Confidentiality of data exchanged with the local product side

Where disclosure of data exchanged with the local product side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the RDPS side shall protect the confidentiality of that data during exchange with the local product side.

Rationale

This requirement ensures confidentiality where disclosure of exchanged data could affect the security or secure operation of the RDPS-dependent product function.

R.4.3.4 REQ-RDPS-R-AVAIL Availability

The RDPS side shall detect unavailability of the local product side or unacceptable delay of an expected interaction and apply a defined behaviour for the concerned product function where the availability or timeliness of interactions received from the local product side is necessary for the secure operation of the concerned product function.

NOTE 1: The defined behaviour may include, as defined for the concerned product function, rejection of the affected interaction, limitation of the service, termination of the affected exchange, or transition of the affected interaction to a secure state.

NOTE 2: Examples of such conditions include loss of connectivity to the local product side, failure to receive an expected request or input within the acceptable time, or repeated timeout of interactions required for the concerned product function.

Rationale

Where secure operation of the concerned product function depends on the availability or timely receipt of local product-side interactions, the RDPS side needs to detect unavailability or unacceptable delay and respond in a defined and secure manner.

R.4.4 Threats ↔ Requirements mapping

Table R.4.4-1: Threats ↔ Requirements mapping

Threat ID	Requirement(s) – Local product side	Requirement(s) – RDPS side
T-RDPS-01	REQ-RDPS-L-AUTH	REQ-RDPS-R-AUTH
T-RDPS-02	REQ-RDPS-L-INTEG	REQ-RDPS-R-INTEG
T-RDPS-03	REQ-RDPS-L-CONF	REQ-RDPS-R-CONF
T-RDPS-04	REQ-RDPS-L-AVAIL	REQ-RDPS-R-AVAIL

R.5 Conformity assessment

R.5.1 Overview

The assessment cases in the present clause are aligned with the requirements in clause R.4. Each assessment case follows a common structure: assessment reference, assessment objective, assessment preparation, assessment activities, assessment verdict, and assessment evidence.

R.5.2 Local product side assessments

R.5.2.1 REQ-RDPS-L-AUTH assessment

R.5.2.1.1 Objective

The objective of the assessment is to verify that the local product side verifies origin assurance for relevant received interactions using mechanisms commensurate with the security needs of the function and rejects replayed or stale interactions where required.

R.5.2.1.2 Preparation

- the RDPS-dependent product function;
- the relevant RDPS-side interactions that can influence the behaviour, state, configuration, security, or availability of that function;

- the intended RDPS-side endpoint for those interactions;
- the mechanism used by the local product side to determine or verify the origin of the received interaction.

R.5.2.1.3 Activities

- inspect the design and configuration of the mechanism used by the local product side to verify the origin or data authenticity of the relevant interaction;
- verify that the origin or authenticity check is performed before the interaction is acted upon;
- verify that interactions from the intended RDPS-side endpoint are accepted;
- verify that interactions not originating from the intended RDPS-side endpoint, or lacking required assurance of origin, are rejected or not acted upon;
- where replay or reuse could affect secure operation, verify that replayed or stale interactions are detected and rejected.

R.5.2.1.4 Verdict

Pass:

- the local product side verifies origin or data authenticity of the relevant interaction before acting upon it;
- interactions lacking the required assurance of origin are rejected or not acted upon.

Fail:

- the local product side acts upon a relevant interaction without verifying required origin or authenticity; or
- the required rejection of invalid, mis bound, replayed, or stale interactions is not enforced.

R.5.2.1.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery, or continuity behaviour for invalid or failure conditions, as applicable.

R.5.2.2 REQ-RDPS-L-INTEG assessment

R.5.2.2.1 Objective

The objective of the assessment is to verify that the local product side verifies integrity of relevant received interactions using mechanisms commensurate with the security needs of the function and rejects modified, substituted, corrupted, injected, duplicated, or replayed interactions where required.

R.5.2.2.2 Preparation

- the RDPS-dependent product function;
- the relevant RDPS-side interactions that can influence the behaviour, state, configuration, security, or availability of that function;
- the mechanism used by the local product side to detect modification, substitution, corruption, injection, duplication, or replay as applicable.

R.5.2.2.3 Activities

- inspect the design and configuration of the integrity-protection mechanism used by the local product side;
- verify that integrity verification is performed before the interaction is acted upon;
- verify that a valid interaction is accepted;
- verify that modified, substituted, corrupted, or injected interactions are rejected or not acted upon;
- verify that integrity protection is bound to the authenticated source where required, and that replayed or duplicated interactions are rejected where replay or reuse could affect secure operation.

R.5.2.2.4 Verdict

Pass:

- the local product side verifies integrity of relevant interactions before acting upon those interactions;
- modified, substituted, corrupted, injected, duplicated, or replayed interactions are rejected or not acted upon where required.

Fail:

- the local product side acts upon a relevant interaction without verifying required integrity; or
- the required rejection of altered, invalid, mis bound, duplicated, or replayed interactions is not enforced.

R.5.2.2.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery, or continuity behaviour for invalid or failure conditions, as applicable.

R.5.2.3 REQ-RDPS-L-CONF assessment

R.5.2.3.1 Objective

The objective of the assessment is to verify that, where disclosure of exchanged data could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the local product side protects the confidentiality of that data during exchange with the RDPS side.

R.5.2.3.2 Preparation

- the RDPS-dependent product function;
- the relevant RDPS-side interactions that can influence the behaviour, state, configuration, security, or availability of that function;
- the categories of exchanged data for which disclosure could lead to unacceptable cybersecurity risk;
- the mechanism used by the local product side to protect confidentiality during exchange.

R.5.2.3.3 Activities

- inspect the design and configuration of the confidentiality-protection mechanism used by the local product side;
- verify that the identified data is protected during exchange;

- verify that data designated as requiring confidentiality is not exchanged in an unprotected manner.

R.5.2.3.4 Verdict

Pass:

- the local product side protects the confidentiality of exchanged data where disclosure could lead to unacceptable cybersecurity risk;
- such data is not exchanged in an unprotected manner.

Fail:

- the local product side exchanges relevant confidential data without the required confidentiality protection; or
- protected data is disclosed to an unintended endpoint.

R.5.2.3.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery, or continuity behaviour for invalid or failure conditions, as applicable.

R.5.2.4 REQ-RDPS-L-AVAIL assessment

R.5.2.4.1 Objective

The objective of the assessment is to verify that the local product side detects unavailability, unacceptable delay, or intolerable degradation of required RDPS-side interactions, and applies a defined behaviour, including recovery or continuity measures where necessary.

R.5.2.4.2 Preparation

- the RDPS-dependent product function;
- the relevant RDPS-side interactions that can influence the behaviour, state, configuration, security, or availability of that function;
- the acceptable timing or service conditions for those interactions;
- the defined behaviour to be applied when the required interactions are unavailable, delayed, or degraded;
- the degraded behaviour, secure state, recovery support, or continuity mechanism required by the selected requirement.

R.5.2.4.3 Activities

- inspect the design and configuration of the timeout, timeliness, degradation-detection, or equivalent controls used by the local product side;
- verify that unavailability, unacceptable delay, or intolerable degradation of required interactions is detected;
- verify that a defined behaviour is applied when such conditions occur;
- verify that a defined degraded behaviour or secure state is applied where required;
- verify that recovery support is available and can be used to restore secure operation where required;

- where failover, redundancy, or equivalent resilience is required, verify that continuity of operation is supported when the primary interaction path becomes unavailable, delayed, or degraded.

R.5.2.4.4 Verdict

Pass:

- the local product side detects the specified failure, delay, or degradation conditions;
- a defined behaviour is applied when the identified conditions occur;
- recovery or continuity support is available and effective where required.

Fail:

- the local product side does not detect the relevant failure, delay, or degradation condition; or
- the required defined behaviour, recovery support, or continuity mechanism is absent or ineffective.

R.5.2.4.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery, or continuity behaviour for invalid or failure conditions, as applicable.

R.5.3 RDPS side assessments

R.5.3.1 REQ-RDPS-R-AUTH assessment

R.5.3.1.1 Objective

The objective of the assessment is to verify that the RDPS side verifies origin assurance for relevant received interactions using mechanisms commensurate with the security needs of the function and rejects replayed or stale interactions where required.

R.5.3.1.2 Preparation

- the RDPS-dependent product function;
- the relevant local product-side interactions that can influence the behaviour, state, configuration, security, or availability of that function;
- the intended local product-side endpoint for those interactions;
- the mechanism used by the RDPS side to determine or verify the origin of the received interaction.

R.5.3.1.3 Activities

- inspect the design and configuration of the mechanism used by the RDPS side to verify the origin or data authenticity of the relevant interaction;
- verify that the origin or authenticity check is performed before the interaction is acted upon;
- verify that interactions from the intended local product-side endpoint are accepted;
- verify that interactions not originating from the intended local product-side endpoint, or lacking required assurance of origin, are rejected or not acted upon;

- where replay or reuse could affect secure operation, verify that replayed or stale interactions are detected and rejected.

R.5.3.1.4 Verdict

Pass:

- the RDPS side verifies origin or data authenticity of the relevant interaction before acting upon it;
- interactions lacking the required assurance of origin are rejected or not acted upon.

Fail:

- the RDPS side acts upon a relevant interaction without verifying required origin or authenticity; or
- the required rejection of invalid, mis bound, replayed, or stale interactions is not enforced.

R.5.3.1.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery, or continuity behaviour for invalid or failure conditions, as applicable.

R.5.3.2 REQ-RDPS-R-INTEG assessment

R.5.3.2.1 Objective

The objective of the assessment is to verify that the RDPS side verifies integrity of relevant received interactions using mechanisms commensurate with the security needs of the function and rejects modified, substituted, corrupted, injected, duplicated, or replayed interactions where required.

R.5.3.2.2 Preparation

- the RDPS-dependent product function;
- the relevant local product-side interactions that can influence the behaviour, state, configuration, security, or availability of that function;
- the mechanism used by the RDPS side to detect modification, substitution, corruption, injection, duplication, or replay as applicable.

R.5.3.2.3 Activities

- inspect the design and configuration of the integrity-protection mechanism used by the RDPS side;
- verify that integrity verification is performed before the interaction is acted upon;
- verify that a valid interaction is accepted;
- verify that modified, substituted, corrupted, or injected interactions are rejected or not acted upon;
- verify that integrity protection is bound to the authenticated source where required, and that replayed or duplicated interactions are rejected where replay or reuse could affect secure operation.

R.5.3.2.4 Verdict

Pass:

- the RDPS side verifies integrity of relevant interactions before acting upon those interactions;
- modified, substituted, corrupted, injected, duplicated, or replayed interactions are rejected or not acted upon where required.

Fail:

- the RDPS side acts upon a relevant interaction without verifying required integrity; or
- the required rejection of altered, invalid, mis bound, duplicated, or replayed interactions is not enforced.

R.5.3.2.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery, or continuity behaviour for invalid or failure conditions, as applicable.

R.5.3.3 REQ-RDPS-R-CONF assessment

R.5.3.3.1 Objective

The objective of the assessment is to verify that, where disclosure of exchanged data could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the RDPS side protects the confidentiality of that data during exchange with the local product side.

R.5.3.3.2 Preparation

- the RDPS-dependent product function;
- the relevant local product-side interactions that can influence the behaviour, state, configuration, security, or availability of that function;
- the categories of exchanged data for which disclosure could lead to unacceptable cybersecurity risk;
- the mechanism used by the RDPS side to protect confidentiality during exchange.

R.5.3.3.3 Activities

- inspect the design and configuration of the confidentiality-protection mechanism used by the RDPS side;
- verify that the identified data is protected during exchange;
- verify that data designated as requiring confidentiality is not exchanged in an unprotected manner.

R.5.3.3.4 Verdict

Pass:

- the RDPS side protects the confidentiality of exchanged data where disclosure could lead to unacceptable cybersecurity risk;
- such data is not exchanged in an unprotected manner.

Fail:

- the RDPS side exchanges relevant confidential data without the required confidentiality protection; or
- protected data is disclosed to an unintended endpoint.

R.5.3.3.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery, or continuity behaviour for invalid or failure conditions, as applicable.

R.5.3.4 REQ-RDPS-R-AVAIL assessment

R.5.3.4.1 Objective

The objective of the assessment is to verify that the RDPS side detects unavailability, unacceptable delay, or intolerable degradation of required local product-side interactions, and applies a defined behaviour, including recovery or continuity measures where necessary.

R.5.3.4.2 Preparation

- the RDPS-dependent product function;
- the relevant local product-side interactions that can influence the behaviour, state, configuration, security, or availability of that function;
- the acceptable timing or service conditions for those interactions;
- the defined behaviour to be applied when the required interactions are unavailable, delayed, or degraded;
- the degraded behaviour, secure state, recovery support, or continuity mechanism required by the selected requirement.

R.5.3.4.3 Activities

- inspect the design and configuration of the timeout, timeliness, degradation-detection, or equivalent controls used by the RDPS side;
- verify that unavailability, unacceptable delay, or intolerable degradation of required interactions is detected;
- verify that a defined behaviour is applied when such conditions occur;
- verify that a defined degraded behaviour or secure state is applied where required;
- verify that recovery support is available and can be used to restore secure operation where required.
- where failover, redundancy, or equivalent resilience is required, verify that continuity of operation is supported when the primary interaction path becomes unavailable, delayed, or degraded.

R.5.3.4.4 Verdict

Pass:

- the RDPS side detects the specified failure, delay, or degradation conditions;
- a defined behaviour is applied when the identified conditions occur;
- recovery or continuity support is available and effective where required.

Fail:

- the RDPS side does not detect the relevant failure, delay, or degradation condition; or
- the required defined behaviour, recovery support, or continuity mechanism is absent or ineffective.

R.5.3.4.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery, or continuity behaviour for invalid or failure conditions, as applicable.

Annex S (informative): Change history

Version	Information about changes
V1.0.0	Final draft

History

Version	Date	Status
V1.0.5	August 2026	SRdAP process EV20261105: 2026-08-13 to 2026-11-05